Issues_Summary

Issues_Summary

Open workable items (current_location = Issues), regenerated from the SQLite single-source-of-truth (§11.4.12).

Counts by Type × Status

Type	Status	Count
Bug	In progress	11
Bug	Operator-blocked	1
Bug	Queued	43
Bug	Ready for testing	4
Task	In progress	12
Task	Queued	30
Task	Ready for testing	2
TOTAL		**103**

Items

ATM ID	Type	Status	Severity	Description
BOB-008	Bug	Operator-blocked	—	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): COMPLETE THE CAPTCHA FLOW ONCE** Session establishme path is DECIDED: the operator drives the interactive CAPTCHA flow at `/api/v1/auth/rutracker/captcha` then `/login` once, and the proxy stores the resulting `bb_session`. The co paste path and the cookies-file autoload path were both offered and NOT chosen. THE BLO

ATM ID	Type	Status	Severity	Description
				NARROWS BUT DOES NOT LIFT: the operator must physically drive the flow — no agent ca solve a CAPTCHA (§11.4.52 honest operator_attended boundary). AGENT PREP OWED BEFORE THE HAND-OFF, so the opera single attempt succeeds rather than discover broken endpoint mid-flow: verify both endpo are reachable and correctly wired end-to-enc verify the session is actually PERSISTED after successful post (not merely accepted), and ve a stored session is actually USED by a subseq search. Honest limitation to state up front: a stored bb_session expires, so this path requir repeating — that cost was accepted with the decision. This answer is recorded as consume DATA per §11.4.35 — it is the operator's state choice, not an agent inference, and supersede any prior agent-chosen default on this questi Options not chosen are named above so a fut reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline appl to decisions). — prior item text follows — RuTracker automated login blocked by CAPT
BOB-065	Task	Queued	High	Lava P2: Egress diagnosis and VPN-host SOC routing (containers pkg/egress)
BOB-066	Task	In progress	High	Lava P3: BOBA_UPSTREAM_PROXY in downl proxy + qBitTorrent-go + Jackett + compose e forward
BOB-068	Bug	In progress	High	RD2-00: unattributed, unreviewed Auto-com mechanism pushing to main
BOB-069	Task	In progress	High	RD2-40: §11.4.238 QA-discovery-channel ledg ongoing coverage-escape backfill
BOB-074	Task	In progress	Medium	RD2-07: DDoS-class testing fully absent from mandated test-type matrix
BOB-077	Task	Queued	High	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): UNKNOWN — INSTRUMENT THE NEXT OCCURRENCE** Th operator does not currently know which hos produces the +0500 Auto-commit fast-forwar so the three candidate answers (second Clau session / intentional rsync job / stale job) all

ATM ID	Type	Status	Severity	Description
				remain open. DECIDED ACTION: stop hunting host this session cannot reach (§11.4.6 — rem state is not knowable without access) and ins INSTRUMENT the mechanism so the next occurrence identifies itself. Forensic capture add: committer identity, hostname, timezone offset, push timing, and the git remote used, recorded at Auto-commit time into a tracked forensic log. ACCEPTANCE: the next Auto-con event yields a captured record naming its ori host — at which point this item resolves to or the three original branches with evidence rat than a guess. This is the §11.4.101 reversible- move: it costs little, blocks nothing, and conv a recurring mystery into a self-identifying ev This answer is recorded as consumer DATA p §11.4.35 — it is the operator's stated choice, r an agent inference, and supersedes any prior agent-chosen default on this question. Optior not chosen are named above so a future read does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisio — prior item text follows — RD2-10: Identify second host running the Auto-commit rsync/s mechanism (OPERATOR-DECISION)
BOB-078	Task	Queued	High	RD2-11: Once identified, wire Auto-commit mechanism through §11.4.234 dedicated com push script OR retire it
BOB-080	Task	Queued	High	RD2-13: Retroactive Fable-xhigh code review the substantive Auto-commit diffs
BOB-082	Task	Queued	High	RD2-15: Create BOB-064..067 workable items the four Lava-porting findings (closes GA-05)
BOB-085	Task	Queued	Medium	RD2-18: Create top-level Boba proxy/merge-service v1.0.0 readiness ledger (closes GA-10)
BOB-088	Task	Queued	Medium	RD2-21: Complete/verify README Tracked-It + Status Documents table row-completeness (GA-07 remainder)
BOB-090	Task	In progress	Medium	RD2-25: HelixQA Challenge entry exercising a three start.sh subcommands end-to-end agai real compose stack
BOB-093	Task		High	

ATM ID	Type	Status	Severity	Description
		In progress		RD2-28: Live compose bring-up + verify rutra ReDoS regex bounds deployed to container (closes runtime half of GA-12)
BOB-094	Task	In progress	Medium	RD2-29: Author tests/stress/ test_tracker_fetch_stress_chaos.py with §11.4 fault injection
BOB-095	Task	In progress	Medium	RD2-30: Author tests/stress/ test_scheduler_hooks_sse_stress_chaos.py for side triangle
BOB-097	Task	Queued	Low	RD2-32: Author DDoS-class coverage for expo download-proxy/merge endpoints (canonical impl of RD2-07)
BOB-100	Task	Queued	Low	RD2-39: Bump submodules/jackett one comm (canonical impl of RD2-09)
BOB-101	Task	Queued	High	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): DEFER PAST v1.0** Go `--profile go` parity remains a goal but is LONGER a v1.0.0 release blocker. RW-10..13 m to a post-1.0 milestone and stop gating the ta Nothing advertised is removed, so §11.4.122 s clean and no §11.4.90 Obsolete closure is warranted. The BOB-141 measured fact stand unchanged: the Go container's Dockerfile run ONE binary binding only :7187; nothing bind :7186 or :7188 despite compose setting PROXY_PORT/BRIDGE_PORT. CLAUDE.md's p map already describes what the container ACTUALLY does and needs no amendment u this decision. This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inferen and supersedes any prior agent-chosen defa on this question. Options not chosen are nam above so a future reader does not re-litigate settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior item follows — GA-19/RW-09: Is –profile go parity a release goal? (gates RW-10..13) — OPERATO DECISION
BOB-102	Task	In progress	Medium	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): KEEP 0.0.0.0 +**

ATM ID	Type	Status	Severity	Description
				MANDATORY AUTH GUARD The tunnel STA LAN-reachable — no bind address changes to 127.0.0.1. The operator explicitly chose to preserve access from other devices on the network. THE DECISION CARRIES A BINDING OBLIGATION: a permanent §11.4.135 regress guard MUST land that FAILS THE BUILD if an LAN-reachable route ever stops demanding authentication. The operator accepted 0.0.0.0 THE CONDITION that guard exists — without this decision is unprotected and the item is N closeable. Guard requirements: enumerate routes from the authoritative source (FastAPI app, Go handlers, boba-jackett) never a hand maintained list; resolve real auth coverage no grep for the string 'auth' (§11.4.201 real-condition); deliberately-public routes exempt ONLY via a checked-in list with per-entry justification, enumerated as honest gaps neve silent; golden-TRUE + golden-FALSE fixtures p §11.4.107(10). This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inferen and supersedes any prior agent-chosen defau on this question. Options not chosen are nam above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior item follows — RW-05: LAN-exposure threat mode bind tunnel 127.0.0.1 or keep 0.0.0.0? — OPERATOR-DECISION
BOB-104	Task	In progress	Medium	§11.4.238 followup: CodeGraph 1.5.0 nested-.gitignore regression challenge
BOB-106	Task	Queued	Medium	§11.4.238 followup: §11.4.84 quiescence-chec helper for the unattributed auto-commit path
BOB-107	Task	Queued	Medium	§11.4.238 followup: pre-dispatch existence ch for subagent task-brief source inputs
BOB-109	Task	Ready for testing	Medium	BOB-074 followup: scaling-class test coverage absent from mandated test-type matrix
BOB-110	Task	Queued	Medium	BOB-074 followup: UX-class test coverage (accessibility/usability) absent

ATM ID	Type	Status	Severity	Description
BOB-111	Task	In progress	High	BOB-074 followup: configure real rate limitin for boba's 3 public HTTP endpoints
BOB-114	Task	Queued	Medium	BOB-074 followup: self-validation golden-bad fixture for the rate-limit detector
BOB-121	Task	Ready for testing	Important	External watchdog for the forced-logout architectural gap (task #85, incident #3)
BOB-135	Bug	Ready for testing	Low	Test isolation: test_list_hooks_after_create fai bulk suite (Permission denied /config)
BOB-137	Bug	In progress	High	Merge service on 7187 wedges while the sam process still serves 7186 (GIL starvation by or spinning thread)
BOB-141	Task	Queued	Low	CLAUDE.md claims the Go profile serves 7186/7187/7188 but its container binds only 7 — doc contradicts the Dockerfile
BOB-143	Bug	Queued	Medium	Orphaned .worktrees/ dirs (46M, unresolvabl gitdir) pollute gate scan scope and manufactu false BOB-126-class findings
BOB-149	Bug	Queued	Low	Managed-plugin count diverges 43/42/48 acro constitution, CLAUDE.md and the README badge; the badge is hand-maintained and unguarded
BOB-150	Task	Queued	Low	pre_build_verification.sh invariant labels rea 44 but only 35 invariants are labelled
BOB-151	Task	Queued	Medium	CM-SCRIPT-DOCS-SYNC is a named gate with implementation, and 24 of 36 scripts have no companion doc
BOB-152	Bug	Queued	Medium	Constitution sweep walks vendored third-par code: 82% of one gate's 38,291 findings come from submodules/
BOB-154	Bug	Ready for testing	Medium	Host venv and production container run different starlette versions (1.4.1 vs 1.6.0)
BOB-156	Bug	Queued	Medium	BOB-145 event-loop regression guard is load-sensitive and flaky: 8786ms under host load v 900-1500ms ceiling calibrated on a quiet host
BOB-159	Bug	Queued	Medium	**OPERATOR DECISION (2026-08-26, §11.4.66) REPAIR, THEN RE-VERIFY UNTIL STABLE T** warm ./start.sh path keeps running the ownership repair against a live stack, but wa re-verifies, and repeats until a pass finds notl

ATM ID	Type	Status	Severity	Description
				new. Options not chosen: refuse the repair w the stack is up and direct the operator to –recreate; stop the stack on the warm path to (correct but ends 'warm'); accept and docum the window. WHY THIS MATTERS MORE THA NORMAL ITEM: this is the exact defect the wh 002-user-owned-downloads feature exists to The –recreate path was already fixed to order precondition -> down -> repair -> up so the w sees a tree no container can write. The warm path was not, so a container can create a new non-owned file AFTER the repair has passed directory — the ownership problem leaking b in through the other door. REQUIRED BY THE CHOSEN OPTION, and it is the hard part: the MUST be BOUNDED, and on giving up it MUS report honestly that ownership is UNPROVEN rather than silently exiting 0 (§11.4.201(6) — loop that stops finding new files because it ra out of iterations returns the same quiet zero genuinely clean tree). An active download creating files faster than the walk completes the realistic non-converging case and must b named in the give-up message. Recorded as consumer DATA per §11.4.35 — the operator' stated choice, not an agent inference. Options chosen are named so a future reader does no litigate a settled call. — prior item text follow **Reported-Via:** §11.4.202 reporting directive on 2026-08-21T19:01:17Z **Reported-By:** T041 independent review (IMPORTANT-2), partiall remediated **What (the report, verbatim):** Th –recreate path was fixed this round: run_ownership_precondition -> stack_down - run_ownership_repair -> stack_up, so the rep walks a tree no container can write to. That ordering is now asserted behaviourally by th new checks in tests/unit/ test_start_reload_recreate.sh, each killed by i paired 1.1 mutation (11/11 RED-OK). The WA path is NOT covered by that fix and this item tracks the remainder. On a warm ./start.sh th gate runs before THIS invocation brings anyt

ATM ID	Type	Status	Severity	Description
				up, but if the stack is ALREADY running, containers write while the repair walks. A container can then create a new non-operato owned file BEHIND the walk, after which the completion marker records complete over a t that is not, and those stragglers are never repaired without a manual –force. BOUNDED dismissed: after any successful pass the mark valid for the scope fingerprint and the repair short-circuits without walking (marker_is_va so the window requires a stale-or-absent mar AND a live stack together. Declaring a new sc entry re-arms the marker, which is exactly ho that combination arises in practice. NOT DON THIS ROUND, with the reason stated rather th hidden: the clean guard is a cheap marker-on probe mode on scripts/ownership_repair.sh t answers has-this-scope-been-repaired withou walking the tree. The existing –dry-run canno serve: it deliberately SKIPS the marker fast-p (FORCE=0 && DRY_RUN=0 guard) and always walks, so using it as a warm-start probe woul walk the tree twice on every start. Adding tha mode requires editing ownership_repair.sh, which another stream was actively editing during this round; duplicating marker_is_val into start.sh instead would be a near-identica fork (11.4.251). Deferred to this item rather th done unilaterally or silently. The misleading comment at the warm-start call site (which claimed the gate runs before any container writes) has been corrected to state this bound honestly. **Affected scope / file-scope manife** start.sh (warm-start dispatch, run_ownership_gate call site); scripts/ ownership_repair.sh (marker fast-path) **Reproduction / context:** 1. Ensure the stack UP. 2. Change config/owned_paths.yaml so the scope fingerprint changes (this re-arms the marker by design, data-model E2). 3. Run a warm ./start.sh (no –recreate). 4. The owners repair walks and chowns the declared tree w containers are still running and able to write

ATM ID	Type	Status	Severity	Description
				it. **Acceptance criteria:** A warm ./start.sh car complete an ownership repair while a contai that writes to a declared location is running. Either the repair is deferred with an actionab refusal naming –recreate, or the stack is quie for the walk. Asserted behaviourally in tests/ test_start_reload_recreate.sh alongside the existing PRECONDITION_BEFORE_DOWN / REPAIR_AFTER_DOWN / REPAIR_BEFORE_UP checks, each with a paired 1.1 mutation that it.
BOB-160	Task	Queued	Medium	**Reported-Via:** §11.4.202 reporting directive on 2026-08-21T19:02:48Z **Reported-By:** AI **W** **(the report, verbatim):** Independent §11.4.2 review (IMPORTANT-3) found two of the feat strongest automated checks were never exec by any runner: (1) tests/ownership/ test_container_writes_owned_files.py — the §11.4.115 RED-turned-regression-guard for FR-011/FR-007, proven via a docker-compose revert mutation — was moved out of tests/ integration/ (commit 58d340a, to escape an autouse fixture hang) but no runner (ci.sh, test.sh, run-all-tests.sh) was ever extended to cover tests/ownership/. (2) tests/pre_build/ test_*.sh, the §1.1 paired-mutation meta-tests fo the scripts/pre_build/check_cm_*.sh gate family was executed by NOTHING — self-reported honestly in commit 04742d7's own message ('STILL OPEN (reported, not fixed): tests/ pre_build/ is executed by NOTHING') but nev tracked as a workable item (a §11.4.197 loss-o requirements gap) and never wired into scrip pre_build_verification.sh invariant 30, which globbed only tests/unit/test_*.sh. **Affected scop file-scope manifest:** *ci.sh; scripts/ pre_build_verification.sh invariant 30 (CM-BA UNIT-TESTS-EXECUTED)* **Reproduction / context:** *grep -rn test_container_writes_owned_files ci.sh test.sh run-all-tests.sh scripts/ returned zero runner h (only docs/specs mentioned the path); grep in*

ATM ID	Type	Status	Severity	Description
				*scripts/pre_build_verification.sh showed invar 30's for-loop globbing only tests/unit/test_*.sh, never tests/pre_build/test_*.sh. **Acceptance criteria:** ci.sh gains a runtime-gated pytest te ownership/ stage (skips honestly, rc=0, when n podman/docker present); scripts/ pre_build_verification.sh invariant 30's glob co both tests/unit/test_*.sh and tests/pre_build/ test_*.sh, verified by an extracted standalone of the invariant's exact block reporting a non zero RAN count that includes files from both directories.
BOB-161	Task	Queued	High	**Reported-Via:** §11.4.202 reporting directive on 2026-08-21T19:31:12Z **Reported-By:** BOB-(remediation, residual finding **What (the rep verbatim):** §11.4.69 names CM-NO-FAIL-OPE SKIP as one of three mandatory pre-build gat it audits sink-side probe helpers and FAILs if code path converts an empty or unreachable response into a PASS-counting SKIP for a feat class with a sink-side probe. This project does have it. Why this matters now rather than in abstract: the BOB-092 remediation just remov TWO fail-opens of exactly this class from test e2e/test_live_stack_evidence.py — the nnmclu SKIP-on-404 (already removed at 7baef2b) ar surviving sibling at test_iptorrents_is_authenticated_in_search th skipped on 'not authenticated and status != success' while asserting 'treating as transient outage'. That assertion was false for rejected credentials (upstream_http_403) and for a broken container (plugin_env_missing), both which are definitive product failures the prod already classifies via error_type. Two fail-ope of one class, found one at a time, is the §11.4. extend-to-all-cases signal and the §11.4.238 coverage-escape signal together: the regime d not surface either, an agent reading code did. remediation's own guards are AST-structural lethal under three discriminating mutations, they LIVE IN THE FILE THEY GUARD, so delet

ATM ID	Type	Status	Severity	Description
				that file evades them entirely. A pre-build gat the durable home because it audits the corpu rather than one file. Honest boundary (§11.4. this item does NOT claim the two remediated opens are unguarded — they are guarded, wi runtime evidence (13 passed in 97.36s agains live stack). It claims the CLASS has no corpus wide detector, so the next instance in a differ file is invisible again. **Affected scope / file-sc manifest:** scripts/pre_build/ (gate absent); tes e2e/test_live_stack_evidence.py (guards curre live inside the file they guard) **Reproduction context:** grep -rl 'CM-NO-FAIL-OPEN-SKIP' scripts/ tests/ returns exactly ONE hit, and it i tests/e2e/test_live_stack_evidence.py — the fi the guards live in, not a gate. Control needle: same query for CM-OWNERSHIP-INVARIANT gate that does exist) returns 3 files, so the instrument can see gate tokens and the single is a real absence, not a blind zero (§11.4.201((b)). **Acceptance criteria:** A scripts/pre_build gate named CM-NO-FAIL-OPEN-SKIP exists, is wired into scripts/pre_build_verification.sh, a audits sink-side probe helpers for code paths converting an empty/unreachable/error resp into a PASS-counting SKIP for a feature class HAS a sink-side probe. It ships a golden-TRUE fixture (a real fail-open -> gate FIRES) and a golden-FALSE-with-carrier (an honest topolog geo skip, and a comment merely MENTIONIN the phrase -> gate MUST NOT fire), per §11.4.107(10)/§11.4.201(1). Paired §1.1 mutati makes the gate FAIL before the gate is trusted
BOB-162	Task	Queued	Medium	**Reported-Via:** §11.4.202 reporting directive on 2026-08-21T19:35:02Z **Reported-By:** BOB-1 BOB-107 remediation, residual **What (the report, verbatim):** The TESTS for both guard are now executed: pre-build invariant 30's gl was extended from tests/unit + tests/pre_buil also cover tests/hooks. MEASURED before/aft the glob expanded to 27 suites with 0 under t hooks while 3 existed there; it now expands t

ATM ID	Type	Status	Severity	Description
				with 3 under tests/hooks. All three pass. But t GUARDS themselves are still invoked by noth check-brief-inputs.sh is honestly conductor-r rather than automatic: a brief's required-inp list lives in free-form prose that the Agent too structured input does not expose, so an automatic prompt-scraping gate would itself an unproven pattern-match. Its seam is the dispatch procedure, and that is a documenta + habit change, not a hook. unattributed-com guard.sh is different and is why this item exis Run against real history it names 14 violating commits since the last tag (and 21 bare Auto-commit subjects exist across all refs). Wiring into the pre-build or commit seam AS-IS wou therefore refuse every commit immediately, pre-existing debt nobody can fix in the mome That is precisely the 11.4.224(E) brownfield-adoption shape, and 11.4.66/11.4.122 put the choice with the operator, not with an agent inventing a ratchet. The options, stated so the decision is a decision and not a default: (a) immediate hard floor – the seam refuses unti 14 are attributed; (b) one-time monotone-decrease ratchet (the 11.4.135 pattern) – snap 14 as the baseline, the count may fall and ma never rise, so day one is green and the diseas cannot spread; (c) changed-commits-only – ga only commits created from now on, with a scheduled deadline for the historical 14; (d) report-only for a stated period, then escalate. Recommendation, with the reasoning rather just the pick: (b). It is the pattern this constitu already uses for exactly this situation, it mak the debt visible and bounded immediately, ar cannot be satisfied by deleting the guard's na (11.4.227 closes that gaming channel). But it i operator's call and this item is not closed unt that answer is recorded. Honest boundary (11.4.6): this item does NOT claim the 14 com are harmful in themselves – it claims their ATTRIBUTION is absent and that nothing currently prevents the 15th. **Affected scope /**

ATM ID	Type	Status	Severity	Description
				file-scope manifest: scripts/hooks/unattribu commit-guard.sh; scripts/hooks/check-brief-inputs.sh; scripts/pre_build_verification.sh; scripts/commit-push-all.sh **Reproduction / context:** Both guards run correctly by hand a are covered by passing tests (9/9 and 15/15, ea proven non-bluff against a no-op stub). Neith invoked by scripts/pre_build_verification.sh o scripts/commit-push-all.sh, so neither exerts standing detection pressure (11.4.226: a guar with no execution seam is not coverage; registration is not coverage). **Acceptance criteria:** Each guard is invoked by a named seam, OR carries a registered deferral pointin this item. For unattributed-commit-guard.sh specifically, the operator has answered the adoption question below and the answer is recorded as consumer DATA – never an inver ratchet.
BOB-163	Bug	In progress	Medium	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): YES — 429 IS RESPONSIVE IF Retry-After IS WELL-FORM** A 429 carrying a VALID Retry-After header counts as the sibling endpoint being RESPONSIVE. Assertion (c) of the DDoS challe accepts 2xx OR a well-formed 429 (positive integer seconds or valid HTTP-date — PARSE not merely present/non-empty). DEGRADED remains: connection failure, timeout, any 5xx and a 429 with absent or malformed Retry-A RESIDUAL RISK, accepted knowingly and to b stated in the script source per §11.4.6: a genuinely wedged endpoint that happens to answer 429-with-Retry-After would pass — th Retry-After parse narrows that window, it do not close it. Options (b) limiter-aware drain a (c) exempt healthz probe were both offered a NOT chosen. STILL OPEN, not covered by this decision: the detector counts 429 only, not 50 though the script header says ‘429 (or equivalent)’; counting 503 would collide with crash detector’s 5xx tally. Decide when BOB-1

ATM ID	Type	Status	Severity	Description
				lands limiters on :7185 and :7189. This answe recorded as consumer DATA per §11.4.35 — i the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader d not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisio — prior item text follows — **Reported-Via:** §11.4.202 reporting directive bug on 2026-08-21T19:41:08Z **Reported-By:** BOB-114 remediation, pre-existing defect surfaced by BOB-111 landing a real limiter **What (the rep verbatim):** PRE-EXISTING, NOT INTRODUCE and proven so rather than asserted: git diff shows assertion (c) is BYTE-IDENTICAL to HE and the failure reproduces against the unmodified HEAD script. What changed is no the challenge but the SYSTEM: BOB-111 appe at least partially delivered, because :7187 nov returns real 429s where it previously returne none. :7185 and :7189 still produce zero 429s This is a 11.4.248-class corrosion risk and tha why it is filed rather than left as a footnote: run_all_challenges.sh will now fail INTERMITTENTLY, and an intermittent red tr everyone to re-run until green, at which poir real regression is dismissed as 'probably the flaky rate-limit one'. THE DECISION, which is operator call under 11.4.66 and which I deliberately did NOT invent: Does a 429 from WORKING limiter count as the sibling endpoi being RESPONSIVE? (a) YES – a 429 proves th endpoint is alive and correctly protecting itse Assertion (c) accepts 2xx OR 429, and only a connection failure / 5xx / timeout counts as degraded. Risk: a genuinely wedged endpoin that happens to answer 429 would pass. (b) N keep requiring 2xx, but make the challenge limiter-aware: drain or wait out the window before the sibling probe (retry-after is served the budget is knowable rather than guessed). Probe siblings on a path the limiter exempts

ATM ID	Type	Status	Severity	Description
				healthz-class route), so the isolation question asked without spending the bucket. Recommendation with reasoning, not just a p (a) composed with a bounded liveness check 429 carrying a well-formed Retry-After IS evidence of a live, correctly-behaving service and (b) makes the challenge slower and coup it to a window value that will drift. But the semantics of 'responsive' here are a product judgement, so the answer is recorded, not assumed. RELATED, stated as fact rather than folded in: the detector counts 429 only, not 50 though the script header says '429 (or equivalent)'. Counting 503 would collide with crash detector's 5xx tally. Worth deciding wh BOB-111 lands limiters on :7185 and :7189. **Affected scope / file-scope manifest:** challer scripts/ddos_resilience_challenge.sh assertion cross-endpoint isolation; run_all_challenges.s which invokes it **Reproduction / context:** Assertion (c) requires a sibling-endpoint prob answer ^2 (a 2xx). :7187 now enforces a real limiter (measured live: x-ratelimit-limit: 120, ratelimit-remaining: 86, retry-after: 45, serve uvicorn). A full challenge run sends roughly requests to :7187, so sibling probes fired duri the OTHER endpoints' tiers land on an exhau bucket and receive 429 – which assertion (c) scores as 'endpoint degraded'. Timing-dependent: one run measured PASS=5 FAIL= the UNMODIFIED HEAD script against the sa live stack ~30s later measured PASS=7 FAIL=(SKIP=2. **Acceptance criteria:** The operator h answered the classification question below, t answer is recorded as consumer DATA, and assertion (c) implements it. The challenge the produces the same verdict across 3 consecuti runs against a rate-limited stack (11.4.50 deterministic consistency), and the fix ships a paired 1.1 mutation proving assertion (c) still catches a genuinely degraded sibling endpoi narrowing it must not blind it (11.4.201(1)).

ATM ID	Type	Status	Severity	Description
BOB-164	Bug	In progress	Medium	**Reported-Via:** §11.4.202 reporting directive on 2026-08-21T19:56:53Z **Reported-By:** BOB-UX-class coverage, discovered by the new axe core suite on its first live run **What (the repo verbatim):** This is a REAL user-facing defect, a test-tuning artifact, and it was found by the automated regime rather than by a human squinting at the page – which is exactly the 11.4.238 posture the project is aiming for. The static-grep oracle would NOT have found it. Measured: the served root ships an empty pr hydration, so any check reading the raw HTM audits a page nobody sees. The violation only exists in the hydrated DOM, which is why 11.4.170 requires a rendered oracle and forb value-equality assertions as the proof a UI is correct. Severity reasoning, stated rather tha assumed: this is user-visible and affects the primary dashboard heading, but it degrades legibility rather than breaking function, and surface is operator-facing rather than public. Medium, not High. The failing test was left FAILING on purpose (11.4.238) instead of silenced or marked xfail. tests/ux/ currently reports 1 failed, 16 passed; that 1 is this defec Anyone reading a red UX suite should read it this item, not as flakiness – and when this is f the suite goes fully green, which is the signal it is closed. HONEST SCOPE LIMIT (11.4.6): or the dashboard landing view was scanned. Th jackett/* sub-routes and the ng-serve-hosted :4200 route set were NOT audited – the commands to close both are recorded in docs testing/ux_accessibility.md. So this item's 21 nodes are a floor, not a total. **Affected scope file-scope manifest:** the Angular dashboard served at http://localhost:7187/ (same compile SPA as frontend/); production component CS not test files **Reproduction / context:** Run te ux/test_live_dashboard_accessibility.py again the running merge service. axe-core v4.13.0, scanning a real Playwright-rendered JS-hydra DOM, reports color-contrast violations on 21

ATM ID	Type	Status	Severity	Description
				nodes. Measured pairs: .brand / h1 text #9d00 on background #3c3f41 = 1.43-1.62:1 (WCAG A large-text floor is 3:1); tagline #808080 on #3c = 2.68:1 (body-text floor is 4.5:1). **Acceptance criteria:** axe-core reports ZERO color-contras violations against the live rendered dashboar with the fix made in production component C rather than by relaxing the assertion or excluding the rule (11.4.120: reconcile to the correct mechanism, never weaken the check) The existing tests/ux/ suite is the guard and already fails today, so the RED is captured – closure requires it flipping GREEN against th live surface, which is runtime-class evidence 11.4.226.
BOB-165	Bug	Queued	High	**Reported-Via:** §11.4.202 reporting directive t on 2026-08-21T20:00:08Z **Reported-By:** surfa while capturing closure evidence for BOB-09 diagnosed rather than worked around **What report, verbatim):** This is a STALE-ABI-AFTE INTERPRETER-UPGRADE defect, not a missin package. The package is installed; its compile half is built for the previous interpreter. That distinction matters because 'pip install rpds-p style advice can appear to succeed while leav the 313 artefact in place. WHY IT WAS NOT NOTICED EARLIER, stated as fact: the paths th DO work all avoid system python3. ci.sh selec an interpreter through _select_python; the lo running suites in this session ran .venv/bin/ python -m pytest and passed. So the automate regime is green while the DOCUMENTED operator command is broken – an 11.4.238-shaped gap, since the escape was found by an agent capturing evidence rather than by the regime. WORKAROUND (measured, not theorised): PYTEST_DISABLE_PLUGIN_AUTOLOAD=1 wit the needed plugins passed explicitly (-p pytest_timeout ...) avoids the schemathesis autoload that drags in jsonschema -> referen -> rpds. That is a workaround, NOT the fix: it

ATM ID	Type	Status	Severity	Description
				silences the import path rather than repairin the install, and it will surprise the next perso who runs the documented command verbati RELATED, and worth deciding together rathe than twice: BOB-154 wants .venv rebuilt on 3 to match the container (which runs CPython 3.12.13 while both system and venv run 3.14. There are therefore THREE interpreters in pl Whoever rebuilds the venv should confirm r resolves for the TARGET interpreter afterwar or this same class reappears one directory ov HONEST BOUNDARY (11.4.6): this item does N claim any test is wrong or any product code i broken. The product and the venv-run suites unaffected. What is broken is the documente entry point. **Affected scope / file-scope manifest:** host user site-packages (~/.local/lib python3/site-packages/rpds/); every CLAUDE. documented ‘python3 -m pytest …’ invocatio any tooling that uses system python3 rather than .venv/bin/python **Reproduction / conte** python3 -m pytest tests/e2e/ test_live_stack_evidence.py -q –import-mode=importlib -> ModuleNotFoundError: N module named ‘rpds.rpds’, raised during collection via the schemathesis plugin autolo -> jsonschema -> referencing._core -> rpds. MEASURED root cause: system python3 is 3.1 but ~/.local/lib/python3/site-packages/rpds/ sh rpds.cpython-313-x86_64-linux-gnu.so – an extension built for 3.13. rpds/**init**.py does ’from .rpds import *‘, and a 313-tagged .so is importable by 3.14, so the submodule genuin does not exist for this interpreter. The venv is CORRECT and unaffected: .venv/lib64/python site-packages/rpds/ ships rpds.cpython-314-x86_64-linux-gnu.so and’.venv/bin/python -c import rpds’ succeeds. **Acceptance criteria:** python3 -m pytest tests/unit/ -v –import-mode=importlib – the command CLAUDE.md documents – reaches collection without ModuleNotFoundError, OR CLAUDE.md is corrected to document the supported runner

ATM ID	Type	Status	Severity	Description
				explicitly. Either way the documented comma and the working command agree (11.4.99: a guide that misleads is the documentation-lay equivalent of a PASS-bluff). WORKAROUND S EFFECTS MEASURED 2026-08-21 — the recipe not free, and the item previously implied it w PYTEST_DISABLE_PLUGIN_AUTOLOAD=1 disables ALL plugin autoload, not just the bro one, so anything the suite silently relied on m be re-enabled by hand: - It BREAKS 5 pre-exis env-dependent tests in tests/unit/ test_plugin_rutracker.py — TestConfig::test_default_mirrors, test_env_mirrors_override, test_get_env_with_default, test_get_mirrors_from_env_empty, test_get_mirrors_from_env_whitespace — wh need an autoloaded env plugin. PROVEN not caused by any in-flight change: running HEA OWN copy of that file under identical flags produces the same 5 failures. - It makes –timeout=60 (set in pyproject.toml) an UNKNOWN ARGUMENT unless -p pytest_time is passed explicitly, so pytest.mark.timeout is silently inert under the naive recipe — a test believed to be time-bounded is not. - With autoload ON and only schemathesis disabled no:schemathesis), that same file is 96/96 gree CONSEQUENCE FOR ANYONE USING THE WORKAROUND: `-p no:schemathesis` alone is strictly better than blanket autoload-disablin where it suffices, because it removes only the broken plugin. Where the blanket form IS us -p pytest_timeout must be added or timeouts inert, and the 5 env-dependent failures must recognised as workaround artifacts rather th filed as defects. That last point is the real risk workaround manufactures failures that look exactly like product defects. This does not ch the root cause (the venv's rpds ships a cpython-313 ABI tag CPython 3.14 cannot imp or the fix (rebuild the venv — BOB-154). It documents that the interim recipe has a blas

ATM ID	Type	Status	Severity	Description
				radius, so nobody reads a workaround artifa a regression.
BOB-167	Bug	Queued	Medium	WHAT. download-proxy exposes two Server-S Events routes. They are the same expensive c — long-lived connections that hold a worker a generator for their lifetime — but only one rate-limit classed: routes.py:801 @router.get(' search/stream/{search_id}') @_rl('sse_stream classed routes.py:150 @router.get('/theme/ stream') async def stream_theme(...) <- NO limiter decorator _rl(cls) resolves to limiter.limit(limit_for(cls)), so /search/stream bound to the sse_stream class while /theme/ stream falls through to the application defaul Measured live on the running stack: /api/v1/ theme/stream reports x-ratelimit-limit 120. PROVENANCE + A CORRECTION WORTH KEEPING (§11.4.6). This was surfaced by the BOB-109 scaling agent, whose report framed 'sse_stream_limit_decorator is defined and imported/applied nowhere ... SSE falls throug the 120/minute default: 24x less protected'. Th framing is WRONG and was NOT filed as give The agent searched for one symbol NAME; th wiring uses a different mechanism (@_rl('sse_stream')), and it IS applied — to / search/stream. Verified by reading routes.py:795-806 and the _rl helper at routes.py:46-51, with a control needle confirm other *_limit_decorator symbols show real us in api/**init**.py so the zero-hit was not a blind search. The agent's MEASUREMENT (120 on / theme/stream) was correct and is what make this a real finding; its MECHANISM was not. B halves are recorded so the next reader does n re-derive the same wrong cause. WHY IT MATTERS. An unclassed SSE endpoint is the cheapest way to pin server resources: each connection is held open, and the default class permits 120/min of them. The declared sse_stream class exists precisely because this route shape needs a tighter bound than ordin

ATM ID	Type	Status	Severity	Description
				GETs. ACCEPTANCE. (a) A decision, recorded, whether /theme/stream belongs in the sse_str class or genuinely warrants the default — thi a policy question, not automatically a bug to patch. (b) If it belongs in sse_stream, the decorator is applied and a test drives BOTH S routes and asserts each returns its INTENDE class limit from x-ratelimit-limit, so a future route added without a class is caught. (c) A gu that enumerates SSE-shaped routes and fails any that carries no explicit rate-limit class — general form, so the third SSE route does not repeat this. (d) Honest boundary: this does no claim 120/min is exploitable in this deployme with network_mode host and no reverse pro every caller shares the 127.0.0.1 bucket, whic BOB-111 measured and recorded separately. CLAIMED. No change made. The limit values were read from headers, never driven to exhaustion — the limiter is per-IP and shared with concurrent agents on this host (§11.4.11
BOB-168	Task	In progress	Low	WHAT. scripts/run_all_challenges.sh:66 lists “scaling_horizontal_challenge.sh” in its challe set. challenges/scripts/ scaling_horizontal_challenge.sh does not exis sed -n ‘66p’ scripts/run_all_challenges.sh “scaling_horizontal_challenge.sh” $ ls challen scripts/scaling_horizontal_challenge.sh ls: ca access …: No such file or directory VERIFIED independently, not taken on report — surface by the BOB-109 scaling agent and re-checked here by direct invocation. WHY IT MATTERS. Whether this is cosmetic or a §11.4.201 gate-honesty defect depends entirely on how the runner treats a missing entry, and that is the thing to determine: if it SKIPs silently, the challenge bank advertises coverage it does no have (a §11.4.266 claim-vs-reality row with n passing challenge behind it); if it FAILs, the runner is permanently red for a reason unrelated to the system under test, which tra readers to ignore it. Neither outcome is

ATM ID	Type	Status	Severity	Description
				acceptable; they need different fixes. ACCEPTANCE. (a) Determine and record the runner's actual behaviour on the missing ent by invoking it, not by reading it. (b) EITHER author the challenge, OR remove the entry — with §11.4.124 discipline: check git history fo whether it once existed and was deleted, sinc silently-dropped challenge is the more interesting defect. (c) If the runner silently sk missing entries, that is its own finding: a miss challenge must be loud (§11.4.3 SKIP-with-rea at minimum), never absent-and-quiet. SEVER Low as a defect, but it sits on the challenge-coverage seam, so (c) may deserve its own ite CORRECTION 2026-08-22 (§11.4.6) — THIS ITI PREMISE WAS FALSE, and the error was min Recorded openly rather than quietly edited. scaling_horizontal_challenge.sh EXISTS. It is a submodules/challenges/challenges/scripts/ scaling_horizontal_challenge.sh, executable, bytes, dated Aug 7. So do all 14 other entries a the meta-runner. It was never deleted: added the roster at 1c959ba, the challenge itself add in the submodule at 873c0b1, and a pickaxe search across both repositories and all branc finds ZERO deletions. HOW I GOT IT WRONG run_all_challenges.sh reads submodules/ challenges/challenges/scripts/. I checked challenges/scripts/ — a DIFFERENT directory belonging to a DIFFERENT, glob-based runne Two similarly-named directories; I measured wrong one. That is a §11.4.201(9) field-identit error. Worse, I wrote that it was "verified by invocation": I had listed a directory and neve run the aggregator, so the claim overstated th evidence class as well as getting the answer wrong. THE LESSON, which generalises past item. In the SAME commit I correctly caught sibling agent making this exact class of error BOB-167 — a zero-hit produced by searching symbol name — and applied a control needle there. Then I omitted the needle one paragra later on my own measurement. The distinctio

ATM ID	Type	Status	Severity	Description
				that would have caught it: A CONTROL NEED PROVES THE INSTRUMENT CAN SEE; IT DOES NOT PROVE IT IS POINTED AT THE THING UNDER TEST. §11.4.201(7)(b) as commonly applied guards blindness; it does not guard n aiming. The needle for THIS query would hav been to resolve the path the runner itself rea not to confirm that some directory listing wo WHAT IS ACTUALLY WRONG, and it is worse than what I filed. The missing-entry path run challenges by definition, so it can be exercise safely. Run against a checkout where the submodule is absent — the ordinary state of clone made without –recursive — the REAL runner (byte-identity sha-asserted, not a repl reports: PASS: 0 FAIL: 0 SKIP: 16 TOTAL: 16 OBSERVED EXIT CODE: 0 An ENTIRELY UN-R BANK REPORTS SUCCESS. Not one dangling e tolerated — the whole suite silently passes without executing anything. That is §11.4.201 false-null verbatim, and it is observed-reacha rather than constructed (§11.4.115(G)). REVIS ACCEPTANCE. (a) ANSWERED, though not as filed: the runner reports a loud, counted SKI and then never blocks, because the exit expression reads only the FAIL count. (b) The dangling-entry half is VOID — nothing is dangling. (c) The real work is the exit contrac roster entry the runner cannot execute must be indistinguishable from a healthy run. See decision recorded in docs/qa/BOB-168/ decision_missing_vs_skip.md. RELATED, REPORTED NOT FIXED: scripts/ pre_build_verification.sh:1792 carries the sa SKIP/MISSING conflation one level up, for the other runner. Filed separately.
BOB-169	Bug	In progress	Medium	WHAT. The §11.4.65 markdown-export mand requires every in-scope doc to ship .html/.pdf twins. 286 of the 326 .html files under docs/ (excluding dist/ and node_modules/) are panc FRAGMENTS — they begin at
BOB-170	Task	Queued	Medium	

ATM ID	Type	Status	Severity	Description
				WHAT. The BOB-109 scaling suite gates its tw timing tests on loadavg_1m/nproc <= 0.75 — o this 8-cpu host, a 1-minute load average at or below 6.0 — and SKIPs loudly otherwise. Tha gate is correct and was adopted for a good re (§11.4.201(8)): the author validated a 2.10 growth-exponent threshold, then observed it FALSE-FAIL correct code at load 11.06 (baseli span 2.136), and at load 15-23 measured base spans of 2.358 against injected-cubic mutants 2.278-2.331 — the signal is smaller than the n and the two are not separable in either direct Gating was the honest response. THE PROBLI The gate has consequently NEVER RUN unde own precondition. Every recorded run today measured load 9.15-23; the independent reviewer measured 9.66 during review; the conductor measured 6.45 at its lowest. GREEI polarity WAS observed — at loads 9.4-11.6 (sp 1.882) and in three stability runs (1.759/1.832/1.848) — but never once beneath shipped ceiling. The author states this honest an inference from data rather than a run the can paste, and the reviewer confirmed the inference is sound (quiescence is strictly mor favourable). Sound inference is still not an observed run. WHY THAT MATTERS (§11.4.22 A registered, topology-present guard that nev executes is indistinguishable from a guard th would fail if it did. Nothing currently ensures ever runs: no freshness contract, no schedule quiet-window invocation, no tracked item — which is precisely the unexecuted-standing-guard class §11.4.226 names, where registrati gets treated as coverage while execution is nobody's job. The forensic precedent in that anchor is two standing guards that, when fin executed, immediately emitted latent FAILs. ACCEPTANCE. (a) Execute both quiescence-ga timing tests on a host whose 1-minute loadav genuinely <= 0.75/cpu — no agent fleet, no concurrent build — and capture the run as a artifact showing the resolved load reading

ATM ID	Type	Status	Severity	Description
				alongside the measured span exponent, so th precondition is provable from the artifact an not asserted. (b) Record the observed GREEN polarity in the item and in the test source, replacing the current honest-inference note. the gate FAILS under genuine quiescence, tha the finding this item exists to surface, and it reopens the threshold-calibration question rather than being worked around. (d) Establi freshness contract per §11.4.226: how stale a quiescent verdict may be before the gate cou as uncovered again, so this does not silently return to never-executing. HONEST BOUNDA This item does not claim the gate is wrong. Th evidence points the other way — quiescence strictly more favourable than the loads wher GREEN was already observed. It claims only the run has not happened, and that an unexecuted guard cannot be cited as coverag PROVENANCE. Raised as IMPORTANT-2 by th independent Fable-substrate reviewer of the BOB-109 work, and independently corrobora the reviewer verified the SKIP is loud and pri its resolved numbers, and confirmed the ship tests do SKIP at today's load.
BOB-171	Bug	Queued	Low	WHAT. Both rate limiters key their per-client bucket on the LEFTMOST element of X-Forwarded-For when TRUST_FORWARDED_F is enabled: download-proxy/src/api/ rate_limit.py:117-123 (:7187) and the new std limiter in plugins/download_proxy.py (:7186) which was deliberately built to exact policy parity with it. That element is CLIENT-SUPPL An honest reverse proxy APPENDS the peer address to the RIGHT of whatever arrived, so leftmost entry is whatever the client sent — attacker-controlled by construction, not by misconfiguration. Consequences with the flag (1) rotating a forged leftmost value mints an unlimited sequence of fresh buckets, which i total bypass of the limit the flag is supposed t make MORE accurate; (2) it also defeats the L

ATM ID	Type	Status	Severity	Description
				idle-reap cap, since each forged identity is a distinct key — the bucket map is a memory-growth surface bounded only by the cap, and cap's eviction then discards the budgets of RE clients to make room for forged ones. NOT EXPLOITABLE AS DEPLOYED TODAY, and tha why this is Low, not High. TRUST_FORWARDED_FOR defaults OFF at bo sites, and the deployed stack runs network_m host with no reverse proxy in front (verified across all five compose services), so peer addresses are real client IPs and no NAT colla occurs. The defect is latent: it arms the mome someone puts a proxy in front and turns the on to recover real client IPs — which is exact the situation the flag exists for. The failure m is therefore 'correct-looking configuration change silently disables the limiter', not 'currently broken'. PROVENANCE. Raised as MINOR-3 by the independent reviewer of the BOB-111 rate-limiter work and independentl confirmed by the implementing agent, which noted it at BOTH source sites as a tracked foll up rather than fixing it in that change. Filed b because neither agent has write access to the tracker. WHY IT COVERS BOTH PORTS. :7186' limiter was built to deliberate policy parity w :7187's, including this parsing. Fixing one and the other would leave the two surfaces disagreeing on client identity — worse than t shared defect, because it becomes surface-dependent and untestable as a single invaria ACCEPTANCE. (a) Replace leftmost-element parsing with a trust-aware resolution at BOT sites: either rightmost-minus-N-trusted-hops, trusted-proxy CIDR allowlist where only a pe inside the allowlist may assert XFF at all — th choice is a deployment-topology decision and should be recorded, not assumed. (b) A test th forges a rotating leftmost element and assert bucket key does NOT rotate, per site. (c) Paire §1.1 mutation: restore leftmost parsing and th test must FAIL. (d) Negative control

ATM ID	Type	Status	Severity	Description
				(§11.4.201(1)): with TRUST_FORWARDED_FOI OFF, the header must be ignored entirely and keying must fall back to the peer address — a guard that starts honouring XFF when the fla off would be a worse defect than the one bei fixed. (e) Honest boundary: this closes heade forgery bypass; it does not make per-IP limiti fair behind NAT, where many real users legitimately share one address. NOT CLAIME No change made. Both sites still parse leftmo the flag still defaults off.
BOB-172	Bug	Ready for testing	High	WHAT. The rutracker SEARCH endpoint is refused by bot protection while the site itself fully reachable. Measured unauthenticated 2026-08-21 (no cookie file read, no credential value in any artifact — §11.4.10): GET /forum index.php -> 200, 96283 B,
BOB-173	Bug	Ready for testing	High	WHAT. download-proxy/src/api/hooks.py:96-1 def _save_hooks(hooks: list[dict[str, Any]]) -> None: try: os.makedirs(os.path.dirname(HOOKS_FILE), exist_ok=True) with open(HOOKS_FILE, 'w') a json.dump(hooks, f, indent=2) except Excepti as e: logger.error(f'Failed to save hooks: {e}') catches EVERY exception, logs, and returns N The signature returns None, so the caller has channel to learn the write failed. Both call sit then report success unconditionally: :152 _save_hooks(hooks) :174 _save_hooks(hooks) logger.info('Created hook: …') :175 logger.info('Deleted hook: …') :156 return HookResponse(hook_id=…, …) :176 return {'message': 'Hook deleted', …} USER-VISIBLE CONSEQUENCE, which is why this is High and not a code-hygiene nit. A user POSTs a webho receives HTTP 200 and a hook_id, and the ho was never written — their automation silentl never fires, and the API told them it exists. Symmetrically, a user DELETEs a hook, is tolc 'Hook deleted', the file still holds it, and it fire again after the next restart. In both direction product reports the opposite of what happen

ATM ID	Type	Status	Severity	Description
				and the only trace is a log line nobody is watching. THIS IS THE §11.4.252 SHAPE. The path combines two dangerous capabilities fr that anchor's taxonomy — MUTATION of a shared resource (a filesystem write) and EXTERNAL SIDE EFFECT (hooks are outboun calls the system will or will not make) — so it required to FAIL CLOSED: verify the precondition, refuse when it cannot be satisf and surface the refusal. Instead it fails open, a bare 'except Exception:' that only logs is th exact anti-pattern §11.4.252 enumerates. At t product layer it is also a §11.4.201(6) false-nu successful write and a swallowed failure are indistinguishable to the caller. PROVENANCE Surfaced as an out-of-scope observation by th independent reviewer of the BOB-135 test-isolation work — this swallow is what turned that defect into an 'assert 0 == 1' mystery, because the EACCES on /config was logged an discarded while the endpoint kept returning Verified here directly from source before filin (the function body and both call sites read above), not taken on report. Recorded as a §11.4.238 discovery-channel escape: found by agent reading code during an unrelated investigation, not by the automated QA regim the coverage gap is a defect of equal standin the defect itself. ACCEPTANCE. (a) _save_hoo propagates failure — raise, or return a status callers must consume. (b) Both endpoints translate a persistence failure into an HTTP e (500-class), never a success body; a create tha did not persist must not return a hook_id. (c) test drives each endpoint with the hooks file unwritable (read-only dir or a patched open raising OSError) and asserts a non-2xx status AND that a subsequent GET does not list the phantom hook — assert on the user-observab outcome, not on the log line. (d) Paired §1.1 mutation: restore the swallow; the test must FAIL. (e) Audit the same file for sibling swallo — this is a pattern, and one instance is rarely

ATM ID	Type	Status	Severity	Description
				alone. (f) Honest boundary: this does not clai the write currently fails in production; it clai that WHEN it fails the user is told the opposit and the BOB-135 investigation shows it does i in at least one real environment. NOT CLAIM No change made. No assessment of how ofter write fails in the operator's deployment. RECORDING A SHELL ERROR OF MY OWN (§11.4.6): the first version of this description v written with the anti-pattern snippet inside backticks in a double-quoted shell argument, the shell ran it as command substitution and text was replaced by nothing — the stored description read 'and is the exact anti-patterr This is the SECOND time this session that backticks-inside-double-quotes has corruptec content (the first mangled a commit message Fixed here by editing through a Python client with no shell quoting in the path. Noted beca a silently-truncated defect description is exac the kind of quiet corruption §11.4.201(7)(c) warns about — the path is part of the instrument, and it failed without erroring.
BOB-174	Bug	In progress	High	WHAT. A corrupt hooks file is silently indistinguishable from "no hooks configured and the next create then DESTROYS every existing hook while returning HTTP 200. Thre defects on one path, filed together because fi any one alone leaves the data loss reachable. — download-proxy/src/api/hooks.py:104-112. _load_hooks wraps the read in `except Exception: logger.error(...)` and fal through to `return []`. A truncated or malforn hooks.json is therefore reported to every call as an empty, healthy hook list. Confirmed at source. A2 — the consequence, and the reaso this is High. create_hook loads, appends, save Given a corrupt file that load turns into [], the save writes a one-element list over the top. E previously-configured hook is gone. Measure the implementing agent against the ALREADY FIXED tree, so this survives the BOB-173 writ

ATM ID	Type	Status	Severity	Description
				failure fix: BEFORE on disk : [‘prod-hook-0’, ‘prod-hook-1’, ‘prod-hook-2’] GET reports : 20 {‘hooks’: [], ‘count’: 0} <- claims ZERO hooks configured DELETE reports : 404 {‘detail’: ‘Ho not found’} <- for a hook that IS in the file PO reports : 200 hook_id=3c8a5930-… AFTER on disk : [‘3c8a5930-…’] Three prod hooks destro HTTP 200 throughout, nothing surfaced to th user. A5 — _save_hooks writes with a plain `open(path, "w")`. A crash, ENOSPC, or a kill m write truncates the file in place. That is preci the corruption A1 then reads as “no hooks” a A2 overwrites. The same codebase already ha the correct pattern: theme_state.py:115-126 u tmp-file + os.replace. WHY THE THREE ARE O ITEM. A5 manufactures the corrupt file, A1 misreads it as empty, A2 destroys the content Fixing only A1 leaves truncation reachable; fixing only A5 leaves an existing corrupt file data-loss trigger; fixing only A2 leaves the AP lying about what is configured. The chain is t defect. DELIBERATELY NOT FIXED UNDER BOB-173, and the reasoning is sound. The implementing agent identified all three while auditing sibling swallows as that item requir and declined to fix them in the same change because: they change GET semantics on an endpoint the frontend consumes (200 -> 5xx) they need a CORRUPT-file reproduction rathe than the UNWRITABLE-file one BOB-173 buil and they need a design decision that is genui not obvious — a MISSING hooks file legitima means “no hooks configured”, while a CORRU one does not, and today’s code cannot tell tho apart. Expanding BOB-173’s scope to cover th would have meant shipping that decision unexamined. ACCEPTANCE. (a) Distinguish MISSING from CORRUPT: a missing file rema an empty list; a corrupt one is an error, neve silently []. (b) Decide and RECORD what GET on corruption — 5xx, or 200 with an explicit degraded marker the frontend can render. Th the design decision, and it should be stated

ATM ID	Type	Status	Severity	Description
				rather than inferred from whatever the patch happens to do. (c) create/delete MUST NOT overwrite a file they could not parse — refus not clobber (§11.4.252: mutation plus externa side effect must fail closed). (d) Make the wri atomic via tmp + os.replace, reusing theme_state.py's existing pattern rather than inventing it (§11.4.28). (e) Tests asserting the USER-OBSERVABLE outcome, not log lines: se corrupt file, assert GET does not claim zero hooks, assert a create refuses rather than destroying, and assert the file still holds the original hooks afterwards. (f) Paired §1.1 mutation per guard. (g) NEGATIVE CONTROL (§11.4.201(1)): a MISSING file must still yield empty list and a working create; a VALID file must behave exactly as today. A fix that make every load fail closed by failing always is not fix. A3, RECORDED SEPARATELY, NOT PART O THIS CHAIN. VALID_EVENTS and HookEvent are two sources of truth for one closed set. Verified identical today, unguarded against d if they diverge a hook registers successfully a then silently never fires. One assertion pinni them would close it. NOT CLAIMED. No chan made. The BOB-173 write-failure fix is real a orthogonal — it makes a FAILED write hones does nothing about a SUCCESSFUL write of wrong data derived from a misread file.
BOB-175	Task	Queued	Low	WHAT. The workable-items `update` seam guar the status-location invariant in one direction only. After BOB-166, `update --status <termi` on an Issues-located row is refused. The mirr still open: `update --location Fixed --status <non-terminal>` exits 0 and creates a row that `update`'s own validator immediately rejects. Verified empirically by the independent revi of BOB-166: update –location Fixed –status 'I progress' -> exit 0 validate -> FAILS, naming t row (check (f), fixedLocationNonTerminalSta So the command can still mint a state its own validate call refuses. That is the §11.4.196(F)

ATM ID	Type	Status	Severity	Description
				shape at the seam layer: the invariant is CONFIGURED in validate but not ENFORCED every write path that can violate it. WHY IT W DELIBERATELY LEFT OPEN IN BOB-166, and that was right. Three reasons, all checked rat than asserted: (1) the real corpus has ZERO instances of this direction against TEN of the direction BOB-166 closed — the asymmetry in data matched the asymmetry in the code; (2) detective coverage ALREADY existed and demonstrably fires, so unlike BOB-166's direc this cannot rot silently; (3) and the load-beari one — `reopenCmd` documents and SANCTIONS transient Fixed-plus-non-terminal state via it `location Fixed` operator override. A naive preventive guard at the update seam would collide with that override's semantics. Closing this therefore requires a design decision abo how the two interact, which is a different question from the one BOB-166 was scoped to answer, and expanding that item would have meant shipping the decision unexamined. ACCEPTANCE. (a) Decide and RECORD how a preventive guard on this direction coexists w reopenCmd's sanctioned override — this is th actual work, and the answer should be writte down rather than inferred from whatever th patch does. Candidates worth weighing: exem the reopen path explicitly, require an overrid flag on `update` mirroring reopen's, or leave th direction detective-only with the rationale recorded so the asymmetry is a decision rath than an oversight. (b) If a guard lands, it reus `terminalStatuses()` — BOB-166 established o predicate source specifically so the two directions cannot drift. (c) Paired §1.1 mutati (d) NEGATIVE CONTROL (§11.4.201(1)), and it the sharp one here: the sanctioned reopen pa MUST still work. A guard that breaks reopenCmd's documented override is a false-positive refusal, and worse than the gap it clo because it breaks a workflow operators are to to use. HONEST BOUNDARY. This is not a live

ATM ID	Type	Status	Severity	Description
				data defect. Zero corpus instances, and the detective gate catches it at the next validate. I filed so a scoped, deliberate omission stays visible as a tracked decision instead of living in a code comment where the next reader wi mistake it for an oversight (§11.4.197: a starte thread reaches a documented terminal state, never quiet abandonment). PROVENANCE. Raised by the implementing agent of BOB-16 a known asymmetry it deliberately did not cl independently verified and endorsed as an acceptable scope boundary by that item's reviewer, on the condition that it become a tracked item rather than a comment. This is t item.
BOB-176	Bug	Queued	Medium	WHAT. _get_enabled_trackers() in download-proxy/src/merge_service/search.py gates rutracker on RUTRACKER_USERNAME and RUTRACKER_PASSWORD only. It never consu RUTRACKER_COOKIES. So an operator configured with cookies alone — no usernam no password — never has rutracker enabled all, and the tracker is silently absent from eve fan-out rather than failing visibly. WHY THA INCOHERENT WITH THE REST OF THE CODE _search_rutracker treats COOKIES as the PREFERRED auth path, not a fallback. And th nnmclub sibling DOES check its own *_COOK variable. So the same codebase holds three positions at once: cookies preferred at the sea site, cookies ignored at the enablement gate, cookies honoured for a sibling tracker. WHY I MATTERS MORE THAN IT LOOKS. CLAUDE.m documents a standing operator mandate (2026-08-15) that per-tracker Netscape cookie files at ${TRACKER_COOKIE_DIR}/ cookies_<tracker>.txt are auto-loaded into .en <TRACKER>_COOKIES before every boba-svc restart, install Stage 6 and start.sh boot — an rutracker is named in that set. So the SANCTIONED, documented configuration pat for this tracker produces exactly the state thi

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>gate ignores. An operator who follows the documented instructions gets a tracker that never runs, with no error to explain it. FAILU MODE. Silent absence, not a visible failure — same §11.4.201(6) false-null shape as BOB-17 one layer earlier. BOB-172 fixes a tracker that RAN and was REFUSED being reported as em this is a tracker that never ran at all, and the merged result simply has one fewer contribu with nothing to indicate it. PROVENANCE. Fo by the BOB-172 implementing agent while tracing the enablement path to locate the stat handling defect. Recorded here rather than fi in that change: it is a separate defect on a separate seam with its own oracle, and foldin in would have widened BOB-172 past its captured evidence. ACCEPTANCE. (a) The enablement gate honours RUTRACKER_COOK as an independently sufficient credential, matching what _search_rutracker already prefers and what the nnmclub sibling alread does. (b) A test asserting that a cookies-only configuration ENABLES rutracker, driving the real _get_enabled_trackers rather than a repl (c) Paired §1.1 mutation restoring the userna password-only gate — the test must go red. (c NEGATIVE CONTROL (§11.4.201(1)): a configuration with NO credentials at all must leave rutracker DISABLED. A fix that enables unauthenticated tracker is worse than the ga because it produces failing searches instead o absent ones. (e) Audit the other trackers' gate the same asymmetry rather than fixing only t one that was noticed — three positions in one codebase suggests nobody has checked them together (§11.4.118). HONEST BOUNDARY. No verified against a live cookies-only deployme read from source by the BOB-172 agent and recorded on its report. The reading is specific and checkable, but whoever takes this should confirm by invocation before relying on it. | BOB-177 | Bug | Queued | High | WHAT: BOB-172 wired an identical 4-line HTTP-refus</td></tr>
</table>

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>guard at five private-tracker fetch sites in download-proxy/src/merge_service/search.py (rutracker cookie :1390, rutracker credential :1468, kinozal :1648, nnmclub :1761, iptorren :1934). Only the rutracker COOKIE path is exercised by tests. EVIDENCE (reviewer-auth mutation R1, per 11.4.194(6)(d), during the BOB-172 independent review): deleting ONLY kinozal guard wiring (search.py:1655-1658) w leaving the classifier intact left the full merge_service suite at 883 passed, ZERO failu The suite cannot see four of the five sites. FAILING SCENARIO: a refactor drops or subtl breaks the wiring at kinozal, nnmclub, iptorrents, or rutracker-credential. A 403 at t site silently folds back to status=empty with error=None -- the exact BOB-172 signature -- no test reddens. FIX DIRECTION (reviewer preferred): collapse the five duplicated wirin into one shared helper, e.g. _check_search_response(tracker_name, statu body) -> bool, so there is ONE copy to test and sixth site cannot be added unguarded (11.4.2 byte-identical-fork extraction). Alternative: parametrise the guard tests across all five site with per-site stub sessions. ACCEPTANCE: mutating the wiring at ANY of the five sites reddens at least one test. Prove it by running same R1 deletion at each site in turn. | | BOB | Bug | Queued | Medium | WHAT: downloa proxy/src/merge_service/search.py:1638-1640 handles a failed kinozal LOGIN response with login_resp.status not in (200, 301, 302): logger.error(...); return [] -- and sets NO diagnostic. FAILING SCENARIO: Cloudflare returns 403 on takelogin.php. The kinozal chi reads status=empty, error=None. That is the BOB-172 signature exactly: a refusal reported the user as an empty result set. CONTRAST establishing this is an oversight, not a design choice: the rutracker and nnmclub login failu DO set diagnostics (upstream_captcha / auth_failure), and the iptorrents login failure</td></tr>
</table>

<table>
<thead>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
</thead>
<tbody>
<tr><td></td><td></td><td></td><td></td><td>falls through to the search fetch where BOB-1 new guard catches it. Kinozal is the one leg w neither. FIX DIRECTION: stash _classify_upstream_http_status(login_resp.sta "") before the early return, or an auth_failure diag for the status-in-(200,301,302)-but-no-coo case. ACCEPTANCE: a stubbed 403 on the kino login endpoint produces a non-None error on kinozal chip, with a RED captured against the pre-fix code first (11.4.115). | | BOB-179 | Tas Queued | Medium | WHAT: the BOB-172 independent review demonstrated two furth paths that still report a refusing or unreachab tracker as an empty result. Both are PRE-EXISTING and neither is a regression from BOB-172, but the fix evidence log presents the five-site coverage without stating the bounda (11.4.194(5) requires un-analysed dimensions explicit gaps, never silently assumed safe). GA -- exception before resp.status is read. Review probe B, captured: a connection-refused rutracker yields status=empty, error=None, http_status=None, metadata.errors=[], metadata.status=completed. Each _search_* method swallows exceptions (except Exceptio logger.error; return results) before _search_o error handling can see them, so a tracker tha DOWN is indistinguishable from one that is genuinely empty. GAP B -- soft refusal at HTT 200. Reviewer probe A, captured: _classify_upstream_http_status(200, <cf-chl body>) returns None, which is CORRECT by design (a 2xx is a usable response; body-mark triggering would risk the over-fire the negati controls exist to prevent). But all five search use aiohttp's default allow_redirects=True, so session-expiry 302 -> login-page-200 chain pa to zero rows and reports empty. FIX DIRECTI Gap A needs the exception to reach a diagnos rather than being swallowed. Gap B needs a DISTINCT detector (final-URL check or login-f marker) with its own RED -- explicitly NOT a widening of the status-code trigger.</td></tr>
</tbody>
</table>

ATM ID	Type	Status	Severity	Description
				ACCEPTANCE: both gaps closed with their ow REDs, or explicitly closed per 11.4.112 with evidence. Immediate sub-task: append a state gaps paragraph to docs/qa/BOB-172/ fix_evidence_20260822.log. | | BOB-180 | Bug Queued | Low | WHAT: download-proxy/src/ routes.py:727-745 sets status=captcha_requir with a hardcoded message naming RuTracke 'RuTracker requires CAPTCHA. Use /api/v1/au rutracker/captcha'. FAILING SCENARIO: a wh search returns zero results and the captcha- flavoured diagnostic came from NNMClub's Turnstile, not RuTracker. The user is told to v a RuTracker captcha endpoint for an NNMClu problem. SEVERITY BOUNDED: the full errors and tracker_stats travel in the same response payload, so the truth is present and a client th reads them is not misled -- only the headline wrong. The branch was revived by BOB-172's error propagation (correctly: suppressing tha propagation would recreate the same false-n one layer up, 11.4.247) and is already covered the routes layer by tests/unit/api_layer/ test_routes_coverage.py:782. FIX DIRECTION: derive the message from the tracker(s) that actually erred rather than hardcoding one. SCOPE NOTE: api/ was owned by a sibling str during BOB-172; the author was correct not t touch it. ACCEPTANCE: an NNMClub-only cap diagnostic on a zero-result search produces a headline naming NNMClub. | | BOB-181 | Bu Queued | High | WHAT: scripts/ generate_markdown_exports.sh accepts no arguments. It unconditionally scans PROJECT_ROOT/*.md, docs/ recursively and scripts/ recursively (scan loops at lines 105/111/116 as of 2026-08-23; they were 96-10 when this was filed — line numbers shifted w the BOB-169 fix, the substance is unchanged a was independently verified by execution: invoking the generator with an explicit path produced an out-of-scope export and NOT the requested one), and PROJECT_ROOT is derive

ATM ID	Type	Status	Severity	Description
				from BASH_SOURCE (line 17). A caller who w 'bash scripts/generate_markdown_exports.sh docs/qa/SOME/file.md' gets a WHOLE-TREE ru with the argument silently discarded. WHY IT MATTERS: the caller reasonably believes the was scoped to one file. It was not. In a shared checkout with parallel work streams this regenerates any export whose .md is newer t its derived files anywhere in the tree -- landin artifacts in other streams' scopes and, with th BOB-068 auto-commit hazard, into another stream's commit. CLASS: a false affordance -- script's interface implies a capability it does n have (11.4.201: an interface must mean what claims). FIX DIRECTION: either accept option path arguments and honour them (scoping th run to exactly those files), or REFUSE with a c message when arguments are passed. Silently discarding them is the one option that must n remain. ACCEPTANCE: passing a path either scopes the run to it, or exits non-zero naming unsupported argument. A RED capturing tod silent-discard behaviour first (11.4.115). LIVE INSTANCE, MEASURED 2026-08-23 (this is no longer hypothetical): During the BOB-169 fix conductor invoked the generator with an exp path to regenerate ONE document. The argum was discarded and the whole tree was scann generated docs/qa/BOB-174/DESIGN_DECISIO {html,pdf,docx} at 11:50 -- a SIBLING STREAM document, while that stream's author was sti editing the source (.md mtime 12:00). The exp were therefore stale on arrival, and addition carried the pre-fix BOB-169 charset defect. Th sibling author independently reported them stale in its own hand-off, having no idea anot stream had created them. SECOND-ORDER LESSON worth keeping with this item: the conductor's attempt to verify the blast radius ALSO failed, and failed silently. 'git status --porcelain | grep -E "\.(html|pdf)$"' returned only its own files and read as clean – but docs BOB-174/ is an UNTRACKED DIRECTORY, whi

ATM ID	Type	Status	Severity	Description
				porcelain collapses to a single line, so the gre was structurally incapable of seeing the files inside it (11.4.201(7)(a): matched the wrong surface; the quiet zero read as absence). The instrument that DOES see it is 'find
BOB-182	Task	In progress	Medium	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): KEEP THE MONOTONE RATCHET** §11.4.224(E) brownfi adoption answer, recorded as consumer DAT the adoption model for CM-EXPORT-CHARSE VALID is the MONOTONE-DECREASE RATCH The count may only go down, never up. Immediate hard floor, changed-code-only-wit deadline, and per-corpus phase-in were all offered and NOT chosen. This closes half of BOB-182 — the half that was genuinely the operator's. THE REMAINING HALF IS A REAL DEFECT STILL OWED: BASELINE is a hardcod constant, so the ratchet does not actually rat — on improvement the gate PASSES and PRI the value to lower it to, but nothing lowers it the gate keeps permitting regression back to original count after the corpus heals. The fix must NOT collapse §11.4.249 role separation: gate that writes its own threshold during a p build run becomes a PRODUCER as well as a GATE. Acceptable shapes include a persisted baseline the gate READS but never writes wi lowering via a separate explicitly-invoked command, or a gate that FAILS loudly when t live count is below baseline so drift becomes actionable refusal. This answer is recorded a consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inferen and supersedes any prior agent-chosen defa on this question. Options not chosen are nam above so a future reader does not re-litigate settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior item follows — WHAT: CM-EXPORT-CHARSET-VA (pre-build invariant 50) adopts its 301 pre-existing violations via a monotone-decrease

ATM ID	Type	Status	Severity	Description
				ratchet rather than a hard floor. Two things a owed. (1) THE ADOPTION DECISION IS THE OPERATOR'S, NOT THE SCRIPT'S. 11.4.224(E) requires the brownfield adoption question be SURFACED to the operator and the answer recorded as consumer DATA – never an inver ratchet. What exists today is a header comme plus a BOBA_EXPORT_CHARSET_BASELINE override: that DOCUMENTS a decision the ag made, it does not RECORD an answer the operator gave. The independent reviewer jud the choice defensible and would not reverse hard floor on 301 violations makes the build unreachable, which 11.4.234 forbids; 11.4.10 favours the reversible option) but correctly h that it is not yet compliant. Options for the operator: immediate hard floor (BASELINE=0 keep the monotone ratchet / per-corpus phas in / changed-code-only with a scheduled full-corpus deadline. (2) THE RATCHET DOES NO ACTUALLY RATCHET. BASELINE is a hardcod constant. On improvement the gate PASSES a PRINTS the value to lower it to, but nothing lowers it, so the gate keeps permitting regres all the way back to 301 after the corpus heals The header now says tightening is MANUAL rather than claiming automatic behaviour th does not exist (11.4.6), but the honest stateme a stopgap, not the fix. WHY IT WAS NOT BUIL WITH THE FIX: a gate that writes its own threshold during a pre-build run becomes a PRODUCER as well as a GATE (11.4.249 role separation), and that is a design change the operator should approve rather than receive side effect. ACCEPTANCE: the operator's adop answer recorded as consumer DATA; and eith persisted baseline the gate lowers and never raises (with the role-separation question answered), or an explicit decision that manu tightening is acceptable.
BOB-184	Task	Queued	Medium	Three icon-glyph controls (.bridge-retry, .the toggle, .caret) render text made of non-BMP c

ATM ID	Type	Status	Severity	Description
				points. axe-core declines to decide their contr reporting them under the incomplete channe with messageKey nonBmp and resolving NEITHER fgColor NOR bgColor, so the Python recomputation in docs/qa/BOB-164/ axe_contrast_scan.py cannot decide either: 40 such nodes across 16 palette x mode combinations. BOB-164 round 2 stopped them being scored as silent passes by naming them GLYPH_UNMEASURED, printing them on eve run and fencing them, so any NEW unmeasu glyph node blocks. What remains genuinely unproven is their contrast itself: as non-text u interface components they owe 3:1 under WC SC 1.4.11, and no oracle in this repo measure that today. Acceptance: a measurement path resolves the effective foreground and backdr for glyph controls (for example reading getComputedStyle colour against the compos backdrop, or replacing the glyphs with inline carrying explicit fill tokens), each of the three controls shown to clear 3:1 in all 16 palette x mode combinations, and the GLYPH_UNMEASURED fence shrunk by exact the nodes then proven.
BOB-185	Task	Queued	Medium	docs/qa/BOB-164/axe_contrast_scan.py scans static dist with no backend, so every node wh existence depends on fetched data is absent f the page it measures: the results table render empty, so .type-badge and .quality-badge nev appear, and the hooks list renders empty, so .status pills never appear. That is precisely why the BOB-164 round-1 regression went unseen in a rendered DOM even though it wa scanned in all 16 themes, and it is why round had to close the class in the arithmetic oracle instead. Those nodes are now covered by frontend/src/app/models/style-contrast.spec.t which extracts declared foreground-on-fill pa from the stylesheets, but that is an ARITHME claim about declared colour pairs, not a rendered-pixel one: it cannot see opacity app

ATM ID	Type	Status	Severity	Description
				by an ancestor, a composited backdrop, or a cascade this repo's static extractor does not model. Acceptance: the scan drives the dashboard with seeded fixture data (a stub backend, a route fixture, or an injected component harness) so the badge and status nodes are present in the DOM, axe measures them directly, and a control needle proves th rendered oracle sees a seeded sub-floor badg before any clean result from it is believed.
BOB-187	Bug	In progress	—	scripts/ownership_precondition.sh consumes SAME unreviewed .env-driven scope as ownership_repair.sh and creates probe files inside it, but it is NOT fenced. T028 remediati added ownership_path_fence() to scripts/lib/ ownership.sh and wired it into ownership_repair.sh, closing the path-escape class there; the precondition was outside tha agents file scope and still accepts whatever config/owned_paths.yaml expands to. Blast radius is lower than a recursive chown (it wr probe files rather than mutating ownership o existing tree) but the INPUT is identical and equally unreviewed, so the same QBITTORRENT_DATA_DIR value that would h driven a filesystem-wide chown will drive pr file creation at an arbitrary location. Note the escape is empirically confirmed for the repai path, not merely reasoned: during T028 remediation a probe declaring the verbatim shipped entry with QBITTORRENT_DATA_DIF hung the suite, and ps showed the real artifa executing "find / (! -uid 1000 -o ! -gid 1000) -printf …" before it was killed by verified pid. Acceptance: ownership_precondition.sh calls SAME ownership_path_fence() predicate fron scripts/lib/ownership.sh (never a second dial 11.4.251), refuses fail-closed on a rejected ent and ships a paired 1.1 mutation proving the refusal fires PLUS a negative control proving six live shipped entries still ACCEPT so the fix not a 11.4.201(1) false-positive refusal.

ATM ID	Type	Status	Severity	Description
BOB-188	Bug	In progress	—	Discovered out-of-band during T028 remedia and reported by the agent as needing trackin it is also a 11.4.238 coverage escape. **OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): UNTRACK THE BINARY — BUILD ON DEMAND** §11.4.30 ans recorded as consumer DATA: the compiled `workable-items` binary is NOT to be git-tracke 'Any build derivate which we can recreate by executing proper mechanism for generating MUST NOT be versioned' applies without exception here. Keeping it tracked with only invariant-52 fingerprint gate, and keeping it tracked with a commit-time rebuild, were bo offered and NOT chosen. REQUIRED END STA the gate builds from source, or REFUSES HONESTLY when the Go toolchain is absent (§11.4.201(11) — probe the artifact through it real invocation path, never fake a pass, never silently fall back to a stale binary). Staleness becomes structurally impossible rather than merely detected. ACCEPTED COST: a fresh clo needs a Go toolchain before invariant 17 can — already true for the qBitTorrent-go backen so this adds no new host requirement. The invariant-52 fingerprint gate remains useful defence-in-depth for as long as any binary ex on disk. This answer is recorded as consume DATA per §11.4.35 — it is the operator's state choice, not an agent inference, and supersed any prior agent-chosen default on this questi Options not chosen are named above so a fut reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline appl to decisions). — prior item text follows — pre_build_verification.sh invariant 17 (CM-WORKABLE-ITEMS-VALIDATE) resolves its binary through the candidate loop at :534, wl FIRST entry is constitution/scripts/workable-items/bin/workable-items. That file is GIT-TRACKED (md5 17644a248363, identical to bi workable-items-linux) and executable, so it W

ATM ID	Type	Status	Severity	Description
				resolution over the current untracked sibling constitution/scripts/workable-items/workable items (md5 43376a6d0184). The tracked binar STALE: it does not contain the guards its own source now has. MEASURED, needle-proven, 2026-08-25. String presence in the tracked bin "refusing to set terminal status" -> 0; "Issues- location item has TERMINAL status" -> 0; con needle from the SAME updateCmd, "at least o mutable field flag is required" -> 2 (so the instrument sees through that path and the ze are real absences, not a blind read). The untracked sibling returns 1 / 1 / 2 for the sam three queries. A check whose message string absent from the binary cannot fire. RUNTIME PROOF: the same injected violation (a row se terminal status while current_location=Issue run through both binaries -> stale reports 1 violation (only the body_md desync class), current reports 2 including the location-statu class verbatim. This is exactly why the ten BOB-166 rows (BOB-087/129/131/144/145/146/148/153/155/15 survived undetected: the gate that was suppo to catch them was running a binary structura incapable of seeing them. The 11.4.108 SOUR >ARTIFACT gap: source correct, artifact stale, every gate reading the artifact reports green. This is the THIRD instance of that class found one session, alongside BOB-169 (a charset gat that never opened a file) and BOB-183 (a serv bundle five days older than its sources). COMPOUNDING: the comment at :519-523 directly above the loop asserts "The naive bin workable-items path never existed in this checkout (bin/ is a gitignored local build-outp dir nothing ever populated)". That statement now FALSE - bin/ holds two tracked binaries. stale comment asserting the absence of the v file that now shadows resolution is how this stayed invisible. Also an 11.4.30 question the operator owns: bin/workable-items and bin/ workable-items-linux are VERSIONED BUILD

ATM ID	Type	Status	Severity	Description
				ARTIFACTS in a constitution submodule that inherited by reference by every consumer, sc every consumer inherits whichever binary w last committed. Flagged independently by tw separate agents this session. ACCEPTANCE: (a resolution must never prefer a stale artifact c a current one - either the tracked binaries are removed and resolution falls through to build on-demand, or a freshness check refuses a binary older than its sources (see the BOB-18 fingerprint gate for a working pattern); (b) th false comment at :519-523 corrected; (c) a pai 1.1 mutation proving the new refusal fires, pl negative control proving a genuinely fresh binary still passes so the fix is not an 11.4.201 false-positive refusal; (d) the 11.4.30 tracked- binary decision recorded as operator DATA. Discovered out-of-band during BOB-166 remediation - a 11.4.238 coverage escape in it own right.
BOB-189	Bug	Queued	—	WHAT: the fail-open scanner's shape-(A2) heuristic cannot distinguish 'return False' meaning PROCEED-AS-IF-FINE from 'return False' meaning REFUSE. It flags six textbook f CLOSED guards as fail-open defects: _is_safe_fetch_url (x3), _qbit_add_succeeded (and the hooks path-boundary guard. INDEPENDENTLY VERIFIED 2026-08-25 by th conductor rather than taken on the triage age word: download-proxy/src/api/routes.py:1122 defines _is_safe_fetch_url returning bool, and only call site at :1476 reads 'if not _is_safe_fetch_url(url): logger.warning(Refusi SSRF-unsafe download URL (non-public targe skipping); continue' - a False return REFUSES URL. WHY THIS MATTERS: per §11.4.201(1) a false-positive refusal is a FAIL-bluff of equal severity to a false-negative pass, and here the consequence is worse than noise - acting on t finding would mean making the SSRF guard s returning False, i.e. deleting an SSRF protecti to satisfy a gate. A gate that instructs you to

ATM ID	Type	Status	Severity	Description
				remove a security control is actively dangero not merely imprecise. REPRO: run the fail-op scan; observe six hits; read each call site. ACCEPTANCE: the scanner distinguishes refu shaped from proceed-shaped False returns (c site-aware, or an audited waiver list with per entry justification), the six drop out, AND a golden-FALSE fixture containing a real fail-cl guard is added so the discrimination is itself falsifiable per §1.1.
BOB-191	Bug	Queued	—	WHAT: the §11.4.252 fail-open scan reports 0 for qBitTorrent-go, and that zero is NOT evidence. The triage agent ran control needle through the scanner's own path per §11.4.20 (b): a Python 'except Exception: pass' needle SEEN, a TypeScript 'catch (e) {}' needle was S (so frontend/src's zero IS a real zero), but a G empty-'if err != nil {}' needle was NOT SEEN. instrument that cannot see the idiom returns same quiet zero as a clean tree, and only one those is honest. DISTINCT FROM BOB-189, deliberately not merged with it per §11.4.214 BOB-189 is a false MATCH (fail-closed guards reported as fail-open); this is a false NULL (ar entire language unscanned). Same scanner, opposite failure directions, different fixes - merging them would hide one behind the oth IMPACT: Go is the language of qbittorrent-pr go and boba-jackett (port 7189, which owns encrypted tracker credentials), so the unscan surface is exactly where §11.4.252's credentia plus-mutation combination is most likely. Nobody has assessed it; the dashboard says clean. ACCEPTANCE: the scanner grows a Go covering the empty-err-block and swallowed error idioms, its needle is SEEN through the r path, qBitTorrent-go's result is re-derived, an every finding is triaged as this Python/TS pas was. Until then qBitTorrent-go's fail-open pos is UNKNOWN and must be reported as UNKNOWN, never as 0. === ROUND-2 INVESTIGATION, MEASURED 2026-08-26 — T

ATM ID	Type	Status	Severity	Description
				FILED TITLE WAS TOO NARROW (§11.4.6) == The live scanner is constitution/scripts/gates/ cm_dangerous_combination_fail_closed.sh, driven per-root by invariant 39 at scripts/ pre_build_verification.sh:1481-1544. (scripts/ pre_build/check_cm_no_fail_open_skip.sh ha NEVER existed on any branch — it exists only an uncommitted worktree. Any citation of th path is citing a file that is not there.) IT IS A WEAK-MATCHER DEFECT, NOT A SCOPE HOL Line :243 sets exts="py go rs c cc cpp h hpp ja cs js ts jsx tsx php rb" — .go IS enumerated. B line :537 gates the Python ast analyser on `cas "$f" in *.py)`, so every non-Python file falls through to just two text matchers (:772 empty `catch (...) {`, :794 credential `= x || "literal"`). Go has no `catch` keyword, so neith matcher CAN fire on Go by construction. NEE TEST, BOTH ARMS (planted / rc / result): Pyth 2 / 1 / SEEN · TypeScript 1 / 1 / SEEN · Java 1 / SEEN · **Go 6 / 0 / NOT SEEN — PASS** · Rust 2 / NOT SEEN · Ruby 1 / 0 / NOT SEEN · C 2 / 0 / N SEEN. Go is ONE OF FIVE BLIND EXTENSION not a special case. The Go needle is real code build rc=0, go vet rc=0, gofmt -e clean. THE DECISIVE DISCRIMINATOR — same bytes, extension changed: .zig (NOT enumerated) → "SKIP — topology_unsupported"; .go (enumerated) → "PASS". The gate ALREADY OWNS an honest-blindness mechanism and i works correctly; Go routes around it precisel BEING ENUMERATED. A scope hole announc itself; this matcher hole prints green. That m it the worse defect and is why the corrected t leads with it. QUANTIFIED SURFACE (exclusio stated, §11.4.224(E)): using the scanner's OW prune list and nothing added — 106 .go files / 20,389 LOC (52 production files / 6,858 LOC). WITH and WITHOUT exclusions the count is == 106; no vendored tree exists, so no unstate exclusion could manufacture a clean numbe qBitTorrent-go holds 106 blind files and 0 analysable files — 100% blind — yet invarian

ATM ID	Type	Status	Severity	Description
				counts it among “5 first-party source root(s)” reported clean. DEFECTS THE BLINDNESS HI filed as BOB-204 (credential DELETE returns unconditional 204 while the .env plaintext de error is discarded; plus the env_write_failed_db_rolled_back code asserti an unconfirmed rollback). SEPARATE SCOPE HOLE → filed as BOB-205 (cmd/boba-ctl, 947 l orchestrator, absent from DANGER_ROOTS entirely). Distinct-but-similar per §11.4.214, deliberately not merged. GOLDEN-FALSE FIXTURE FOR ANY FUTURE GO ARM: interna jackettapi/auth_middleware.go:45-66 is corre fail-CLOSED (constant-time compare, 401+ret — a Go arm MUST NOT flag it. LOAD-BEARIN §11.4.250 PREDICTION: bolting a naive Go reg arm on will IMMEDIATELY manufacture BOB-189-class false positives in Go — `if err nil { return false }` in a Go validator is fail CLOSED. Fixing this as layer N+1 reproduces BOB-189 in a new language. THEREFORE the remediation order is fixed: (1) analyser REGISTRY with an UNANALYSED verdict FIRS extension→analyser map, unmapped extensi reports UNANALYSED never silent PASS, whi converts the false null into an honest gap and covers rust/ruby/C too; (2) only then a Go arm call-site-aware from day one (go/ast, or adopt errcheck/staticcheck rather than hand-rolled regex), shipped with the auth_middleware golden-FALSE. ONE PRIMITIVE, TWO SYMPTOMS: the scanner classifies by local syntactic shape and never consults semantic — BOB-189 ignores the CALLER’s context (fal match), BOB-191 searches for a shape from a DIFFERENT language family (false null). The gate’s own header already concedes the prim (“requires real data-flow analysis this gate CANNOT honestly claim”); what is missing is propagating that concession into PER-LANGU honesty. Keep two tracker items. INSTRUMEN BUG RECORDED, NOT HIDDEN (§11.4.201(12) the investigation’s first verdict extraction use

ATM ID	Type	Status	Severity	Description
				`grep -oE 'PASS|FAIL|SKIP'`, which matched FAIL inside the gate's own name (…FAIL-CLO and mislabelled three PASSes. Re-run keyed c exit code; the table above is the corrected run EVIDENCE: docs/qa/BOB-191/ scanner_blindness_investigation_20260826.m (255 lines, §11.4.44 header). No source, gate, c config modified by the investigation.
BOB-192	Task	Queued	—	WHAT: the BOB-161 gate lands with 6 real fai open skips RATCHETED rather than fixed. Ratcheting is the constitution's named brownfield default (§11.4.135/§11.4.224(E)) ar this repo's own precedent, so the choice is co - but the remediation it defers is real work th must be owned somewhere. WHY THIS ITEM EXISTS: the gate's own header asserted the 6 were 'TRACKED SEPARATELY (§11.4.197)' wh no tracker row existed. The §11.4.209 independent review verified the absence and raised it as IMPORTANT-5, noting that withou row those findings are precisely the parked-unverified debt class §11.4.226(4) names - the population an operator samples and finds broken. A prose claim of being tracked is not tracking. WHAT EACH NEEDS: a skip that fire evidence the host ANSWERED must either classify the response and FAIL on it, or take a §11.4.69 reason that is honestly derivable fro the environment rather than from the respon verified against the live stack, not asserted. T of the six sit under '# allow-skip:' markers at tests/unit/test_tracker_auth_live.py:105 and :1 which the reviewer confirmed genuinely are open, so that marker must not be treated as absolution. ACCEPTANCE: all 6 remediated w RED-first evidence per §11.4.115, the gate's BASELINE ratcheted to 0, and the ratchet's monotone-decreasing property preserved throughout (§11.4.227(A)). NOTE the reviewe MINOR-1: a count-baseline absorbs a one-out one-in swap, so remediation progress must b

ATM ID	Type	Status	Severity	Description
				checked against the finding SET, not only the count.
BOB-193	Bug	Queued	—	WHAT: in download-proxy/src/api/streaming the dedup set is written BEFORE the yield — seen_hashes.add() / seen_hashes_local.add() execute at :317 and :356 ahead of emitting. If format_event raises, the result is never sent A its hash is already recorded, so it is permaner dropped. Independently verified by the §11.4 reviewer at both sites: mid-search the hash persists across subsequent polls so the result never re-emits; at completion the stream bre immediately after, so there is no later chance either. Results later in the SAME batch are no added and do re-emit on the next poll, which why the observed symptom is partial loss rat than total. WHY IT IS FILED SEPARATELY: the §11.4.252 fail-open pass made this loss OBSERVABLE by adding a log line, which is th right first move — but observability is not rep The underlying at-most-once semantics rema and per §11.4.226(5) a mitigation cannot clos defect it mitigates. THE DECISION IS A REAL TRADE, not an oversight to correct blindly: moving to add-after-successful-yield gives at-least-once, but a DETERMINISTIC serializatio failure would then retry the same result on e poll forever — trading silent loss for a hot loc Options are (a) keep at-most-once and treat th log line as the contract, (b) add-after-successf yield with a bounded per-hash retry budget, add-before-yield but remove the hash on emi failure so exactly one retry occurs. ACCEPTAI an explicit decision recorded, implemented, a covered by a test that drives a raising emit ar asserts the chosen semantics — with a RED observed first per §11.4.115. Raised as MINOI by the independent review of the fail-open ba filed rather than absorbed so the residual de is not retired along with the logging that reve it.
BOB-194	Bug		—	

ATM ID	Type	Status	Severity	Description
		In progress		WHAT: agent worktrees under .claude/ worktrees/ are ephemeral copies pinned at arbitrary commits - never built, never shippe deleted when the agent finishes. Pre-build ga that walk the tree with find(1) from the repo descend into them anyway. MEASURED INSTANCE (2026-08-25): CM-GO-TOOLCHAIN- MATCHES-BUILDER FAILED the main build w exactly one finding, from .claude/worktrees/ agent-afda1df906c537ab4 - a worktree 86 commits behind still carrying 'FROM golang:1 alpine' against a go.mod long since at 1.26.2. main tree was CORRECT throughout. Per §11.4.201(1) a false-positive refusal is a FAIL- of equal severity to a false pass: it blocks real work and teaches people to bypass the gate. FIXED FOR ONE GATE: '.claude' added to that gate's PRUNE_DIRS with a deterministic §1.1 - a stale mismatch inside .claude/worktrees m NOT fail a healthy tree, the SAME mismatch outside it MUST still fail, so the prune cannot widen into blindness (§11.4.201(6)). Mutation verified: reverting the prune fails 2 checks. SURVEY, measured not inferred: 8 of 13 pre_ gates walk the tree; only the fixed one prunes .claude. Gates using 'git ls-files' are structurally immune - worktrees are untrack Empirically probed: check_cm_closure_seam_binds, check_cm_killpg_pgid_guard and check_cm_no_production_mutation_residue rc=0 with ZERO worktree references - clean i practice today. UNMEASURED, not clean: check_cm_test_mock_pid_explicit_int and check_cm_test_mock_pid_patched_when_rea were not reached before the probe budget expired. HYPOTHESIS REFUTED, recorded so nobody re-walks it: an earlier revision of this item speculated that check_cm_plugin_count 90s timeout was caused by walking worktree is NOT. That gate's find is scoped to $PLUGINS_DIR (check_cm_plugin_count.sh:2 so worktrees are outside its walk entirely. Its

ATM ID	Type	Status	Severity	Description
				slowness is real - still running past 54s on a r measure - but has a different, still-unidentifie cause and belongs to its own item, not this or ACCEPTANCE: every tree-walking gate either prunes agent scratch or is proven immune by measurement, each with a paired mutation. NOTE the asymmetry that bounds the risk: a worktree can only ADD findings to a security relevant scan (killpg, mutation-residue), neve remove them - so the exposure is false refusa and eroded trust, not a missed defect.
BOB-195	Bug	In progress	—	**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): TEACH THE SCANNER With NODES — KEEP SIM105** The §11.4.252 fail-open scanner is FIXED to see `contextlib.suppress`; ruff's SIM105 rule STAY ENABLED in pyproject.toml. Disabling SIM10 and the belt-and-braces both-at-once option, were offered and NOT chosen. Rationale carr with the decision: fixing the gate makes SIM1 harmless, whereas disabling SIM105 alone w leave the gate blind to any suppress written b hand, inherited from a dependency's style, or already present in the tree. REQUIRED BEHAVIOUR: `with contextlib.suppress(...)` `with suppress(...)` (the `from contextlib imp` `suppress` binding) wrapping a dangerous-combination call are DETECTED with the sam severity and message shape as the try/except pass form; a narrow `suppress(SpecificError` around a NON-dangerous call must NOT fire, since a false-positive refusal is a §11.4.201(1) FAIL-bluff of equal severity to a missed real c CONSEQUENCE FOR THE NUMBER: once lanc the scanner's finding count stops being a floo over try/except shapes and becomes a genuir census — any prior count citing completenes was scoped to try/except only. This answer is recorded as consumer DATA per §11.4.35 — i the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not

ATM ID	Type	Status	Severity	Description
				chosen are named above so a future reader d not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisio — prior item text follows — WHAT: the §11.4 fail-open scanner matches Try-handler shape (A1)/(A2). contextlib.suppress is a With node, swallow written that way is invisible. VERIFI BY THE CONDUCTOR with a control needle through the same invocation path (§11.4.201((b)), because a first attempt returned 0 for BC forms and was itself blind - the gate takes –ro not a positional, so a bare path exits on an unknown arg (§11.4.201(7)(c): the invocation path is part of the instrument). Correct run: t except/pass around os.unlink(user_supplied_path) -> 'FAIL - swallowed exception … :5', the needle sees. contextlib.suppress(Exception) around the IDENTICAL call -> 'PASS - no swallowed-exception … anti-patterns found'. Both combi untrusted input with an irreversible unlink; l swallow everything; one is caught and one is WHY IT IS WORSE THAN A PLAIN GAP: pyproject.toml enables ruff's SIM ruleset, and SIM105 is 'use contextlib.suppress instead of except-pass'. Our own linter therefore instruc authors to rewrite the form this gate CAN see into the form it CANNOT. The two tools are pulling in opposite directions and the lint one runs more often. Every SIM105 autofix silent shrinks this gate's coverage while the count g down, which reads as progress. CONSEQUEN FOR THE NUMBER: the scanner's finding cou a FLOOR over try/except shapes, not a census swallows. Any statement of the form 'N fail-o sites remain' must be read as 'N among try/ except shapes'. ACCEPTANCE: the scanner recognises contextlib.suppress (a With whose items call contextlib.suppress with a broad exception type) and applies the same ≥2-capability test; a golden-TRUE fixture in supp form; a golden-FALSE fixture where suppress wraps a single-capability diagnostic emitter a

ATM ID	Type	Status	Severity	Description
				must NOT fire; and an explicit decision on the SIM105 tension - either exempt the shapes th gate governs, or accept suppress and teach th gate to read it. Discovered by the §11.4.252 remediation agent when its own MINOR-3 fix required using contextlib.suppress at three diagnostic-emitter sites; those three uses are legitimate and justified in-source.
BOB-196	Task	Queued	—	WHAT: the CM-PLUGIN-COUNT pre-build gat takes 189 SECONDS to verify 8 documented counts. Measured 2026-08-25: exceeded a 90s probe budget (rc=124), then a bounded re-ru completed at ‘rc=0 wall=189s’ - it PASSES, it is simply slow. CAUSE, MEASURED NOT GUESS the marker loop at check_cm_plugin_count.sh:273-290 iterates EVERY LINE of every governed document an spawns a pipeline per line. Per iteration: ‘pri grep -oE | wc -l | tr -d’ (4 processes) plus ‘pri sed -n’ (2) = ~6. Governed docs are AGENTS.m 689 + CLAUDE.md 494 + docs/features/Status. 670 = 1853 lines, so ~11,118 process spawns, measuring ~102 ms/line. Classic per-line-subprocess shell trap. THE IRONY WORTH PRESERVING, because it explains why nobod simplified it: the in-code comment shows ‘-oE wc -l’ was chosen DELIBERATELY over ‘grep - after measuring the §11.4.201(12) footgun - o this host (ugrep 7.8.4) ‘grep -coE’ returned 3 a top level but 1 inside a ‘set -euo pipefail’ subs a context-dependent reading. The correctnes is right and must be kept; it is the PER-LINE application of it that costs the three minutes. HYPOTHESIS REFUTED, recorded so nobody walks it: this is NOT worktree traversal. The gate’s find is scoped to $PLUGINS_DIR (:224), the five agent worktrees are outside its walk. That guess was raised on BOB-194 and is dea LIKELY FIX (unverified, stated as a candidate a conclusion): pre-filter with ONE grep for lin containing ‘CM-PLUGIN-COUNT:’ before ente the loop, reducing ~1853 iterations to the ~8

ATM ID	Type	Status	Severity	Description
				that carry a marker, while leaving the per-lin parsing logic - and its footgun-avoiding form completely unchanged. WHY IT MATTERS beyond impatience: this gate is on the pre-bu critical path, and CLAUDE.md leans on it as t mechanical authority for the three distinct plugin rosters (43 curated / 43 engines / 12 bootstrap) whose conflation was BOB-149. A slow enough to tempt anyone into skipping it protects nothing. ACCEPTANCE: runtime redu with the counts and the footgun-avoiding par preserved byte-for-byte in behaviour, proven the existing paired mutation still biting plus a before/after wall-clock recorded. §11.4.6: not here questions the gate's VERDICTS - only its runtime.
BOB-197	Bug	In progress	—	**OPERATOR DECISION (2026-08-26, §11.4.66) GENERATE THE TOKEN AND ARM IT** The conductor generates a 32-byte random token writes BOBA_API_TOKEN into .env; the opera configures clients with it. DONE 2026-08-26: token generated via secrets.token_hex(32), appended to .env with a comment naming BOB-197 and the routes.py:83 env-gating fact chmod 600, value shown to the operator ONC and never written to any other file. Safety verified BEFORE writing (§11.4.30/§11.4.10): . matched .gitignore:27 '*.env' and was untrac (needle-proven — the same matcher confirm docker-compose.yml IS tracked, so the negati real); a §9.2 pre-op backup was taken and is i ignored; post-write re-check confirmed .env s ignored and absent from git status. Pre-store audit found the only tracked BOBA_API_TOK occurrences are the docker-compose passthrough ${BOBA_API_TOKEN:-} and pros the leak-audit challenge — no literal value ha ever been committed. STILL OWED, and the i stays open until it lands: the BOOT-TIME INVARIANT (§11.4.254) that refuses to start L bound when the token is unset or empty. Wit it the arming is a state fix, not a defect fix —

ATM ID	Type	Status	Severity	Description
				§11.4.226(5) is explicit that a state-only repai cannot close a defect item. Options not chose operator sets it themselves with the invarian blocking until then; invariant warns first and blocks on a named date. Recorded as consum DATA per §11.4.35 — the operator's stated ch not an agent inference. Options not chosen a named so a future reader does not re-litigate settled call. --- prior item text follows --- OPERATOR DECISION (2026-08-26): arm BOBA_API_TOKEN and keep 0.0.0.0, backed b BOOT-TIME invariant that refuses to start LA bound with the token unset. This item IS that invariant. MEASURED FACT, not inference. download-proxy/src/api/routes.py:83 require_api_token() reads BOBA_API_TOKEN request time and returns immediately when unset or empty. Its own docstring states it plainly: "BOBA_API_TOKEN unset/empty -> return (OPEN). This is the DEFAULT and preserves the current no-auth contract + dev workflow". docker-compose.yml:237 passes BOBA_API_TOKEN=${BOBA_API_TOKEN:-}, so container inherits empty unless the operator declares it. The operator .env does NOT decla it, needle-verified per 11.4.201(7)(b): the sam matcher hit QBITTORRENT_DATA_DIR in the same file, so the miss is a real absence and no blind read. The qbittorrent-proxy container RUNNING and LAN-bound at measurement t Consequence: the ten routes the BOB-102 gua resolves as auth-wired are open in practice o default deploy. WHY A STATIC GATE CANNOT COVER THIS. The BOB-102 gate asserts static route WIRING - that a Depends(require_api_token) marker exists o handler, decorator or router. It cannot assert runtime ARMING, which depends on an env read per request. Claiming the static gate cov it would be exactly the bluff the gate exists t prevent (11.4.262: machine evidence must m the layer it claims). This is a boot-time invari class per 11.4.254. ACCEPTANCE: a boot-time

ATM ID	Type	Status	Severity	Description
				check that, when the listener is LAN-bound (r loopback), refuses to start with a non-zero ex and a named cause if BOBA_API_TOKEN is ur or empty, so the open state becomes UNREACHABLE rather than the default. Paire 1.1 mutation: remove the check, prove the service starts LAN-bound-and-open. Golden- FALSE per 11.4.201(1): a loopback-bound liste with the token unset must NOT be refused, or check becomes a false-positive refusal blocki legitimate dev work. 11.4.238 COVERAGE-ESC NOTE: found by a subagent reading source during BOB-102 guard construction, NOT by t automated QA regime - which is itself the def class 11.4.238 names. The boot-time check IS new automated check that would have caugh
BOB-198	Bug	Queued	—	**OPERATOR DECISION (2026-08-26, §11.4.66) REFUSE TO START LAN-BOUND** The Go pro gets a boot-time guard: bind loopback only, o refuse to start. It does NOT get auth middlew in this cycle. Rationale carried with the decis the profile is opt-in via –profile go, was not running when measured, and is used for development — so closing the exposure costs guard rather than a parity implementation. Options not chosen: write auth middleware t parity with the Python route set (real work, a it would partially un-defer BOB-101); docume dev-only with no guard (rejected — nothing would enforce it, and the next –profile go run this network silently re-opens 22 routes). ACCEPTANCE: a boot-time check that resolves listener's bind address and refuses to start w it is not loopback, with a paired §1.1 mutation proving the check FAILs on a 0.0.0.0 bind, and golden-FALSE proving a loopback bind is NOT refused (§11.4.201(1)). Scope reminder record so it is not lost: this is NOT covered by BOB-10 parity deferral, which was about ports; foldin in would be a §11.4.112(5) verdict leak. Recor as consumer DATA per §11.4.35 — the operat stated choice, not an agent inference. Options

ATM ID	Type	Status	Severity	Description
				chosen are named so a future reader does no litigate a settled call. — prior item text follow MEASURED, conductor-verified independentl the reporting subagent. qBitTorrent-go/cmd/ qbittorrent-proxy/main.go registers exactly t middlewares, at lines 62, 63 and 68: middleware.CORS, middleware.Logger, middleware.GinRateLimit. There is NO authentication middleware and no per-route auth dependency. main.go:119-121 binds addr=":" which is ALL interfaces, so every ro is LAN-reachable when the profile runs. SCO 22 routes, of which the mutating ones matter most - POST /api/v1/download, POST /api/v1/ magnet, DELETE /api/v1/hooks/:id, POST and DELETE /api/v1/schedules. A LAN peer can qu downloads and delete webhook configuratio with no credential. PARITY GAP, stated as fac PUT /api/v1/theme is auth-gated in the Pytho service and open in Go. The same asymmetry holds for the download, hooks and schedules mutations. Two implementations of one advertised surface disagree about whether it needs a credential. RELATIONSHIP TO BOB-1 (Go parity deferred past v1.0.0, operator deci 2026-08-26): that deferral covered PORT parit the Go container binding :7186 and :7188 as w as :7187. It did NOT cover an authentication l and the operator was not asked about one, because the hole had not been measured wh the question was posed. Treating this as cove by the deferral would be a 11.4.112(5) verdic leak: citing a bounded decision outside the sc its evidence supports. This item stands separ and its severity is NOT settled by BOB-101. MITIGATING FACT, so severity is not overstat the Go profile is opt-in via –profile go and wa NOT running at measurement time (the container list showed qbittorrent-proxy, the Python service, with no Go sibling). The expo is latent, not live. ACCEPTANCE: either auth middleware landed in the Go service with pa to the Python route set, or an explicit operato

ATM ID	Type	Status	Severity	Description
BOB-199	Task	Queued	—	decision recording the Go profile as dev-only must refuse to start LAN-bound - with a guar enforcing whichever is chosen. **OPERATOR DECISION (2026-08-26, §11.4.66) FLAG NARROW SUPPRESS ONLY WITH AN IRREVERSIBLE CAPABILITY** The scanner fla narrow contextlib.suppress ONLY when combined with an irreversible capability (del truncate / kill) — the shape that actually caus harm. Idiomatic narrow tolerances stay quiet the gate keeps its credibility and no false-pos storm trains readers to ignore it. Options not chosen: accept the asymmetry permanently w a header statement; flag all narrow suppress absorb existing sites via a justified exemption list. MEASUREMENT CORRECTED TWICE, and second correction explains the first: the origi '37 narrow sites, all idiomatic' was propagate this conductor without verification, then re-measured by the authoring agent as OBSERVE CONTAMINATION (§11.4.201(10)) — 27 vendo third-party + 9 sibling-agent worktree COPIES the very tree being measured + 1 real = 37. Th instrument was counting other agents' duplic of its own subject. Reproducible figures, each with its scope stated: constitution repo 0 narr with-suppress; boba DANGER_ROOTS 0 narro with-suppress and 23 narrow except-pass; bo repo minus vendored 1 narrow with-suppres suppress(OSError)); narrow except-pass RETRACTED-AND-RESTATED 2026-08-26 per 11.4.201(9): the figure 97 previously recorded here reproduces under NO scope and is withdrawn. Measured replacements, each wi its scope and both independently reproduced narrow except-pass git-tracked first-party (canonical); 50 narrow except-pass on-disk m scratch dirs (the 'minus vendored' scope this sentence states). Brackets that explain the ba number: 87 ALL-except-pass git-tracked and ALL-except-pass on-disk-minus-scratch strad 97, so 97 was a class-scope conflation (narrow

ATM ID	Type	Status	Severity	Description
				all), not a corpus-scope one. The 35 cited late this record is the same measurement at git-tracked scope and agrees with 34 within one The ‘every one idiomatic’ claim was also fals the except-pass census contains SystemExit x (tests/unit/test_plugin_torrentscsv.py:305,328 which is not a benign tolerance. CORRECTIO 2026-08-26: a ‘KeyboardInterrupt x1’ previou written in this sentence was itself unsourced is WITHDRAWN — it reproduces at NEITHER stated scope. Independent AST count over gi tracked *.py: ZERO genuine ‘except KeyboardInterrupt: pass’. The only genuine instance in the checkout is .worktrees/ci-split workflows/tests/unit/test_main.py:63 — a sib agent scratch worktree, i.e. the exact observe contamination class (11.4.201(10)) this very record teaches to exclude — and the only ma tree textual match (tests/unit/ test_graceful_shutdown.py:165) sits inside a triple-quoted string literal, a carrier not code (11.4.201(7)(a)). Recorded because the error i instructive: it was introduced BY the retracti that removed the 97, so a correction is not exempt from the discipline it applies. Record as consumer DATA per §11.4.35 — the operat stated choice, not an agent inference. Option chosen are named so a future reader does no litigate a settled call. — prior item text follow RESIDUAL ASYMMETRY surfaced by the BOB fix, reported rather than silently closed. Afte teaching the scanner With nodes, a BROAD suppress (Exception / BaseException) is dete with the same severity as try/except/pass. A NARROW suppress (suppress(FileNotFoundError)) is not - but th semantically identical narrow try/except FileNotFoundError: pass IS flagged. So ruff SIM105 rewriting a narrow handler still mov that site out of the gate’s scope, a smaller ver of the exact mechanism BOB-195 was filed to close. WHY IT WAS NOT CLOSED IN THAT PA with the measurement that decided it: the

ATM ID	Type	Status	Severity	Description
				authoring agent reported 37 narrow suppres sites, all idiomatic. CORRECTION (2026-08-26, independent review): that figure DOES NOT REPRODUCE and this conductor propagated i into this item as fact without verifying - the e is mine, not the reviewer's. Measured: the constitution repo has 0 narrow `with suppres` sites; boba first-party has exactly 1 (a suppress(OSError)). The nearest corpus matc 35 narrow `except X: pass` handlers in boba f party - a DIFFERENT construct - and their cla census (OSError x7, ImportError x7, BrokenPipeError x3, RuntimeError x3, ValueError x2, FileNotFoundError x2, IndexE x2, SystemExit x2) contradicts 'every one idiomatic': a bare `SystemExit: pass` is not a benign tolerance. The two populations must r be conflated, and the distinction is the whole substance of this item. The false-positive-stor argument therefore rests on the 35 narrow except-handlers, not on 37 suppress sites, and strength should be re-judged on that basis, w under 11.4.201(1) is a FAIL-bluff of equal seve to the gap it would close, and worse in practi because it trains readers to ignore the gate. T subagent recorded the asymmetry in the gate header as a known gap rather than shipping storm. That was the right call, and is why this separate tracked item rather than an unfinisl one. THE DECISION IS THE OPERATOR'S, mirroring BOB-195 itself: (a) accept the asymmetry permanently, with the gate heade stating it so no reader mistakes the count for census; (b) flag narrow suppress ONLY when combined with an irreversible capability (de truncate / kill), catching the shape that actual matters and leaving the 37 idiomatic sites qu (c) flag all narrow suppress and absorb the 3 a justified exemption list like the LAN-route guard uses. RELATED FACT worth carrying: t five newly-visible production sites in downlo proxy/src/merge_service/search.py (1294, 130 1322, 1329, 1333) wrap proc.kill / os.killpg /

ATM ID	Type	Status	Severity	Description
				proc.wait in the BOB-126 cleanup path. The conductor verified the 11.4.263 pgid guard IS present and correct at both killpg sites - _pid _pgid each checked isinstance(int) and > 1 be the syscall, with the BOB-126 forensic reason inline - so those sites are true-by-the-scanner definition but SAFE in fact, and want a justifi exemption entry rather than a code change.
BOB-200	Bug	Queued	Medium	WHAT: scripts/gates/ cm_dangerous_combination_fail_closed.sh bu its scan file list with find(1). If find itself DIES (permission error, resource exhaustion, interrupted), the gate receives an EMPTY file and interprets that as ‘no files in scope’ -> ho topology SKIP -> exit 0. The failure IS loud on stderr but SILENT in the exit code, so any cal gating on exit status reads a dead instrument clean corpus. WHY IT MATTERS: this is a textbook 11.4.201(6) FALSE-NULL – a blind instrument and a clean artifact return the identical quiet zero. It is also a 11.4.252 fail-O on exactly the ‘cannot enumerate the corpus condition where the gate’s own stated discipl is to fail CLOSED. A gate that cannot see must refuse, not pass. AFFECTED SCOPE: constituti scripts/gates/ cm_dangerous_combination_fail_closed.sh (t find invocation and the empty-list branch). P EXISTING – NOT introduced by the BOB-195 change; found by the independent round-2 reviewer while reviewing that change and explicitly scoped OUT of its remediation. REPRODUCTION: make find(1) fail during the gate run (unreadable scan root, or a find stub returning non-zero with empty stdout) and observe the gate exit 0 with a topology-SKIP message, indistinguishable from a genuinely empty corpus. ACCEPTANCE: (1) the gate distinguishes ‘find succeeded and found zero files’ from ‘find failed’ – check find’s exit statu not only its output; (2) a failed enumeration i FINDING (non-zero exit) naming the unresol

ATM ID	Type	Status	Severity	Description
				precondition, never a SKIP; (3) a genuinely empty scan root still SKIPs honestly at exit 0 - 11.4.201(1) golden-FALSE guard, so the fix do not become a false-positive refusal; (4) paired mutation: restore the swallow-find-failure behaviour and the new fixture MUST fail.
BOB-201	Bug	Queued	Medium	WHAT: scripts/ownership_repair.sh fences declared scope entries LEXICALLY (string normalisation + prefix/traversal refusal). A lexical fence cannot see a symlink sitting at a INTERMEDIATE path component. A static (already-present, no race required) symlink i the middle of an otherwise-legal declared pat steers the recursive walk at a tree the operat never declared. Measured by the T028 round independent reviewer as surviving mutation WHY IT IS FILED SEPARATELY: the in-source honest-boundary note and Case 24 fixture as this reach is 'tracked as BOB-159'. It is NOT. VERIFIED 2026-08-26 by direct query: BOB-15 description is 4685 chars with ZERO occurren of 'symlink' or 'intermediate' (control-needle the body is readable through the same query path), and no item in the tracker recorded th reach at all. A dangling tracker citation mean real defect is recorded NOWHERE - the 11.4.2 lost-defect shape, where the pointer looks lik coverage and is not. This item IS that record; in-source note must now cite THIS id. SCOPE SEVERITY BOUNDS, stated honestly (11.4.6): t reach is BOUNDED, not arbitrary. It requires attacker or accident to have already placed a symlink inside a declared scope path. It is NO reachable from the shipped config/ owned_paths.yaml as it stands (shipped-scop control needle: 6 rows, RC=0). It is a real widening of what a recursive chown can tou not a theoretical one - the reviewer measure no race needed. WHAT THIS ITEM DOES NOT CLAIM: that the lexical fence is broken. The f does what it says - it refuses lexical escapes (' system trees, '..' climbs) and was verified doi

ATM ID	Type	Status	Severity	Description
				under 12 reviewer-authored mutations. This documented LIMIT of lexical fencing, now recorded as a real item instead of a citation t unrelated one. ACCEPTANCE: (1) decide deliberately and record the decision - resolve components (realpath/-P semantics) and re-fe the resolved path, OR keep the lexical fence a state the limit as an accepted operator-owned risk; the choice is operator-owned per 11.4.66 because resolving makes the fence depend or filesystem state at check time, which has its o failure modes; (2) if resolution is chosen, a golden-FALSE set proving legitimate symlink but-in-scope download roots still walk (11.4.201(1) - a fence that over-refuses is a FA bluff of equal severity); (3) the in-source note the Case 24 fixture cite THIS item, not BOB-15 (4) paired 1.1 mutation: restore the un-resolv behaviour and the fixture MUST fail.
BOB-202	Bug	Queued	Medium	WHAT: scripts/ownership_repair.sh:493 reads parsed scope rows with ‘while IFS=$'\t' read - e_path e_kind e_opt e_pres e_rec'. A scope en that OMITS 'kind' emits the row '<path>\t\t1\t TAB is an IFS-WHITESPACE character in bash even when IFS is set to it explicitly, so a RUN consecutive tabs collapses into ONE delimiter instead of delimiting an empty field. Every fie after the omission shifts left by one. MEASUR 2026-08-26 on GNU bash 5.2.37, control-needl (the with-field case was run FIRST and produ output, proving the instrument sees; an earli probe of mine returned nothing for BOTH ca because printf lacked a trailing newline - an 11.4.201(7)(b) false-null I discarded rather tha reported): kind PRESENT: path=[P] kind=[dir opt=[1] pres=[0] rec=[1] kind EMPTY: path=[P kind=[1] opt=[0] pres=[1] rec=[] CONSEQUEN 'optional' is read out of 'preserve_mode's slot entry declared 'optional: true' is therefore tre as NON-optional, so an absent path that shou skip honestly instead becomes a hard failure and 'preserve_mode'/'recursive' are likewise

ATM ID	Type	Status	Severity	Description
				from the wrong slots, with 'recursive' arrivin EMPTY. The shift is silent: no parse error, no diagnostic, no refusal. REACHABILITY: NOT reachable from the shipped config/ owned_paths.yaml - all six declared entries c 'kind' (verified). This is a latent defect in the reader, not a live misbehaviour of the produc today. PROVENANCE: surfaced out-of-band by T028 round-5 remediation agent while isolati an unrelated instrument slip, and deliberatel left unfixed and unfiled by it because (a) ownership_repair.sh had to stay at hash ae025b74602414ca for that round's do-not-regress set, (b) it was outside that round's tw NIT remit, and (c) it had not root-caused whe the repair belongs in the parser, the consume the schema. That judgement was correct; this item is the filing it deferred. Independently r measured by the conductor before filing - no accepted on report. 11.4.238 COVERAGE-ESC NOTE: no automated check found this. It was found by a human-directed agent isolating a different problem. Per 11.4.238 the coverage is itself a defect of equal standing to the bug, closing only the bug is the violation. ACCEPTANCE: (1) root-cause the correct laye parser (never emit a row with an empty field consumer (read with a delimiter that is not I whitespace, or read positionally), or schema (make 'kind' mandatory and REFUSE an entr lacking it, consistent with the whole-run refu already landed for empty expansions); the ch is operator-owned per 11.4.66 because it cha the scope-file contract; (2) a fixture with an omitted 'kind' and 'optional: true' asserting t entry is treated as OPTIONAL (or the row refused), RED-first against current code; (3) a golden-FALSE proving a fully-specified row s parses identically - 11.4.201(1), the reader mu not start refusing valid scopes; (4) paired 1.1 mutation restoring the collapsing read so the fixture FAILs; (5) an automated check that w have caught it, per 11.4.238. PRECEDENT FO

ATM ID	Type	Status	Severity	Description
				2026-08-26 (surfaced by the T028 round-5 reviewer, independently verified before recording): the SIBLING script scripts/ ownership_precondition.sh ALREADY docum this exact collapse class at lines 565-578 and already ships the repair as split_tsv() at line 5 (used at 437, 699, 775). Its in-source note carr real forensic measurement dated 2026-08-21: FIRST version of that script used the collapsi read and reported "no compose service mou this location" for config/ and for the downloa root WHILE FIVE SERVICES MOUNT THEM - false statement about what was checked, produced by the instrument rather than the system, which its own comment classifies as 11.4.201(7)(c) 'the path is part of the instrume failure. It also records why the unit suite cou not see it: the fixture scope has no compose service at all, so only running the real invoca against the real scope surfaced it. WHAT THA CHANGES FOR THIS ITEM: (a) acceptance-criterion (1) 'root-cause the correct layer' nov has a PRECEDENT rather than an open desig question - the consumer layer, via a split_tsv- reader that does not use tab-as-IFS; adopting sibling's existing function is preferable to inventing a second dialect (11.4.251 - two answers to one question across two files that read the SAME scope rows is exactly the divergence that produced the round-1 'two readers of one scope file disagree' finding); (b this is a RECURRENCE of a class already diagnosed and closed once in this codebase, novel discovery - the fix landed in one reade 2026-08-21 and the sibling reader kept the collapsing form, which is the 11.4.238 escape shape at the code layer: the lesson was captu in a comment instead of in a check; (c) the 11.4.238 coverage-escape note above is SHARPENED - the sibling's own comment alr states that a fixture-scope suite cannot see th class, so the required automated check must exercise a row with a genuinely empty middl

ATM ID	Type	Status	Severity	Description
				field, not merely a well-formed one. | | BOB- | Bug | Queued | Critical | MEASURED LIVE 2026-08-26 against the running stack from LA 192.168.1.90 (NOT loopback - qBittorrent's localhost bypass would have exercised a different code path). Evidence: docs/qa/BOB-1 runtime_auth_verification_20260826.md. VERDICT: unauthenticated mutating LAN requests ARE currently accepted. Two live services, four named routes: 1. POST /api/v2/ torrents/stop port 7186 -> HTTP 200 with NO credentials (real torrent control) 2. POST /api hooks port 7187 -> 422 field-validation (reque REACHED FastAPI body validation, which run AFTER middleware) 3. POST /api/v1/schedule port 7187 -> 422 (same) 4. DELETE /api/v1/hoo <id> port 7187 -> 404 'Hook not found' (the handler EXECUTED A LOOKUP) The 422/404 responses are the decisive evidence, not the 2 a 401 never appears anywhere, and reaching body validation or a handler lookup proves n auth middleware intervened. THE ARMED TOKEN IS INERT. BOBA_API_TOKEN was arm in .env earlier this session on an operator decision. Port 7187 returns BYTE-IDENTICAL responses with and without it across three header shapes. Port 7189 does not open for it five header shapes. Root cause identified: doc compose.yml injects BOBA_API_TOKEN into EXACTLY ONE service - download-proxy (line 237) - and into neither qbittorrent-proxy-go n boba-jackett. And even on 7186, where it IS injected, POST /api/v2/torrents/stop returned unauthenticated, so injection alone is not enforcement. PER-SERVICE POSTURE (measured): 7185 qbittorrent-nox LIVE, binds same mutating surface visible from LAN as v the proxy 7186 download-proxy LIVE, binds 0.0.0.0 - mutating control accepted unauthenticated 7187 merge service LIVE, bi 0.0.0.0 - 34 routes via openapi.json, NO auth l at all 7188 bridge NOT BOUND - honest SKIP 7 boba-jackett Go LIVE, binds * - writes 401-gat

ATM ID	Type	Status	Severity	Description
				reads OPEN incl. /api/v1/jackett/credentials 9 jackett LIVE, binds * EVERY live service binds interfaces. None is loopback-only. RELATION TO BOB-198 (its named subject was NOT running): qbittorrent-proxy-go is profiles:-ga (opt-in --profile go) and absent from the container set, so its '22 unauthenticated route neither confirmed nor refuted - honest 11.4.3 SKIP. The exposure recorded HERE is a DIFFERENT and ADDITIONAL surface on the Python service and the proxy. Do not treat th item as closing BOB-198. 11.4.238 COVERAGE ESCAPE - first class, equal standing to the bug the automated QA regime did NOT find this. T static gate check_cm_lan_routes_authenticate went through SIX independent review round proving routes are statically wired to auth middleware, and its own honest boundary (tracked BOB-197) states it asserts static wirin ONLY. Nobody had measured runtime until a directed agent did. This is precisely the 11.4 covenant's founding failure shape: a green ga over a broken-for-the-user reality. The owed remedy is an automated runtime check that would have caught it, with a RED capturing t exact exposure - not merely a fix to the route ANTI-BLUFF PROVENANCE: control needle - Jackett returned a real 401 through the SAME instrument, so the 200s are not instrument blindness; port 7188 returned exit-7, so abse are real. Negative control - a deliberately wr token still got 401 on 7189. Decisive probes 3 deterministic. Mutating probes used non-exis ids against a provably EMPTY torrent list ([] before and after), so effect was nil and verifie on both sides. Token referenced by name onl never printed (11.4.10); the report was leak-scanned with a needle proving the scanner f on a known leak. ACCEPTANCE: (1) operator decision (11.4.66) on the intended posture pe service - loopback-only bind, real auth middleware, or accepted-LAN-risk-with-rationale; (2) whichever is chosen, an automa

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>runtime check per 11.4.238 that fails RED aga today's exposure; (3) 11.4.108 layer-3/4 evider on a clean deployment, not static analysis; (4 paired 1.1 mutation. === RELATED MEASUREMENT 2026-08-26 — A THIRD LAN-BOUND PORT (§11.4.6, recorded not merged) This item covers unauthenticated mutating routes on 7186 and 7189. A separate triage stream measured, and the conductor verified that port 7188 is ALSO LAN-bound: webui-bridge.py:447 binds ThreadingHTTPServer((" BRIDGE_PORT)) — the empty host string is INADDR_ANY, so it listens on ALL INTERFACE rather than loopback. NOT merged into this i per §11.4.214 (distinct-but-similar): this is a BIND-SCOPE fact about a different service, no demonstrated unauthenticated mutating rou on 7188. Whether 7188 exposes mutating rou without authentication is UNVERIFIED and is open question this note raises. Recorded here the 7188 surface is not overlooked when this item's scope is settled — and so nobody later "discovers" it as new. | | BOB-204 | Bug | Qu | critical | WHAT: internal/jackettapi/ credentials.go:234-253 (boba-jackett, port 718 The DELETE credential handler checks the D delete, then discards the errors of BOTH `_ = envfile.Delete(...)` (line 240) and `_ = d.Jackett.DeleteIndexer(id)` (line 249), then returns an UNCONDITIONAL 204 No Content the .env delete fails, the plaintext credential variables REMAIN ON DISK while the API rep the credential deleted. Second instance, same file: credentials.go:166-176 returns the error `env_write_failed_db_rolled_back` while the rollback's OWN error is discarded (`_ =` at :16 and :171) — the response body asserts a rollb that was never confirmed, a §11.4 bluff in the contract itself. SCOPE: 4 combined dangerous capabilities on one path (credential access + filesystem mutation + external side effect + irreversible delete) where §11.4.252 fail-close on-dangerous-combination requires only 2.</td></tr>
</table>

ATM ID	Type	Status	Severity	Description
				Composes §11.4.10 (credentials must never le — a credential the operator believes deleted, on disk, IS the leak class) and §11.4.252. REPRODUCTION: read the cited lines; the disc is syntactic and unconditional. A runtime rep drives DELETE with the .env path made unwritable (chmod 0444 or a directory-level deny) and observes 204 while the variable persists in .env. WHY IT WAS NOT CAUGHT: t CM-DANGEROUS-COMBINATION-FAIL-CLOSE gate (constitution/scripts/gates/ cm_dangerous_combination_fail_closed.sh) enumerates .go at line 243 but gates its ast analyser on *.py at line 537, so Go falls to two matchers that key on `catch` — a keyword Go does not have. All 106 .go files are structurall unanalysable while being counted as analyse That blindness is BOB-191; this item is the DEFECT it hid. ACCEPTANCE: (1) both discard sites either handle the error or the handler returns a non-2xx naming the unresolved precondition per §11.4.252(2); (2) the env_write_failed_db_rolled_back code is only emitted when the rollback actually succeede else a distinct honest code; (3) a RED test driv the unwritable-.env path and observes the pr fix 204, flips GREEN post-fix (§11.4.115); (4) a golden-FALSE fixture proves the new guard d not refuse the healthy path (§11.4.201(1)). DISCOVERY CHANNEL (§11.4.238): found by a agent reading source during the BOB-191 investigation, NOT by the automated QA regi — this is itself a coverage escape and BOB-19 carries the escape audit. === VERIFICATION COMPLETE 2026-08-26 — BOTH DEFECTS CONFIRMED, RED AUTHORED AND WATCHE FAIL === Line numbers re-derived, NO drift f the filing: :234-237 DB delete checked (500 on error) · :240-244 envfile.Delete error DISCARI · :249 DeleteIndexer error DISCARDED · :253 unconditional 204. NOT AN OVERSIGHT — TI GODOC BLESSES IT. :210-211 reads: ".env and Jackett deletes are best-effort ...; failures are

ATM ID	Type	Status	Severity	Description
				silently swallowed. The 204 status reflects DB success." Any fix MUST delete that sentence o will read as authorizing the defect (§11.4.120 the doc asserting the old behaviour is part of what must be reconciled). MEASURED END STATE when the .env write fails: DB row GON plaintext RUTRACKER_USERNAME/ RUTRACKER_PASSWORD STILL ON DISK, API says 204. WORSE THAN THIS ITEM ORIGINAL FRAMED IT: the ENCRYPTED canonical copy i destroyed while the PLAINTEXT copy survive UNMANAGED — the system's own record of t credential is gone, so nothing will ever clean up. DEFECT (2) IS WORSE THAN FILED — CHECKING THE ERROR WOULD NOT FIX THE LIE. The rollback calls Repo.Upsert(..., ifSet(prior.Username), ...); ifSet("") returns nil repos/credentials.go Upsert maps nil to COALESCE(excluded.username_enc, username_enc) = LEAVE UNCHANGED. So wh the prior row had an empty field and the fail request set one, the compensating Upsert retu nil — it SUCCEEDS — and leaves the new valu place. The DB is not rolled back, there is NO e to check, and the API asserts a rollback anyw Verified live by the third RED case. This mean defect (2) is NOT one-line-ish: it needs the rep surface to express "set this field back to NULL (delete-and-reinsert the prior row, or a tri-sta in Upsert). Scope it separately from defect (1) THE RED: qBitTorrent-go/internal/jackettapi/ bob204_failclosed_test.go (297 lines, NEW file gofmt clean, deliberately isolated from credentials_test.go so it cannot widen the T04 T042 diff). Failure injection is REAL, not mock envfile.mutate writes through <path>.tmp, so test pre-creates that path as a DIRECTORY -> os.OpenFile returns EISDIR (errno 21 probed envfile.Delete fails WHILE .env stays byte- identical with the credential in it. Chosen ove chmod deliberately: opening a directory for writing fails for root too, whereas a chmod mechanism would silently no-op under uid 0

ATM ID	Type	Status	Severity	Description
				turn the RED into a FALSE GREEN. A CONTRO NEEDLE inside breakEnvWrites calls the real envfile.Delete and t.Fatal's if it unexpectedly succeeds — a blind instrument cannot produ conclusion. Measured: 3 FAIL (all three defec cases) + 1 PASS (the §11.4.201(1) golden-FALS proving the REDs are not tautological and tha the fix must not refuse the healthy path). Package-wide exactly 3 failures, all this strea zero skips. §11.4.10 honoured: no assertion o message prints a credential VALUE — names booleans only, fixtures are fake-not-a-real-*. HONEST BOUNDARY (§11.4.6): the GREEN ha the flip is OWED, NOT CLAIMED. The stream forbidden from editing credentials.go, so REI was watched, GREEN was not. THE FIX, SCOP (not applied): defect (1) IS one-line-ish twice replace the two `_ =` with checked errors returning 5xx naming the unresolved precondition (env_delete_failed, jackett_cascade_delete_failed) and DELETE th :210-211 GoDoc sentence. Defect (2) is a repo- surface change, separate scope. ADJACENT FINDINGS: (a) credentials.go is strictly WEAK than its own sibling — indexers.go:207-209 handles the identical DeleteIndexer error and least LOGS it; credentials.go:249 does not eve log. Same package, same call, two standards. Repo is a concrete *repos.Credentials, not an interface, so a rollback-FAILURE path cannot driven deterministically — relevant to §11.4. §11.4.241 if the fix wants that path testable. (The .gitignore false-null that nearly ate this deliverable is filed separately. SPOT-CHECKS the discards this item called benign — BOTH CONFIRMED BENIGN: client.go:140,153 `_ = resp.Body.Close()` closes a body already being discarded before a retry; runs.go:112 `_, _ = w.Write(...)` is post-WriteHeader, same class a credentials.go:274. Bonus: runs.go:43 `_ = json.Unmarshal(...)` is benign but mildly lossy a corrupt ErrorsJSON silently reports error_count=0, documented as deliberate

ATM ID	Type	Status	Severity	Description
				degradation in its GoDoc. Cosmetic under-rep not an integrity issue; recorded so it is not re investigated. | | BOB-205 | Bug | Queued | major | WHAT: the §11.4.252 fail-closed scan is driven per-root by invariant 39 at scripts/ pre_build_verification.sh:1481-1544 over a ha maintained DANGER_ROOTS list. `cmd/boba-c — 4 files, 947 LOC — is NOT in that list, so it i never scanned by any arm. It is the container orchestrator: a shell-exec plus state-mutation surface, precisely the §11.4.252 dangerous-combination class the gate exists for. DISTINC FROM BOB-191: BOB-191 is a MATCHER hole root IS scanned; the Go files inside it are structurally unanalysable while counted as analysed — a false null that prints green). Th a SCOPE hole (the root is not scanned at all). Different failure shapes, different fixes; per §11.4.214 they are distinct-but-similar, deliberately not merged. WHY BOTH EXIST: t root list is hand-maintained, so a new first-pa root joins the tree without joining the gate. §11.4.251 (role-as-data-pack) points at the fix direction — replace the hand-maintained list with a declared manifest derived from the sa source of truth the build uses, so a root canno exist without being enumerated. ACCEPTANC (1) cmd/boba-ctl is scanned — either by being added to DANGER_ROOTS or by the manifest replacing it; (2) whichever is chosen, a RED fixture proves a planted fail-open inside cmd boba-ctl is SEEN pre-fix-absent / post-fix-pres (§11.4.115); (3) if the manifest route is taken, fixture proves a NEWLY-ADDED first-party ro picked up without a hand edit — that is the invariant that stops this recurring; (4) the ho blindness path (§11.4.3 SKIP-with-reason, wh the gate already implements correctly for unenumerated extensions) is preserved, neve converted into a silent PASS. DISCOVERY CHANNEL (§11.4.238): found by an agent auditing the scanner's own root list during th BOB-191 investigation, NOT by the automated

ATM ID	Type	Status	Severity	Description
				regime — a coverage escape; BOB-191 carries escape audit. === VERIFICATION COMPLETE 2026-08-26 — CONFIRMED, with three corrections and a far larger gap === CONFIRM DANGER_ROOTS=(download-proxy/src plugin scripts qBitTorrent-go frontend/src) at scripts pre_build_verification.sh:1511 (conductor-verified verbatim). Invariant 39 spans :1481-1541, skips non-existent roots at :1514, the gate once per root at :1517, and the gate i invoked from exactly ONE place (:1507) — so root absent from that array is scanned by NO arm. cmd/boba-ctl re-measured: 4 tracked .go files, 947 LOC — the filed numbers hold, no d CORRECTION 1 (§11.4.6): this item said boba- a "shell-exec" surface. There is NO exec.Command in main.go — exec is one hop away via digital.vasic.containers/pkg/compos (main.go:13). The §11.4.252 threshold is still r several times over (5 of 6 capabilities: mutati :34,36,95-105,121 · untrusted input :21,33,53,110,144,170,302,453-465 · credential :432-440,496-509 · external side effect :239,323,430 · irreversible :36,142) — but the specific word was wrong. CORRECTION 2 (§11.4.6): this item's acceptance criterion (4) asserted the gate "already implements correc an honest SKIP for unenumerated extensions WRONG. That honest-skip path exists for the PYTHON ARM's degradations only. An extens absent from the ext list is a SILENT false-null Filed separately as the LANGUAGE HOLE iter CORRECTION 3: the gap is not one root. FULL ENUMERATION — 266 files in scope / 512 OU scope = 66% of the gate-visible first-party cor never scanned. tests/ 324 (excluded-by-intent UNDECLARED) · extension/ 108 · docs/ 51 · challenges/ 18 · cmd/boba-ctl 4 · frontend/ e2e+configs 5 · tools/ 1 (CONCEALS 3 REAL HI plugin_update_automation.py:189,198,215) · repository ROOT 1 (CONCEALS 1 REAL HIT: webui-bridge.py:295). Filed separately as the ROOT-SCOPE item. boba-ctl IS a genuine

ATM ID	Type	Status	Severity	Description
				§11.4.252 surface, but the hole around it is LATENT: main.go has no `_ = err`, no empty `i != nil {}`, no silent `return nil` today (grep cor needled against qBitTorrent-go/internal/conf config.go). It hides nothing live; it guarantees future one lands unseen. One real semantic finding WAS spotted by reading: authMethod default branch — filed separately. BOB-205 != BOB-191, AND THEY COMPOUND — measure one temp root, both needles: go-needle 0 hits needle 1 hit. Go-blindness independently reconfirmed (gate routes only *.py to the AST arm). The real cmd/boba-ctl scanned DIRECT returns "PASS — no anti-patterns found" ove 947 LOC it cannot analyse. THEREFORE: fixin BOB-205 ALONE moves the root from never-looked-at to LOOKED-AT-AND-FALSELY-GREE the §11.4.201(6) FALSE-NULL, the WORSE sta because it then counts as covered. Both must land, and the language hole with them. THE tests/pre_build/ test_bob205_danger_roots_scope.sh. Oracle (§11.4.245) = METAMORPHIC + INVARIANT w control needle: two BYTE-IDENTICAL Python open needles (sha equality asserted at runtim 8d8bd909...), one in a root that IS in DANGER_ROOTS (control), one in cmd/boba-c (probe), scanner driven exactly as invariant drives it. Identical input, two locations, must identical verdicts — matcher/language/gate-version held constant so SCOPE is the only fr variable. Independent of the code under test expectation comes from the relation, not fro reading DANGER_ROOTS. Shape (a) chosen; shape (b) included as an explicitly-labelled WEAKER secondary (it would pass on a typo' entry the [[-d]] guard silently skips). CONFO DELIBERATELY AVOIDED: the needle is PYTH not Go — a Go needle would stay unseen pos and the RED would never go green, which is itself a §11.4.201(1) FAIL-bluff. Fixing BOB-19 will NOT turn this green; only widening scop will. BLIND-INSTRUMENT GUARD: control ne

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>not found -> exit 3 ABORT, never RED. The tes parses DANGER_ROOTS from the real driver flips with zero edits, and never runs pre_build_verification.sh. MEASURED: RED e (evidence docs/qa/BOB-205/red_run_live_gate gate sha256 c5752428...) — CONTROL 1 hit "instrument PROVEN seeing", PROBE 0 hits. GREEN polarity proof exit 0 against a SCRATC copy of the driver with the root appended (re driver git diff --stat empty). Determinism 3/3 exit 1, 3/3 GREEN exit 0. FIX DIRECTION (assessed, not applied): §11.4.251 manifest feasible, but the source of truth matters — docker-compose.yml build contexts MISS plugins/, frontend/src, cmd/boba-ctl, webui-bridge.py; language markers (go.mod/ package.json) MISS plugins/ and webui-bridg ONLY derive-from-git-tracked-source-extensi minus a declared §11.4.224(E) exclusion fenc reaches every gap. The derivation must be bu either way: if the operator keeps the hand lis the omission-guard is the SAME computation the only question is whether it drives the sca audits the list. The tests/ question (324 files) is operator §11.4.66 decision; production-only i defensible but currently UNDECLARED. | | BOB-207 | Bug | Queued | critical | WHAT: scripts/lib/ownership.sh:299-320 probe_locati reads stat -c '%u' and compares against ownership_operator_uid (id -u). It NEVER rea '%g'. Meanwhile ownership_operator_gid is defined at scripts/lib/ownership.sh:50 and consumed ONLY by scripts/ ownership_repair.sh:360 — so the REPAIR establishes uid AND gid, while the PRECONDITION that verifies the repair work checks uid ONLY. The precondition can there report ok while exactly half the property the repair exists to establish is wrong. MEASURE LIVE ON THIS HOST, UNPRIVILEGED (a setgid directory is all it takes — no loopback, no mo no sudo): dir: uid=1000 gid=10 mode=2755 (c wheel + chmod g+s, both unprivileged) real fi</td></tr>
</table>

ATM ID	Type	Status	Severity	Description
				created there: uid=1000 gid=10 probe_locatio verdict = ok rc=0 <-- operator gid is 1000, file is 10 SEVERITY RATIONALE: this is the SAME CLASS that BOB-206 alleged (a probe reportir ok while ownership is only partly held) but o axis that is LIVE rather than hypothetical, ne no unusual filesystem, and reproduces with t unprivileged commands. BOB-206 was dismis this is the real defect that investigation surfa underneath it. ACCEPTANCE: (1) probe_locati reads and compares gid as well as uid, OR the asymmetry is deliberately justified in-source with the reason (if only uid matters to the use visible goal, say so and explain why the repai sets gid at all); (2) a RED fixture builds the set directory above, observes ok pre-fix, flips to a refusal post-fix (§11.4.115); (3) a golden-FALS fixture proves a correct uid+gid location is st ok (§11.4.201(1)); (4) whichever way it is resolved, precondition and repair agree on WHICH property they are talking about — th disagreement is the primitive defect (§11.4.2 DISCOVERY CHANNEL (§11.4.238): found by t BOB-206 verification stream, not by the automated QA regime. No existing test exerci a gid mismatch. === CONFIRMED 2026-08-26, AUTHORED — AND THE FIX DIRECTION IS T OPPOSITE OF WHAT THIS ITEM ASSUMED == CONFIRMATION (re-derived against the dirty tree; line numbers happen to match): probe_location() at scripts/lib/ ownership.sh:299-320 reads stat '%u' twice (: file branch, :314 dir branch), compares again want at :301, and NEVER reads '%g'. ownership_operator_gid is defined at :50 and EXACTLY ONE consumer — ownership_repair.sh:360 — verified across tracked AND untracked files, needle-proven (needle ownership_operator_uid -> 13 files, negative control -> 0; untracked sweep needl 8 files, ownership_operator_gid -> 0); every o hit is a docs/DB carrier or comment. THE REP SETS GID AT TWO SITES, not one: :719 chowr

ATM ID	Type	Status	Severity	Description
				"${OP_UID}:${OP_GID}" WRITES both, and :9(find_args selects on (! -uid OR ! -gid). FALSE REPRODUCED unprivileged (chgrp to a group from id -G + chmod g+s): dir uid=1000 gid=10 mode=2755, a REAL file created inside lands uid=1000 gid=10, probe_location verdict = ok rc=0. Needle arm: an absent path returns 'ab: rc=1 — the probe CAN refuse, so the ok is rea DESIGN QUESTION ANSWERED: **NARROW REPAIR. gid is NOT load-bearing.** This item filed assuming the PROBE was deficient. Measured, that is backwards. - With correct u and gid=10: edit, read, rename, move, chmod utime, delete are ALL PERMITTED — includi recovery from chmod 000 with NO elevation Owner-class bits are selected by uid match a chmod is owner-only, so the operator can alw restore access. - Every FR-001 / FR-002 / FR-0(FR-010b is phrased as "owned by the account NO requirement mentions gid. - DECISIVE, conductor-verified in spec.md: the Constrain section blesses "Group-based workarounds (shared groups, permissive modes, access-co lists) are acceptable implementation routes", Dependencies makes "shared group plus inherited permissions" NECESSARY if the container platform cannot map the in-contai account to the operator's identity. => WIDEN THE PROBE would make FR-010 REFUSE TO START on a configuration the spec explicitly sanctions — a §11.4.201(1) false-positive refu the exact failure class this project keeps findi in its own gates. => AND THE REPAIR IS ALREADY DOING HARM: measured, after rep a new file inherits gid 1000 instead of 10 with setgid bit still set and NO diagnostic. The repa silently dismantles a spec-sanctioned shared- group setup. THE RED: tests/unit/ test_ownership_gid_agreement.sh (NEW file, lines, bash -n clean). It deliberately does NOT assert "the probe must call stat %g" — that is implementation assertion that survives a cosmetic fix AND hard-wires one fix directio

ATM ID	Type	Status	Severity	Description
				asserts the user-observable invariant: probe_location(L) == ok IFF ownership_repai --dry-run selects ZERO items under L. Measu 4 passed / 1 failed / EXIT=1, the failure being PRECONDITION certifies it (ok) while the RE reports it broken (selects:2)". VALIDATED AGAINST BOTH CANDIDATE FIXES from patc COPIES (production untouched): baseline FA · narrow-the-repair PASS(0) · widen-the-prob PASS(0). Golden-FALSE passes in all three, so neither direction can go green by refusing everything. That is what makes this RED fix-direction-agnostic rather than a vote. THE FI NOT APPLIED — scripts/ownership_repair.sh - find_args+=(\(! -uid "${OP_UID}” -o ! -gid “${OP_GID}" \) -printf '%U\t%G\t%m\t%p\0') + find_args+=(! -uid "${OP_UID}” -printf’%U BOB-208
BOB-210	Bug	Queued	major	WHAT: scripts/ ownership_precondition.sh:342-348 documen the docker branch of detect_rootless() as documented-not-measured (accurate — verif verbatim). The header then claims the branc built so that ‘an unverified reading can neve manufacture a refusal’. IT CAN. Line :413 em CONFIDENT rootful verdict whenever docke info succeeds with non-empty output contai no name=rootless field. Only the FAILURE m fall through to unknown (:387-394). THE PAT TO HARM: PUID=0 is declared in docker-compose.yml:32 (and again for jackett — deliberate per project policy). With a confide rootful verdict, that reaches the R3 refusal a :517. So a genuinely ROOTLESS Docker host whose docker info output SHAPE differs from documented one gets a FALSE REFUSAL produced by a branch the source itself admit was never measured — precisely the outcom the header promises is impossible. THE ORA PROBLEM (§11.4.245 independence): the shi tests DO cover this path (tests/unit/ test_ownership_rootless_detection.sh:283) —

ATM ID	Type	Status	Severity	Description
				the shim's output shape was authored from t SAME documentation as the code. Oracle and code share the unvalidated premise, so the te cannot discover that the premise is wrong. It confirms the code matches the doc; nobody h confirmed the doc matches Docker. ACCEPTA (1) either the header claim is corrected to ma :413's real behaviour, or :413 is changed to yi unknown when the reading is unverified — t two must agree (§11.4.6); (2) the docker branc premise is validated against REAL docker inf output from a real rootless daemon, or the branch is honestly marked unmeasured at th point of USE, not only in the header; (3) if validation is operator-gated (needs a rootless Docker host), record it as such per §11.4.21 ra than leaving the header's promise standing. ALSO VERIFIED GOOD, recorded so it is not r investigated: the unknown branch is handled IDENTICALLY at both consumers (R3 :519-53 :832-836 — both a named SKIP, both return 0, neither refuses), ROOTLESS_VERDICT is cach at :487 so both read ONE measurement, and t carrier-trap golden-FALSE fixture EXISTS (test_ownership_rootless_detection.sh:279-30 drives name=rootless-lookalike inside a profi path and must NOT read rootless; structural guard at :396-411 uses exact field equality, no substring). DISCOVERY CHANNEL (§11.4.238) found by the BOB-206 verification stream.
BOB-211	Bug	Queued	minor	STATUS: LATENT on this host (measured: all s declared locations sit on ONE btrfs mount, fu ownership-expressive) and OPERATOR-GATE for verification. Retained from the dismissed BOB-206 rather than discarded with it, becau the scenario is well-founded elsewhere: the declared mount is a udisks auto-mounted REMOVABLE NVMe, so another operator's portable drive being exFAT or NTFS is entirel ordinary. TWO RESIDUALS: (1) REPAIR-LAYE DIAGNOSIS. On a uid-flattening mount whose flattened uid is NOT the operator, probe_loca

ATM ID	Type	Status	Severity	Description
				correctly REFUSES (verified: uid=0 and uid=100999 both refuse). But it then hands ownership_repair.sh a chown that will return EPERM, and nothing in the repair path is fsty aware — so the operator sees a permission failure whose real remedy is a REMOUNT OPTION, which no message says. Reasoned, N proven: the shim used to verify BOB-206 mod the stat READ, not the chown WRITE, and can settle whether chown actually fails. (2) MODE CONTRACT. vfat flattens MODE via fmask/dm so the preserve_mode: true / 600 contract on and config/boba.db would be silently unenforceable there. §11.4.10-adjacent: a credential file believed to be 600 that is world readable by mount option is a leak the mode check cannot see. WHY OPERATOR-GATED: a genuine end-to-end RED needs a real uid-flattening mount. The privilege-free route is bindfs -u (FUSE; fusermount IS present and user_allow_other IS set) — but bindfs is ABSE on this host, as are mkfs.vfat and losetup. So verification needs either a bindfs install or a privileged loopback mount. Neither was attempted (§11.4.21 — high-blast-radius host mutation is operator-gated). ALSO RECORDE NO test anywhere exercises a uid-flattening filesystem — vfat/exfat/ntfs/flatten/loopback/ mkfs/losetup/bindfs/fusermount all measure across the three ownership test files, needle-proven (probe_location = 3 hits through the s instrument). ACCEPTANCE: (1) operator decid whether to install bindfs or provide a privile loopback so the RED can be built; (2) if verifie the repair path gains fstype-aware diagnosis naming the remount remedy; (3) the mode contract either detects mode-flattening mour and refuses, or documents honestly that it ca be enforced there. DISCOVERY CHANNEL (§11.4.238): retained residual from the BOB-2 verification stream.
BOB-212	Bug	Queued	critical	

ATM ID	Type	Status	Severity	Description
				WHAT: .gitignore:31 is a deny-all glob *creden* followed by a HAND-MAINTAINED per-file allowlist of ! exceptions (lines 34-50). Any NE source file whose name contains ‘credentials ‘creds’) is silently ignored: git add refuses it a git status shows NOTHING. The author gets n signal at all — the file simply does not exist a as the commit path is concerned. HOW IT SURFACED: the BOB-204 stream authored a R test named credentials_failclosed_test.go. It vanished. The agent noticed only because it w looking for the file it had just written. It rena to bob204_failclosed_test.go to escape both *credentials* and *creds*, and the file became vis A silent deliverable loss, caught by luck rathe than by any gate. INDEPENDENTLY RE-CONFIRMED BY THE CONDUCTOR, control-needle proven: git check-ignore -v –no-index qBitTorrent-go/internal/jackettapi/ credentials_failclosed_test.go -> .gitignore:31:*credentials* (IGNORED) git che ignore -v –no-index qBitTorrent-go/internal/ jackettapi/zzz_probe_test.go -> no match (NO ignored) <– the needle: instrument proven seeing, so the hit above is real git check-ignor –no-index frontend/e2e/credentials.spec.ts -> .gitignore:31:*credentials* (IGNORED) git ls-fi –error-unmatch frontend/e2e/credentials.spe -> tracked SECOND, LATENT INSTANCE: front e2e/credentials.spec.ts is matched by the sam rule and survives ONLY because it is already tracked (git honours the index over .gitignore tracked paths). Delete-and-re-add it — an ordinary refactor, a branch operation, a file r — and it disappears silently. It is one routine operation away from being lost. (For contrast credential-edit-dialog.component.spec.ts is genuinely safe: it is covered by the DIRECTOR rule !frontend/src/app/jackett/credentials/ at 43, not by a per-file entry.) WHY THIS IS A §11.4.201(6) FALSE-NULL, NOT MERELY AN INCONVENIENCE: the blind instrument and t clean tree return the identical quiet zero. git

ATM ID	Type	Status	Severity	Description
				status showing nothing means BOTH ‘no new files’ AND ‘a new file exists but is invisible’. T is no signal that distinguishes them. The com path — the thing every other gate’s output eventually has to travel through — cannot se own blindness. WHY IT IS NOT SIMPLY ‘ADD ANOTHER ! LINE’: that is the mechanism tha produced the defect. A hand-maintained allo against a deny-all glob has the §11.4.251/ §11.4.205 shape — every future legitimate credential-named source file needs a hand ed nobody will remember to make, and the failu mode of forgetting is SILENT. The same shap BOB-205’s hand-maintained DANGER_ROOTS list that must be edited in lockstep with the t with no guard that notices when it was not. TENSION TO RESOLVE HONESTLY (§11.4.10 v §11.4.201(1)): the glob exists for a real reason §11.4.10 forbids credential material reaching and a broad deny-all is the conservative-safe default. Narrowing it carelessly would re-ope genuine leak channel. So the fix is NOT ‘delet the glob’. Candidate directions, operator deci (§11.4.66): (a) narrow the deny to what actua carries secrets — extensions and directories (*.env, secrets/,* credentials*.json|yaml|yml|txt enc) rather than every path containing the wo (b) keep the deny-all but add a GATE that FAIL when an untracked file matches an ignore rule AND lives under a first-party source root AND a source extension, so the swallow becomes lo instead of silent; (c) both. (b) alone closes the f null even if the glob stays exactly as it is, and i smaller change. ACCEPTANCE: (1) a NEW credential-named source file under a first-part source root either commits normally or produ a LOUD refusal naming the rule that blocked i and the remedy — never silence; (2) a RED tha creates such a file and asserts the current silen flipping to the loud path post-fix (§11.4.115); (3 golden-FALSE proving real secret material (a . a key) is STILL ignored — the §11.4.201(1) gua because a fix that leaks credentials to close a f*

ATM ID	Type	Status	Severity	Description
				null is strictly worse than the defect; (4) fronte e2e/credentials.spec.ts is made safe by rule rat than by the accident of already being tracked. DISCOVERY CHANNEL (§11.4.238): found by t BOB-204 stream when its own deliverable disappeared — NOT by the automated QA regi and not by any gate. Nothing in the repo check that an authored file actually became visible t Coverage-escape audit: no surface exists for th class at all. === SCOPED AND MEASURED 2026-08-26 — RECOMMENDATION (b), AND (DISPROVEN NOT MERELY DISFAVOURED === TASK 1a — TRACKED FILES SURVIVING ONL BEING TRACKED: ***3, not 157.*** *A raw sweep of 2795 tracked paths hit 157 ignore rules — but* ***of those are NEGATIONS*** *(! lines), i.e. explici re-included and safe BY RULE. Reporting 157 a the blast radius would have been a §11.4.201(false positive; the investigating stream caught itself. Two independent instruments (check-ig -v filtered on non-negated patterns, and bare check-ignore which emits only truly-excluded paths) produced IDENTICAL sets. 1. frontend/ credentials.spec.ts — .gitignore:31* credentials HAZARD (the known one, 109-line Playwrigh spec) 2. tests/security/ test_jackett_autoconfig_secrets.py — .gitignor *secrets* — HAZARD, **NOT NAMED IN THIS IT WHEN FILED**. Conductor-verified: matched :51, currently tracked. It is a 113-line SECURIT PEN TEST asserting no credential value reach an HTTP body, traceback, or log. Losing it sile would remove the test that guards §11.4.10 — deny-all glob's own purpose. That is the shar instance available: the rule protecting credentials is one refactor away from deletin the test that proves credentials are protected submodules/jackett — .gitignore:260 — NOT a hazard: mode 160000 gitlink, and that entry i documented as deliberately inert for git (it st CodeGraph per §11.4.79). THE MECHANIC TH DECIDES THE FIX: the directory negation at : re-includes the DIRECTORY ONLY. A new

ATM ID	Type	Status	Severity	Description
				frontend/src/app/jackett/credentials/ credentials.guard.ts is STILL swallowed by :3 because *credentials* contains no slash and is therefore BASENAME-scoped — the allowliste directory buys nothing for new files. Of the 1 safe files, 124 are held by ONE robust glob negation (!docs/qa//***.log) and 13 by fragile h maintained per-file entries (all 13 current live, none stale — but each is a future silen loss). TASK 1b — ALREADY-SWALLOWED UNTRACKED FILES: 5 of 60,217 ignored+untracked paths. Two are real los (the tracker-credentials export twins and BOB-124 .txt evidence — filed as their own item); set_password.py is recorded UNKNOWN: provenance and deliberately called lost work; download-proxy/ qbittorrent_creds.json is the POSITIVE CONTROL — shape-inspected keys-only (ne values) as [password, username], genuine credential-bearing, CORRECTLY ignored. TASK 2 — MEASURED IN A SCRATCH TREE, source paths x 15 secret paths: baseline (fu 316-line file) swallows 10 | leaks 0 (a) EXACTLY AS THIS ITEM WORDED IT swallo 0 | leaks 3 (a) repaired to plug those 3 swallows 1 | leaks 1 (b) deny-all unchange loud gate swallows 0 | leaks 0 (a) LEAKS download-proxy/qbittorrent_creds.json — REAL CREDENTIAL FILE SITTING IN THE T TODAY — because credentials.json does no match “creds”. It also leaks my_password and service_credentials. Repairing those s leaves service_credentials: an extension-scoped deny cannot cover EXTENSIONLESS secret files without collapsing back into th deny-all it was meant to replace. So (a) as item worded it is DISPROVEN, not merely disfavoured — and I wrote (a) first in the candidate list, which was wrong. WHAT (b NEWLY ALLOWS INTO GIT: NOTHING — th set is EMPTY. No pattern changes, so the §11.4.10-vs-§11.4.201(1) proof obligation***

ATM ID	Type	Status	Severity	Description
				discharges trivially. No variant of (a) can make that argument. TASK 3 — THE RED: tests/security/ test_gitignore_swallow_is_loud.sh (filenan verified not swallowed BEFORE writing — joke this item is about). It asserts the acceptance DISJUNCTION (commits norma OR refuses loudly), so it is FIX-DIRECTION AGNOSTIC and leaves the direction an operator decision. The load-bearing asser is A3: git status is BYTE-IDENTICAL with a without the file — world A (authored) 330ceb52074cdbbe, world B (never made) 330ceb52074cdbbe. That is the false-null proven directly, not argued. Proven NOT a tautology: RED_MODE=1 -> exit 0; guard stand-in -> exit 0; narrowed glob -> exit 0; the §1.1 mutation DELETING the globs -> ex with 11 leaks caught, which is what makes golden-FALSE load-bearing rather than decorative. Exit 2 is deliberately distinct fr exit 1 so a blind harness can never read it "defect present". BEYOND WHAT THIS ITE FRAMED: it is not a **credentials/creds* problem.** secrets, _password* and *_user* ha EACH already swallowed something real.** *_user* is the broadest — it will match any future *_user.*txt / .json evidence or fixture. Th must be evaluated against the whole rule set, n the one glob that surfaced first. === SECOND I TRAP HIT, SAME SESSION (2026-08-26) === Th BOB-207 stream chose the natural filename te unit/test_ownership_user_owned_gid.sh for its RED. Conductor-verified: that path is SWALLOWED by .gitignore:60* _user. *The strea checked before writing (having been warned) a renamed to test_ownership_gid_agreement.sh, which is clean. That is the SECOND deliverable one session that the deny-all globs would have silently eaten — the first (BOB-204's credentials_failclosed_test.go) was caught only after the fact. It also confirms this item's own "beyond the item" warning empirically:* _user*

ATM ID	Type	Status	Severity	Description
				the broadest of the four globs and it caught a whose name contains no secret and no crede — merely the word ‘user’ inside ‘user_owned which is the FEATURE’S OWN NAME (spec 00 user-owned-downloads). Any test named afte this feature is a candidate for silent loss. Two in one session, from two independent stream not a coincidence rate — it is the defect opera normally.
BOB-213	Bug	Queued	critical	WHAT: the §11.4.252 fail-closed gate’s extens list omits shell entirely. Measured verbatim b the conductor at constitution/scripts/gates/ cm_dangerous_combination_fail_closed.sh:45 exts="${DANGEROUS_COMBO_EXT:-py go rs c cpp h hpp java cs js ts jsx tsx php rb}" No sh. bash. THE CONSEQUENCE, MEASURED: scrip IS a declared DANGER_ROOT (scripts/ pre_build_verification.sh:1511). It contains 71 tracked .sh files and 3 .py files. So 71 of 74 sou files in a root the gate is explicitly pointed at SILENTLY INVISIBLE — while invariant 39's driver prints "no fail-open anti-pattern acros first-party source root(s)". Project-wide there 198 tracked .sh files (negative control *.zzz = 0 instrument proven seeing). WHY THIS IS THE WORST OF THE THREE HOLES: BOB-205 is a scope hole (root never looked at). BOB-191 is matcher hole (Go enumerated but unanalysa THIS one is worse than either, because the ro declared, IS scanned, IS counted as covered, a 96% of what is in it was never examined. The count in the driver's own summary is an und count presented as a census. AND SHELL IS T HIGHEST-RISK LANGUAGE HERE, not the low the project's orchestration, credential handlin container control and gates are shell. start.sh alone is 1288 LOC and is, per CLAUDE.md, TH orchestrator. Fail-open in shell is also unusua easy to write — a bare `cmd \|\| true`, an unchecked `$?, aset +eregion, a swallowed2 dev/null– and §11.4.67(6) already records live instance of exactly this class (a bar

ATM ID	Type	Status	Severity	Description
				exec redirection silencing an interactive shell for its lifetime). CORRECTION TO A PREVIOUSLY-STATED ACCEPTANCE CRITERION (§11.4.6): I asserted, when filing BOB-205 that "the honest-blindness path (§11.4.3 S with-reason, which the gate already implem correctly for unenumerated extensions) is preserved". THAT IS WRONG. The gate's hone SKIP-with-reason exists for the PYTHON ARM degradations, NOT for extensions absent fr the ext list. An unenumerated extension is SILENT false-null, not an honest skip. The distinction is load-bearing and I stated i backwards. NOTE ON LINE NUMBERS: the BOB- stream cited the ext list at :318; the conductor measured it at :457. Both are correct at their read times — a sibling st (BOB-195 r7) is actively editing this file Re-derive before acting. ACCEPTANCE: (1) either shell is added to the ext list WITH arm that can actually analyse it, or unenumerated extensions produce an explici UNANALYSED verdict per file — never a sile pass (this is the same analyser-registry f BOB-191 needs, and doing it once covers bo (2) the driver's summary reports files ANALYSED, not files present, so an under-c cannot masquerade as a census; (3) a RED planting a shell fail-open under scripts/ asserting it is SEEN; (4) golden-FALSE per §11.4.201(1) — a correctly fail-CLOSED she guard must NOT be flagged; §11.4.67's own brace-scoped exec form is the natural fixture. COMPOSES: BOB-191 (matcher hole same primitive: classify by local shape, r consult semantic role; and the analyser- registry fix closes both) and BOB-205 (sco hole). Per §11.4.250 these are three sympt of one primitive defect; per §11.4.214 the stay three items because the fixes differ. DISCOVERY CHANNEL (§11.4.238): found by th BOB-205 verification stream, confirmed independently by the conductor. Not by the

<table>
<thead>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
</thead>
<tbody>
<tr><td></td><td></td><td></td><td></td><td>automated QA regime. | | BOB-214 | Bug |
Queued | critical | WHAT: DANGER_ROOTS =
(download-proxy/src plugins scripts
qBitTorrent-go frontend/src) at scripts/
pre_build_verification.sh:1511. The REPOSI
ROOT itself is not among them (conductor-
verified: no "." entry). Everything living
the top level is scanned by no arm. THE L
HIT: webui-bridge.py — tracked at root
(conductor-verified), 466 LOC, a live HTTP
service on port 7188
(BaseHTTPRequestHandler:85, do_GET/
do_POST:92-97, request path read at :103,
outbound urlopen at :273, environment
credentials read at :55-74). The gate REPO
A REAL HIT AT :295 when pointed at it
directly. This is not a hypothetical gap:
existing gate, unmodified, finds a genuine
defect in this file the moment scope reach
it. ALSO UNSCANNED AT ROOT: 13 first-part
shell scripts including start.sh (1288 LOC
per CLAUDE.md the project's orchestrator a
the sole sanctioned container-control entr
point), stop.sh, ci.sh, install-plugin.sh,
the credential-handling init-qbit-
password.sh / fix-qbit-password.sh. (These
additionally invisible for the separate
LANGUAGE-hole reason — shell is not in the
gate's ext list — so root files get missed
twice over, by scope AND by extension.) T
SCALE THIS SITS IN: 266 files in scope / 5
out of scope — 66% of the gate-visible fir
party corpus is never scanned. Other unsca
roots measured: tests/ (324 files, exclude
by-intent but UNDECLARED — an undeclared
exclusion is exactly what §11.4.224(E) fen
against), extension/ (108, shipped browser
extension), docs/ (51), challenges/ (18),
tools/ (1, and it CONCEALS 3 REAL HITS at
plugin_update_automation.py:189,198,215),
frontend/e2e + 2 configs (5). SO THE SCOP
HOLE CONCEALS AT LEAST 4 REAL HITS the gat
itself finds when pointed at them (1 in we</td></tr>
</tbody>
</table>

ATM ID	Type	Status	Severity	Description
				bridge.py, 3 in tools/). Invariant 39's reported count is an under-count, not a census. ACCEPTANCE: (1) repository root a tools/ are scanned, or explicitly fenced w a stated reason per §11.4.224(E) — silence not an exclusion; (2) the 4 concealed hits triaged (each is either a real defect to f or a false positive to fix in the gate — b are findings); (3) tests/ (324 files) gets OPERATOR decision per §11.4.66 — productio only is defensible but must be DECLARED; (RED proving a root-level fail-open is seen (5) golden-FALSE proving genuine build artefacts and vendored trees stay excluded FIX DIRECTION (measured by the BOB-205 str not guessed): a §11.4.251 manifest is feas but the source of truth must be chosen carefully — docker-compose.yml build conte MISS plugins/, frontend/src, cmd/boba-ctl webui-bridge.py; language markers (go.mod/ package.json) MISS plugins/ and webui-bridge.py. Only derive-from-git-tracked-source-extensions minus a declared §11.4.224(E) exclusion fence reaches every gap. Note the derivation must be built eit way — if the operator prefers keeping a ha list, the omission-guard that audits it is SAME computation; the only question is whe it drives the scan or audits the list. DISCOVERY CHANNEL (§11.4.238): found by th BOB-205 verification stream while enumerat the full gap list — the item it was verify named only one missing root. Not by the automated QA regime. === CORRECTION 2026-08-26 — THE "4 CONCEALED REAL HITS" C IN THIS ITEM IS REFUTED (§11.4.6) === Whe filed this item I wrote that the scope hol "conceals at least 4 real hits the gate it finds when pointed at them". A dedicated triage stream ran the UNMODIFIED gate agai scratch copies, reproduced all four hits exactly, and triaged them: **4 of 4 are FA POSITIVES.** The instrument was control-

ATM ID	Type	Status	Severity	Description
				needle-proven in BOTH directions first (fi on a planted except: pass, stayed silent on clean log-and-reraise), so this is evidenc not a null. All four are the SAME detecto class — shape (A2) "silent default return" which is precisely the BOB-189 false-posit shape: the returned literal IS the functio designed refusal value, consumed by a call that checks it. - webui-bridge.py:295 (_is_root_liveness_probe): False -> send_error(502) at :438. The except DENIES lenient 200 path. Fail-CLOSED. Combines ZE of the six §11.4.252 capabilities — a pure classifier over self.path/self.command. - tools/...:189 (_download_url): None -> :11 handles it explicitly (warn + continue), r write. Handler BOUNDED to (URLError, HTTPError); anything else propagates. - tools/...:198 (_extract_version): "unknown gates nothing — the update decision is the HASH compare at :116. (It IS a bare except: though, so Ctrl-C is swallowed - separate signal-handling defect, filed wit the README item.) - tools/...:215 (_validate_plugin): False -> :151 returns BEFORE the write at :165. This IS the refu Canonical BOB-189 shape. WHAT THIS DOES A DOES NOT CHANGE. The scope hole itself is UNCHANGED and still real — the repository and tools/ are in no DANGER_ROOT, verifie verbatim at scripts/ pre_build_verification.sh:1511. What chang is the ARGUMENT: I justified this item par on "it hides four known defects", and that justification is wrong. The correct justification is narrower and does not dep on any current hit: webui-bridge.py is a L LAN-BOUND HTTP service (see below) handlin request paths, outbound calls, and enviro credentials — a surface that belongs in sc on its capabilities, whether or not it currently contains a defect. NEW FACT RAI THE STAKES — 7188 IS LAN-REACHABLE. webui-

ATM ID	Type	Status	Severity	Description
				bridge.py:447 binds ThreadingHTTPServer((" BRIDGE_PORT)) — conductor-verified. The em host string is INADDR_ANY, so port 7188 listens on ALL INTERFACES, not loopback. Neither localhost-only nor internet-expose (internet only if forwarded). No severity assigned to :295 because it is fail-closec but this is the argument for putting the r in scope: a live LAN-bound service should scanned on principle, not after a defect i found in it. webui-bridge.py IS LIVE, DECISIVELY (§11.4.124 never engages — do N treat it as superseded): 142 tracked files reference it, including config/ served_ports.yaml and the credential-leak- audit challenge; download-proxy actively probes it via bridge_health() at download- proxy/src/api/__init__.py:198; newest of 1 commits is a real functional fix (6e3da73, 2026-06-14). Critically, served_ports.yaml:66-69 records that the G webui-bridge is a SEPARATE binary the qbittorrent-proxy-go container never start so NOTHING ELSE BINDS 7188 and this Pythor file is the only thing serving that port. tools/ RECOMMENDATION (§11.4.224(E)): FENC OUT, DECLARED — exclusion class "non-shipp developer utility". Evidence: 2 tracked fi neither gitignored; the script is invoked NOTHING (control-needle-proven: 91 needle hits, 0 negative control — referenced only its own README, its own docstring, and a tracker note; zero hits across *.sh/*.yml/ *.py/Makefile outside tools/); its README self-declares "not invoked by the normal start/stop flow"; last functional commit 2026-04-12. Because it is FIRST-PARTY, §11.4.224(E) requires the exclusion carry tracked §11.4.197 item — and the two REAL defects found in it must be tracked regarc of scope, since a hand-run --update still executes them. | | BOB-215 | Bug | Queued major | WHAT: cmd/boba-ctl/main.go:498-509

ATM ID	Type	Status	Severity	Description
				authMethod(). Its default branch (:507) returns remote.AuthSSHKey. A deploy-regist entry whose auth: key is misspelled, empty set to an unrecognised value therefore resolves SILENTLY to SSH-key authenticatio rather than refusing to act. WHY IT IS A §11.4.252 VIOLATION: this is a credential- selection decision on a path that also performs remote mutation and external side effects. §11.4.252 requires a path combini >=2 dangerous capabilities to FAIL CLOSED verify every precondition, refuse when any unverifiable, and name the unresolved precondition. Silently substituting a defa credential MECHANISM for an unreadable declaration is the textbook fail-open shap the operator's intent was not determined, the code proceeded anyway using a method t may not have chosen. WHY NO GATE CAUGHT I three independent reasons, each sufficient its own — (a) cmd/boba-ctl is in no DANGER_ROOT (BOB-205); (b) even in scope, files are structurally unanalysable by the current gate (BOB-191); (c) this shape is semantic default-branch decision, not one the two text patterns the non-Python arms match. It was found by a human-equivalent read, which is precisely the §11.4.238 esc class. HONEST QUALIFICATION (§11.4.6): cm boba-ctl/main.go has NO_ = err, NO emptyif e nil {}, and NO silentreturn niltoday — grep- verified with a control needle against qBitTorrent-go/internal/config/config.go. finding is the exception, not one of many; scope hole around boba-ctl is otherwise LA (it hides nothing else live, it guarantees future one lands unseen). ACCEPTANCE: (1) unrecognised/empty auth: value REFUSES wit error naming the offending key and its declared value, never silently defaults; (RED driving a typo'd auth: and asserting today's silent SSH-key resolution, flippin refusal post-fix; (3) golden-FALSE proving

ATM ID	Type	Status	Severity	Description
				every LEGITIMATE auth: value still resolve correctly — a false refusal here would bre real deploys (§11.4.201(1)). DISCOVERY CHANNEL (§11.4.238): found by the BOB-205 verification stream while confirming boba- qualifies as a §11.4.252 surface. | | BOB- | Bug | Queued | major | WHAT: three carri classes fire in the gate's PRIMARY mode, r only its degraded text fallback. Measured ast_rc=1 AND text_rc=1 (both modes report hit): (a) a COMMENT or DOCSTRING quoting credential anti-pattern is reported as a L credential default — both spellings; (b) comment or a string constant holding try { x catch (e) { } is reported as an empty catch, once per carrier line. Shape (b), and the C-family of shape (a), are LANGUAGE-AGNOSTIC GREPS NO structural counterpart in any mode — so there is no parser to be immune. WHY IT MATTERS: the gate's header carried a blank claim that "A parser is immune to both by construction". That is OVER-BROAD and now corrected in place, scoped to the Python T With shapes where it is actually true. Everything else — every non-Python extensi and the credential/empty-catch text matche even on Python — has no AST arm at all, so immunity never applied there. A §11.4.201(false refusal in the PRIMARY mode is materially worse than one in a fallback no expects to be exact: it refuses provably- healthy code on the path the gate is trust on. THE CONTROL NEEDLE THAT SHARPENS IT (recorded so the next reader inherits the measurement): a #-COMMENTED import does NO poison the licensing table (text=0), becau those regexes are line-anchored. So the blindness is to STRINGS specifically, not non-code generally. That distinction is wh makes the comment-strip fix tractable for class and not for the others. WHY IT WAS FIXED IN THE ROUND THAT FOUND IT (§11.4.6

ATM ID	Type	Status	Severity	Description
				honest boundary, and this is the right cal closing these needs a PER-LANGUAGE comment and-string model across every configured extension. That model's failure direction the UNDER-reporting one — a mis-parsed str region silently swallows real violations f the remainder of the file. The same reason made the round DECLINE the triple-quote fe counter for OVER-1 while ACCEPTING the com strip for OVER-A: the comment strip's ambiguity resolves toward KEEPING text (pr by three control needles — real violation comment, # inside a string, escaped quote before # — all 1/1), whereas a fence count ambiguity resolves toward DROPPING text. Direction of failure, not difficulty, is t discriminator. Building a full lexer here would import the under-reporting failure m this gate refuses everywhere else. OPERAT DECISION (§11.4.66 / §11.4.197): whether t build per-language comment-and-string mode is a consumer call, not a default this gat should pick unilaterally. Options: (a) acc the over-reports and DISCLOSE them per cla (what the round did — a new MODE-INDEPENDE CARRIERS section now enumerates all three) (b) build the models per language and own under-report risk with a fixture per langu (c) narrow the language-agnostic greps so only fire where a structural arm exists, trading coverage for precision. RELATION SIBLINGS (§11.4.214 distinct-but-similar, deliberately not merged): BOB-189 is the g flagging a fail-CLOSED SSRF guard — a semantic-role miss in the PYTHON arm. This a CARRIER miss (comment/string read as coc that is MODE-INDEPENDENT. BOB-213 is a language absent from the ext list entirely All three share the primitive §11.4.250 na in BOB-191: classify by local syntactic sh never consult semantic role — but the fixe differ, so the items stay separate. ACCEPTANCE: (1) the operator decision abov

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>taken and recorded; (2) whichever path is chosen, each of the three classes has a fixture proving current behaviour, so a fu change cannot silently alter it; (3) if (b chosen, a golden-FALSE per language provir REAL violation adjacent to a carrier is st caught — the under-report guard, which is whole risk. DISCOVERY CHANNEL (§11.4.238) found by the BOB-195 round-7 remediation stream while closing a different finding, by the automated QA regime and NOT by the independent reviewer that audited the same file in round 6. | | BOB-217 | Bug | Queue critical | WHAT: tools/ plugin_update_automation.py update_plugin(combines three §11.4.252 dangerous capabilities and is gated by nothing that could stop a hostile payload: - UNTRUSTED INPUT: 14 URLs across four GitHub repositories, THREE of which are third-par PERSONAL repos, not the official qbittorre organisation. - MUTATION: writes plugins/ <name>.py. - DEFERRED CODE EXECUTION: qBittorrent EXECUTES those engine files. T bytes fetched over the network become runn code on the operator's host. The ONLY validation is compile(content, "<string>", "exec") at tools/ plugin_update_automation.py:213 — conducto verified as the sole compile call. That is SYNTAX check. A syntactically valid file i exactly what a hostile payload is. There i signature verification, NO pinned commit S NO hash allowlist, NO provenance check of kind. §11.4.252 requires a path combining dangerous capabilities to FAIL CLOSED — ve every precondition, refuse when any is unverifiable. This path combines THREE and verifies none of them. §11.4.246's supply-chain clause is the direct counterpart: dependencies are either vendored hash-verified, provenance-attested, or mirrored through a hash-pinning registry — an</td></tr>
</table>

ATM ID	Type	Status	Severity	Description
				unattested public source is an integrity r and here the unattested public source becc EXECUTED CODE. THE SHARPEST FACT ABOUT TH FINDING: the fail-closed gate produced THR FALSE POSITIVES in this same file (:189, : :215 — all triaged FALSE POSITIVE, see BOB-214's correction) while MISSING this, one genuine dangerous combination in it. T is the §11.4.201 both-directions failure - false-positive and false-negative — demonstrated inside a single file. It is t strongest available evidence that the dete classifies by local syntactic shape and ne consults semantic role (the §11.4.250 primitive named in BOB-191/BOB-216). REACHABILITY, STATED HONESTLY (§11.4.6): t script is invoked by NOTHING — control-nee proven (91 needle hits, 0 negative control is referenced only by its own README, its docstring, and a tracker note; zero hits across *.sh / *.yml / *.py / Makefile outs tools/. Its own README self-declares "not invoked by the normal start/stop flow". La functional commit 2026-04-12. So this is N live in any automated path. It IS reachabl a hand-run --update, which is exactly what tool exists for. Severity is Critical on t capability combination, bounded by that reachability — not on an active exploitati path. ACCEPTANCE: (1) plugin sources are pinned (commit SHA or content hash) and verified before write; (2) an unverifiable source REFUSES and names which check faile (§11.4.252) rather than proceeding on a sy pass; (3) the compile() call is documented source as a syntax check that is NOT a saf gate, so nobody reads it as one; (4) a RED serving a syntactically-valid hostile payl and asserting it is REFUSED pre-fix-absent post-fix-present; (5) golden-FALSE proving legitimate pinned update still succeeds (§11.4.201(1)). DISCOVERY CHANNEL (§11.4.238): found by the concealed-hits

ATM ID	Type	Status	Severity	Description
				triage stream while establishing that the gate's four hits in this area were false positives. Not by the automated QA regime and the regime that WAS pointed here repor the wrong three lines. | | BOB-218 | Bug | Queued | major | WHAT: tools/README.md:30 states "the backup is restored" on validat failure. Conductor-verified: shutil.copy2 appears EXACTLY ONCE in tools/ plugin_update_automation.py and copies FOR only — a reverse-direction restore has ZER occurrences (grep control-needle-proven seeing: needle 2 hits, negative control 0) The plugin write opens in mode "w", which TRUNCATES IMMEDIATELY. USER-OBSERVABLE HA (the reason this is not merely a doc defec a failure part-way through the write leave TRUNCATED, NON-IMPORTABLE plugin on disk. operator is told the update FAILED and reasonably concludes the previous file survived — because the README says it was restored. It was not. The next ./install- plugin.sh copies the corrupt file into cor qBittorrent/nova3/engines/ and that search engine SILENTLY STOPS WORKING. The .bak ne to recover DOES exist on disk; the tool ne mentions it and never uses it. This is a §11.4 documentation-layer bluff with a rea downstream consequence: the doc asserts a safety property the code does not implemen and the operator's recovery decision is ma on that false assertion. SECOND, SMALLER DIVERGENCE: the README claims JSON goes to stdout; :274 writes it to a FILE (open(args.output, "w")). THIRD, SEPARATE MINOR DEFECT in the same file (recorded he rather than as its own item because it sha the file and the fix window): _extract_ver at ~:198 uses a BARE except:, so a Ctrl-C during the 14-URL sweep is SWALLOWED. That a signal-handling defect, not a fail-open the gate flagged this line, but for the wr reason (it read the silent default return;

ATM ID	Type	Status	Severity	Description
				real issue is the bare except catching KeyboardInterrupt). ACCEPTANCE: (1) eithe the rollback is IMPLEMENTED (restore the . on failure) or the README claim is DELETED the doc and the code must agree (§11.4.6); implemented, write to a temp file and rena atomically rather than truncating in place (2) the stdout-vs-file claim corrected; (3 the bare except narrowed so KeyboardInterr propagates; (4) a RED that fails the write mid-way and asserts the previous plugin is intact (post-fix) / truncated (pre-fix). REACHABILITY: same as the sibling item — h run only, not in any automated path, last functional commit 2026-04-12. Severity Maj on the harm shape, bounded by that reachability. DISCOVERY CHANNEL (§11.4.23 found by the concealed-hits triage stream. by the automated QA regime. | | BOB-219 | | Queued | major | WHAT, conductor-verifie docs/guides/tracker-credentials.md is TRAC Its §11.4.65-mandated export twins docs/ guides/tracker-credentials.html and .pdf b EXIST ON DISK, are NOT tracked, and ARE ignored — matched by the .gitignore *credentials* deny-all at :31. The .md is rescued by an explicit allowlist entry at nobody added entries for the twins. WHY I A LIVE VIOLATION AND NOT A HYPOTHETICAL: §11.4.65 requires every in-scope Markdown document to carry synchronized .html/.pdf siblings, and §11.4.212 requires every §11.4.65-scope doc to be reachable from th README. Two artifacts that exist locally b can never be committed are, from any fresh clone, ABSENT — so every clone of this repository has a tracker-credentials guide with no exports, while the authoring host looks complete. The divergence is invisibl the machine that would notice it. WHY NOB SAW IT: this is a §11.4.201(6) FALSE-NULL the BOB-212 class. git status never listed twins, so no gate and no author had a sign

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>The blind instrument and the clean tree re the identical quiet zero. ANOTHER INSTANC THE SAME MECHANISM, filed here rather than separately because it is one fix: docs/qa/ BOB-124/evidence/loginctl_user_state.txt i swallowed by *_user* at .gitignore:~55 and therefore uncommitted §11.4.83 QA evidence Its SIBLINGS IN THE SAME DIRECTORY — user1000_grepped.log, user_scope_events_head.log, user_service_lifecycle.log — ARE tracked, saved only by the robust glob negation !do qa/**/*.log. That one file is lost purely because it is .txt rather than .log. The pattern is exact: robust glob negations ho per-file and per-extension rescues leak. ACCEPTANCE: (1) both twins become trackabl and are committed alongside their .md; (2) BOB-124 .txt evidence likewise; (3) whiche BOB-212 fix direction is chosen, it MUST c these — a fix that closes the future-swall while leaving these three artifacts permanently uncommittable has addressed th mechanism and not the damage; (4) a check a tracked .md in §11.4.65 scope has COMMITTABLE twins, so this class cannot re silently. DISCOVERY CHANNEL (§11.4.238): found by the BOB-212 blast-radius sweep — only on its SECOND pass. The first pass filtered by a source-extension set that omitted .pdf, which hid this finding entir the agent re-ran with no extension filter all 420 non-artifact paths and recorded th blind spot rather than shipping the first number. Worth keeping: an extension allowl is itself a false-null generator, which is same shape as the defect being investigate | BOB-220 | Bug | Queued | minor | WHAT: scripts/ownership_repair.sh:891-895 runs c 755 intending to strip setuid/setgid bits. Traced live: the chmod RUNS and SUCCEEDS, the mode stays 2755. Root cause measured — chmod with a 3-DIGIT symbolic-equivalent c</td></tr>
</table>

<table>
<tr><th>ATM ID</th><th>Type</th><th>Status</th><th>Severity</th><th>Description</th></tr>
<tr><td></td><td></td><td></td><td></td><td>PRESERVES the setgid bit on DIRECTORIES; c
a 4-digit form (00755) or an explicit g-s
clears it. The comment at :868-884 describ
strip that does not occur for directories.
EFFECT: benign today — the surviving setgi
bit is not itself harmful, and no defect i
known to follow from it. This is filed as
§11.4.6 accuracy defect: an in-source comm
asserting behaviour the code does not perf
That matters because the next reader will
trust it, and because a future security-
relevant strip written against the same
pattern would silently fail the same way.
RELATION TO BOB-207: the same stream measu
that after repair a new file inherits gid
with THE SETGID BIT STILL SET — the two fa
compound. If BOB-207 is resolved by narrow
the repair (the recommended direction), th
setgid survival becomes moot for that path
the misleading comment remains. ACCEPTANC
(1) either the strip is made real (00755 o
s) or the comment is corrected to state th
directories retain setgid — code and comme
must agree; (2) if made real, a RED assert
mode 2755 -> 0755 on a directory, since th
current form silently no-ops; (3) golden-F
proving a directory that SHOULD keep its m
is not gratuitously changed. DISCOVERY
CHANNEL (§11.4.238): found by the BOB-207
stream while tracing an unrelated behaviou
Not by the automated QA regime. | | BOB-22
Bug | Queued | critical | WHAT: scripts/
pre_build_verification.sh invariant 30 (CM
BASH-UNIT-TESTS-EXECUTED) enumerates suite
FILESYSTEM GLOB (:1196) and calls fail() o
any non-zero exit. It therefore RUNS untra
suites, and it has NO concept of a test th
is SUPPOSED to fail. MEASURED: tests/
pre_build/test_bob205_danger_roots_scope.s
exits 1 — correctly, because it is a RED t
for BOB-205, an unfixed defect. Invariant
counts that as a gate failure. The predict
T042 verdict is FAIL, and this is one of i</td></tr>
</table>

ATM ID	Type	Status	Severity	Description
				three blocking causes. THE STRUCTURAL PROBLEM: §11.4.115 and §11.4.224 REQUIRE a authored FIRST and OBSERVED TO FAIL before fix exists. §11.4.135 requires the RED to persist as the permanent regression guard. the discipline mandates that failing tests exist in the tree between authoring and fi — and the blocking gate treats their exist as a defect. Following the constitution correctly makes the gate refuse the commit That is a §11.4.120 wrong-seam problem: th gate asserts "no suite fails" when the invariant it should assert is "no suite fa UNEXPECTEDLY". WHY IT SURFACED NOW: this session authored FOUR REDs across parallel streams (BOB-204, BOB-205, BOB-207, BOB-21 the first time the discipline was applied this volume. Previously REDs were flipped GREEN within the same round, so the window never spanned a gate run. The defect is no new; the exposure is. THE FORBIDDEN RESPO (§11.4.120): do NOT delete the RED to make gate green; do NOT weaken invariant 30 to ignore failures; do NOT mark the RED skipp without a tracked reason. Each converts a signal into silence. FIX DIRECTION — this §11.4.248's quarantine mechanism, which th constitution already specifies and this project has not wired: a RED declares its expected-failing status and its tracked it (a header marker, a naming convention, or manifest), invariant 30 reads that declaration, and a declared-RED failure is reported as EXPECTED (not a fail) while an UNDECLARED failure still blocks. Crucially declaration must EXPIRE or be tracked — §11.4.248 pairs quarantine with a stabilisation deadline precisely so "expec to fail" cannot become permanent cover. A whose item closes must flip GREEN or the g should FAIL on the stale declaration. ACCEPTANCE: (1) a declared RED does not bl (2) an UNDECLARED failing suite still bloc

ATM ID	Type	Status	Severity	Description
				(the §11.4.201(1) guard — a fix that ignor all failures is strictly worse than the defect); (3) a declared RED whose tracked is CLOSED blocks, so declarations cannot r (4) a paired §1.1 mutation removing the declaration-check makes the gate accept ar undeclared failure -> gate FAILs. DISCOVE CHANNEL (§11.4.238): found by the T042 readiness preflight, before the endgame ra than during it. Not by the automated QA re — the regime IS the thing that would have blocked. === CORRECTED 2026-08-26 — MY FI DIRECTION IN THIS ITEM WAS WRONG, AND THE BLOCKER IS WIDER (§11.4.6) === CORRECTION §11.4.248 IS NOT THE MECHANISM. I wrote "t is §11.4.248's quarantine mechanism, which constitution already specifies and this project has not wired." That is half right the wrong half matters. §11.4.248(A) QUARANTINE targets FLAKY tests — its trigg is literally "two-consecutive-run-differer verdict OR rerun-after-red", and its remed to MOVE the suite to tests/quarantine/ and the blocking suite WITHOUT it "so green me green". §11.4.248(B) PROTECTED-SPEC is a t plus a required-reviewer gate on MODIFYING regression test; it never says a test may fail. A RED is DETERMINISTIC and MUST STIL RUN — §11.4.115(F) and §11.4.226 require t RED verdict to be PRODUCED as the evidence Excluding it destroys the very artifact th discipline mandates. Merging the two would also let a genuinely flaky suite hide behi RED declaration and vice versa. What §11.4 legitimately supplies, and what should be INHERITED rather than re-invented (§11.4.2 is the SHAPE: a by-name list + a tracked i + a deadline + a must-only-shrink ratchet. CORRECTION 2 — THIS IS A LANGUAGE-PARITY G NOT A DESIGN VACUUM. Conductor-verified: t project ALREADY runs this mechanism on the PYTHON side. pytest.mark.xfail(strict=True used deliberately for OPEN defects at test

ATM ID	Type	Status	Severity	Description
				scaling/test_scaling_envelope.py:907 (BOB- documented in tests/scaling/README.md:64) tests/stress/ test_plugin_parsers_stress_chaos.py:90 — w own comments carry the ratchet discipline verbatim ("it stays visible as xfailed in every report", "then remove this xfail"). "declared expected-failure, strict so an unexpected pass fails" is ALREADY accepted policy in one language. The BASH side has equivalent. That is the real gap. CORRECT 3 — BOB-221 IS NOT SUFFICIENT TO UNBLOCK T A full replication of invariant 30 measure RAN=38 FAILED=4 SKIPPED=2: rc=124 300s test_compute_badges_carrier_match.sh <- a HANG, not a RED. Blocks independently. Fil separately. rc=1 3s test_ownership_gid_agreement.sh <- BOB-207's RED (a SECOND in-glob RED; this assumed one) rc=1 1s test_bob205_danger_roots_scope.sh <- BOB-205's RED rc=127 9s test_check_cm_lan_routes_authenticated.sh CONTAMINATED: a sibling stream was writing lan_route_auth_analyzer.py during and afte the run (§11.4.119 — the surveying stream not own that resource and correctly declin to adjudicate). rc=127 is the §11.4.1 scri internal FAIL-bluff signature, not a produ verdict either way. Returned to its owning stream. ALSO: BOB-204's and BOB-212's REDs share tests/security/ test_gitignore_swallow_is_loud.sh, which i OUTSIDE invariant 30's glob and executed b NOTHING (BOB-222) — they do not block toda and widening the glob would immediately ad another blocker. THE DESIGN, RECOMMENDED: two-place declaration + SSoT expiry + stri semantics. THREE independent facts must ag before a failure is excused — (1) the suit listed in scripts/lib/expected_red.sh, a f the PRODUCING streams do not own; (2) the suite file itself carries# EXPECTED-RED:

ATM ID	Type	Status	Severity	Description
				with the SAME id; (3) <ID> is OPEN in docs workable_items.db, FAIL-CLOSED on unreadab store or unknown id (§11.4.252). Plus STRI XFAIL PARITY: a declared suite that PASSES blocks, which mechanically forces the ratc to shrink in the same commit as the fix. EXIT-CODE CONVENTION REJECTED ON MEASURED EVIDENCE — and I had flagged it as promisi The non-{0,1} exit space is ALREADY CLAIME THIS REPO FOR THE OPPOSITE MEANING: test_gitignore_swallow_is_loud.sh uses exi = "INSTRUMENT BROKEN or SECRET LEAK — verd void", and test_bob205_danger_roots_scope. uses exit 3 = ABORT (instrument blind). Bo were chosen precisely so a blind harness c never be read as a verdict. Overloading ei for "expected red" would make a genuinely BLIND INSTRUMENT INDISTINGUISHABLE FROM A DECLARED RED — the gate would swallow exac the failure class those codes exist to mak loud. It also fails acceptance (4) (an int carries no item id) and (3) (nothing to ro check), and it puts the declaration inside PRODUCER, collapsing producer!=gate (§11.4.240/§11.4.249). HONEST BOUNDARY ON DESIGN (§11.4.240): it achieves separation LOCATION and MULTI-PLACE AGREEMENT, not by true CAPABILITY, which §11.4.240 prefers. There is no PR/CODEOWNERS seam here to enf capability — CLAUDE.md Hard Stop #1 remove all CI/PR gates, so the CODEOWNERS half of §11.4.248(B) is STRUCTURALLY UNENFORCEABLE this project. What the design buys is that silencing a failure requires a coherent th place story visible in a diff, instead of comment line. THE RED: tests/pre_build/ test_bob221_expected_red_declaration.sh. I extracts invariant 30's loop and its block predicate VERBATIM FROM THE LIVE GATE BY CONTENT MARKER (never line number) and RUN them against a hermetic scratch PROJECT_RO so the logic under test is the gate's own text, not a paraphrase (§11.4.226 anti-ech

ATM ID	Type	Status	Severity	Description
				Measured RED: 3 of 5 properties unmet, exi P3 is asserted on the blocking REASON, not merely on "it blocked" — today everything blocks, so a bare did-it-block check would pass FOR THE WRONG REASON and keep passing the anti-rot half were never built. Polari flip proven with the BYTE-IDENTICAL test f against a sandbox carrying the patch: exit all five properties met. Four paired §1.1 mutations each kill exactly ONE property, to-one, no cross-talk. THE PATCH: 72 line hunks + one new file scripts/lib/ expected_red.sh,git apply –checkclean, NOT APPLIED. Operational note the landing comm must not miss: the table names test_bob205_danger_roots_scope.sh and test_ownership_gid_agreement.sh, but NEITH carries an# EXPECTED-RED:` marker today (verified 0 in both) — without those two one- additions the gate blocks them with”declared the file carries no matching marker”, which i the fail-closed design working as intended, n bug. SEQUENCING RECOMMENDATION: (iii), bounded variant of (i) — land the mechanism declaring exactly BOB-205, BOB-207 and this item’s own suite, add the two missing marke triage the rc=124 hang as its own item, retur rc=127 to its owner, THEN run T042. THE HONEST COST, STATED NOT HIDDEN: this modifies the blocking gate BEFORE that gate ever run clean, so the mechanism’s first full-g exercise IS the T042 run. The circularity is unavoidable and IS this item (§11.4.120 — a g whose precondition is produced by the work gates): a clean T042 run is impossible while a RED exists, so “validate the gate before chan it” cannot be satisfied. Risk reduced as far as possible without running the gate (proven- applicable patch, proven polarity flip, four bi mutations, P2 undeclared-failures-still-block asserted and mutation-proven) but NOT eliminated. Against (ii) fix-the-four-defects-fi all four are Queued and genuinely deferred;

ATM ID	Type	Status	Severity	Description
				BOB-212's fix direction is an explicitly unreso §11.4.66 OPERATOR decision whose own test deliberately written fix-direction-agnostic so not to prejudge it — choosing (ii) means mak that decision on the operator's behalf, plus fo implementations and four reviews, and it STI leaves the hang and the rc=127 blocking. RECURSION NOTE: this item's own RED is in-g and failing, so it is itself a 5th blocker until th mechanism lands — at which point its alread present marker and table row clear it. The mechanism is its own first customer.
BOB-222	Bug	Queued	major	WHAT: scripts/pre_build_verification.sh:1196 enumerates bash suites with a glob covering EXACTLY three directories: "${PROJECT_ROO tests/unit/test_*.sh · "${PROJECT_ROOT}"/tests pre_build/test_*.sh · "${PROJECT_ROOT}"/tests/ hooks/test_*.sh tests/security/ is NOT among th Conductor-verified verbatim. So tests/security test_gitignore_swallow_is_loud.sh — a RED authored this session with a golden-FALSE gu proving real secrets stay ignored — is execut by NOTHING. It is a guard that guards nothin and its silence is indistinguishable from succ THIS IS THE THIRD OCCURRENCE OF ONE CLASS. The driver's OWN comment at :1030 records the history: the same defect class "existed for tests/pre_build/test_*.sh" and was fixed by adding that directory to the glob. It t recurred one directory over (tests/hooks), fix the same way. Now tests/security. Each fix wa new glob entry; none addressed why a new t directory is invisible by default. §11.4.250 APPLIES DIRECTLY: three symptoms, one primitive. The primitive is a hand-maintaine enumeration that must be edited in lockstep the tree, whose failure mode is SILENT. It is t identical shape as BOB-205's DANGER_ROOTS and BOB-212's .gitignore allowlist — three separate hand-maintained lists in this repo, a three measured to have silently missed something. Adding tests/security to the glob

ATM ID	Type	Status	Severity	Description
				would be the fourth instance of layer N+1. NO THE GATE ALREADY HAS THE RIGHT INSTIN at :1220: it fails when the glob matches NOTH ("the glob is blind"). That guard catches a TOTALLY blind glob but not a PARTIALLY blin one — the more common and more dangerou case, because a partially blind glob still repor healthy count. FIX DIRECTION (§11.4.251 role data-pack): derive the suite set from the tree every tests/**/test_*.sh — minus a DECLARED §11.4.224(E) exclusion fence with a justificati per entry. Then a new test directory cannot b invisible, and a deliberate exclusion is visible and reasoned. If a hand list is kept, the omiss guard is the same computation, so the deriva must be built either way. ACCEPTANCE: (1) te security suites execute; (2) a NEWLY CREATE tests//test_x.sh is picked up with no hand edit that is the invariant that stops the recurrence and without it this is just the fourth patch; (3) RED creating such a directory and asserting i runs; (4) the :1220 blind-glob guard is extend to catch PARTIAL blindness, not only total. DISCOVERY CHANNEL (§11.4.238): found by t T042 readiness preflight. Not by the automat QA regime — and notably not by the two previous fixes of this same class, neither of w asked why it happened.
BOB-223	Bug	Queued	major	WHAT, both conductor-verified with control needles: CM-SCRIPT-DOCS-SYNC occurrences scripts/pre_build_verification.sh = 0 (control needle CM-MARKDOWN-EXPORT-SYNC = 6, so instrument sees). §11.4.44 revision-header enforcement likewise 0 hits (control needle 3 Neither §11.4.18's companion-doc mandate n §11.4.44's revision header is enforced by any invariant. THE PERVERSE CONSEQUENCE, MEASURED: a new script with NO companion doc passes the gate. Writing the companion d that §11.4.18 MANDATES creates docs/ scripts/.md, which invariant 16 (CM-MARKDOWN-EXPORT-SYNC) then requires to

ATM ID	Type	Status	Severity	Description
				have .html and .pdf twins — and their absenc a BLOCKING failure. This session hit it exactl docs/scripts/test_gitignore_swallow_is_loud. {html,pdf} are missing and are two of invaria 16's six violations. So the gate's incentive gradient points AWAY from the constitution: complying with §11.4.18 is punished, ignorin is free. That is worse than an ungated rule — a rule the machinery actively discourages. §11.4.227 IS THE GOVERNING ANCHOR: a na gate that exists only in prose is gate debt, and ledger of unimplemented CM-* names must b monotone-decreasing. CM-SCRIPT-DOCS-SYN named in §11.4.18's own text and implement nowhere — one concrete row of exactly the 5 unimplemented population §11.4.227 was mi to shrink. ACCEPTANCE: (1) either CM-SCRIPT DOCS-SYNC is implemented, or it is registered a deferral pointing at a tracked §11.4.197 iten silent absence is what §11.4.227 forbids; (2) s for §11.4.44's header check; (3) whichever is chosen, the incentive inversion is closed: it m never be cheaper to skip a mandated doc tha write one — if invariant 16 will demand twin the doc-creation path must produce them, or invariant 16 must scope out docs/scripts unti can; (4) a paired §1.1 mutation per gate implemented. HONEST NOTE ON SCOPE: this item does not argue §11.4.18 should be enfor immediately — that is an operator call about debt priority (§11.4.66). It argues the CURREN state is incoherent: an unenforced mandate whose observance triggers a different gate's failure. Either enforce both ends or neither. DISCOVERY CHANNEL (§11.4.238): found by t T042 readiness preflight while explaining wh new file broke invariant 16. Not by the automated QA regime.
BOB-224	Bug	Queued	critical	WHAT: a replication of invariant 30 (same gl same skip list, same BOBA_PREBUILD_NESTE same timeout 300) measured RAN=38 FAILED SKIPPED=2. One of the four failures is tests/u

ATM ID	Type	Status	Severity	Description
				test_compute_badges_carrier_match.sh exitin **rc=124 after the FULL 300 seconds** — it doe fail, it HANGS. WHY IT IS FILED SEPARATELY AND URGENTLY: it blocks invariant 30, and therefore T042, INDEPENDENTLY of BOB-221 The assumption in BOB-221 that landing an expected-RED mechanism unblocks T042 is FALSE as stated — two of the four failures ar REDs, one is this hang, one is contaminated. Landing the mechanism alone leaves T042 blocked by this suite. IT MUST NOT BE SILEN BY A DECLARATION. A hang is a §11.4.232(C) liveness failure, not a verdict: a wedged op a progressing op both look like "not finished ye and marking it expected-to-fail would conver §11.4.201(6) false-null into permanent cover. is exactly the abuse the expected-RED design property (2) exists to prevent, so it must be triaged as its own defect. INVESTIGATION DIRECTION (§11.4.102 first, no guessing): rc= is the timeout(1) signature. Determine WHER wedges — a consumer blocked on an unclose producer write-end is the documented shape here (§11.4.201(12) records that a backgroun watchdog spawned inside a $(...) command-substitution inherits the pipe write-end, and early disarm orphans its sleep grandchild, so substitution stalls for the FULL budget while every verdict and exit code stays CORRECT). signature — full budget, correct verdicts — matches rc=124 exactly and should be the FI hypothesis tested, not the last. The countermeasure is documented: redirect the watchdog subshell fds away from the cmd-su pipe, or have the probe write to a file. Do NO assume that is the cause; it is the highest-pric hypothesis given the recorded precedent. ACCEPTANCE: (1) the wedge point is identifie with captured evidence, not inferred; (2) the suite completes deterministically well inside budget; (3) a RED reproducing the hang, so a regression cannot silently re-wedge (a timeou based assertion, since the failure IS the

ATM ID	Type	Status	Severity	Description
				duration); (4) NOT closed by a declaration or raising the timeout — raising the budget hide FILE DATE: the suite is dated 2026-08-21, so th hang predates this session. DISCOVERY CHANNEL (§11.4.238): found by the BOB-221 design stream while surveying invariant 30 m widely than its brief required — the T042 preflight had verified only 3 of 38 suites and stated that boundary honestly, which is what prompted the wider survey.
BOB-225	Bug	Queued	major	WHAT, conductor-verified: .gitignore:266 igno *.docx globally. The §11.4.65 export pipeline GENERATES .docx twins — the workable-item export produces Issues.docx / Fixed.docx / Issues_Summary.docx / Fixed_Summary.docx and the doc exporter produced docs/scripts/ check_cm_lan_routes_authenticated.docx dur round 9. Every one of them is untrackable by construction: they exist on disk, git will neve them, and no gate can notice because the absence is silent. WHY THIS IS THE BOB-212 CLASS, NOT A DUPLICATE OF IT: BOB-212 is a deny-all glob plus a hand-maintained per-file ALLOWLIST, where new files leak through th gaps in the list. This is a deny-all glob with NO allowlist at all for a file type the project MANDATES producing. The mechanism diffe the false-null is identical — git status stays sil so the exporter appears to succeed and the artifact appears to exist. It is filed separately §11.4.214 (distinct-but-similar), with BOB-212 BOB-219 as siblings. THE TENSION TO RESOL HONESTLY: §11.4.153 mandates a FOUR-form export (HTML + PDF + DOCX) for its documen class, and §11.4.65 governs the twins general So the constitution requires producing an art the repository is configured to refuse. One of two is wrong and the resolution is an operato decision (§11.4.66): (a) the .docx mandate app here and the glob must carve out generated d twins; (b) .docx is deliberately untracked as a heavy binary derivative regenerable per §11

ATM ID	Type	Status	Severity	Description
				from its .md, in which case the EXPORTERS should stop producing it, or produce it into an explicitly untracked location, and the §11.4.1 four-format requirement should be recorded consciously not-adopted rather than silently unmet. What is NOT acceptable is the present state: generate it, ignore it, and let both the mandate and the glob appear satisfied. MEASURED SCOPE (CORRECTED — my first v of this item said 'tracked .docx files = 0', whic FALSE; recorded here per §11.4.6 rather than silently amended): **2** .docx files ARE tracked a **1140** exist repo-wide, so **1138** are untracked-a ignored. (A second correction, also recorded rather than amended: my first correction sai 344, which counted only the docs/ subtree. Tw numeric errors in a row on one item — the pattern is that each was measured with a narrower instrument than the claim it supported, which is the §11.4.201(7)(c) path-i part-of-the-instrument failure applied to my reporting.) AND THE TWO SURVIVORS ARE T INTERESTING PART: they are docs/features/ Status.docx and docs/features/ Status_Summary.docx — precisely the pair §11.4.153 explicitly mandates as a FOUR-form export. So the only two DOCX artifacts git car are the two a specific anchor named, and the survive not by rule but because they are alre in the index. That makes this a PARTIAL condition, not a total one, and the two surviv are the interesting part — they are in the sam position as frontend/e2e/credentials.spec.ts under BOB-212: alive only because they are already in the index, since git honours the in over .gitignore for tracked paths. One delete- re-add, one file move, and they vanish silentl like any other. So the state is worse than a cle 'we never track docx': it is an inconsistent on where two artifacts appear to prove the form IS tracked while 342 prove it is not. ACCEPTANCE: (1) the operator decision abov taken and recorded; (2) whichever way, the

ATM ID	Type	Status	Severity	Description
				exporter and the ignore rule AGREE — if .doc not tracked, nothing should silently generate into a tracked doc directory; (3) if carved out, check that a generated twin is actually tracka so this cannot recur silently; (4) §11.4.153 compliance is either met or recorded as an honest gap, never left implicitly failing. DISCOVERY CHANNEL (§11.4.238): found by t BOB-102 round-9 remediation stream when i regenerated its own guide twins and noticed the .docx could not be added. Not by the automated QA regime — and the regime cann see it, which is the point.
BOB-226	Task	Queued	major	WHAT: ownership_repair walks a declared r and repairs items whose uid is not the operat The unit suite seeds a foreign uid only onto F and SYMLINKS; interior DIRECTORIES stay operator-owned (case 22 seeds only a foreign declared ROOT, on the failure path). Producti first-start repairs exactly the untested shape. MANIFEST: tests/unit/test_ownership_repair. seed_tree/seed_wrong; scripts/ ownership_repair.sh walk at :994. REPRO: se tree whose interior directories carry uid 100 via podman unshare, run the repair, observe automated assertion covers the outcome. WH UNTESTED: the unprivileged harness cannot create symlinks inside a directory it no longe owns, which cases 8/9/18 require. The DECLA GAPS note cross-references tests/ownership/ test_container_writes_owned_files.py, but tha covers the CREATION side (FR-002), not the repair-side walk. ACCEPTANCE: an integratio layer test (where the unprivileged-harness constraint does not bind) that seeds foreign-owned interior directories, runs the repair, a asserts post-state ownership plus mode preservation. Surfaced by the BOB-207 independent review 2026-08-27.
BOB-227	Bug	Queued	critical	WHAT: three of the four artifacts of the CM-L ROUTES-AUTHENTICATED pre-build gate are untracked in git. MEASURED 2026-08-27 with

ATM ID	Type	Status	Severity	Description
				ls-files –error-unmatch, control-needled agai known-tracked file: scripts/pre_build/ lan_route_auth_analyzer.py UNTRACKED, scr pre_build/check_cm_lan_routes_authenticate UNTRACKED, tests/pre_build/ test_check_cm_lan_routes_authenticated.sh UNTRACKED; only docs/scripts/ check_cm_lan_routes_authenticated.md is TRACKED. IMPACT: (1) losing this checkout lo an entire security gate plus 197 assertions; (2 round-over-round diff claim across review rounds 8 through 14 was ever checkable, bec no committed baseline exists - the same §11.4 evidence-custody failure the BOB-195 chain h independently; (3) a fresh clone runs a pre-bu gate whose implementation is absent. ACCEPTANCE: all four artifacts tracked and committed, and a gate asserting that every executable a pre-build invariant invokes is it tracked. Surfaced by the BOB-102 round-13 remediation and independently verified 2026-08-27.
BOB-228	Task	Queued	minor	WHAT: §11.4.212 makes the main README th canonical entry point for ALL project documentation, with no §11.4.65-scope doc reachable by no link path. docs/scripts/ check_cm_lan_routes_authenticated.md is no reachable from README.md. MEASURED 2026-08-27: grep -c for the guide name in README.md returns 0, control-needled agai doc README does link (CONTINUATION retu 1), so the instrument is not blind. ACCEPTANC README links the guide directly or transitive and the doc-link generator covers docs/script the next such guide cannot land orphaned. Surfaced by the BOB-102 round-13 remediati and independently verified 2026-08-27.